

Marc Carot Figueres

Assistent de Seguretat de Transaccions Web3 mitjançant MetaMask Snaps

Enginyeria Informàtica

Treball de Fi de Grau

Dirigit pel

Dr. Jordi Castellà Roca i Ignacio Miguel Rodríguez



UNIVERSITAT ROVIRA I VIRGILI

Tarragona, 2026

Índex

Resum	vi
Resumen	vii
Abstract	viii
1 Introducció	1
1.1 Objectius	2
1.2 Justificació	3
1.3 Planificació	4
1.4 Organització de la memòria	5
2 Background	6
2.1 Tecnologia	6
2.2 Solucions existents	7
2.3 Diferenciació de la proposta	7
3 Disseny de la proposta	9
3.1 Requisits funcionals	9
3.2 Requisits no funcionals	9
3.3 Model d'amenaques i supòsits de confiança	10
3.3.1 Actius que es volen protegir	10
3.3.2 Amenaces contemplades	11
3.3.3 Supòsits de confiança	11
3.3.4 Elements fora de l'abast	12
3.4 Actors principals	13
3.5 Arquitectura del sistema	14
3.5.1 Flux de comunicació	15
3.5.2 Casos d'ús principals	15
3.6 Decisions de Disseny	18
3.6.1 Separació de responsabilitats i Snap lleuger	18
3.6.2 Prioritat del motor determinista	19
3.6.3 Motivació de l'ús d'IA local	20
4 Implementació	21
4.1 Entorn d'implementació i execució del prototip	21
4.1.1 Control de versions i repositori del projecte	22
4.2 DApp local de proves i monitorització	22
4.3 Implementació del Snap	23
4.3.1 Estructura general del Snap	23
4.3.2 Permisos i configuració	23
4.3.3 Interacció manual mitjançant <code>onRpcRequest</code>	23
4.3.4 Intercepció automàtica de transaccions amb <code>onTransaction</code>	24
4.3.5 Comunicació amb el backend	24
4.3.6 Presentació dels <i>insights</i> dins MetaMask	24
4.4 Implementació del backend d'anàlisi	25
4.4.1 Estructura general del backend	25

4.4.2	Recepció de la transacció	27
4.4.3	Normalització i descodificació de la petició	27
4.4.4	Motor de regles deterministes	27
4.4.5	Persistència local i memòria d'anàlisi	28
4.4.6	Fonts externes de context i adreces conegudes	29
4.4.7	Construcció de la resposta	31
4.5	Integració del mòdul d'intel·ligència artificial	33
4.5.1	Paper de la IA dins del sistema	33
4.5.2	Integració tècnica i selecció del model	33
4.5.3	Generació d'explicacions	34
4.5.4	Revisió complementària de la IA	34
4.5.5	Control semàntic de la resposta	34
4.5.6	Construcció dels prompts	35
5	Avaluació	37
5.1	Infraestructura i preparació de l'avaluació	37
5.1.1	Contractes intel·ligents i entorn de proves	37
5.1.2	Disseny dels contractes de prova	38
5.1.3	Connexió amb Sepolia i ús de l'RPC	39
5.1.4	Compilació i desplegament amb Hardhat	39
5.1.5	Verificació del contracte a Etherscan	39
5.1.6	Preparació de les operacions de prova	40
5.1.7	Protocol d'execució i recollida d'evidències	41
5.1.8	Monitorització i inspecció dels resultats	45
5.2	Estratègia d'avaluació i traçabilitat dels requisits	45
5.3	Escala de puntuació del risc	48
5.4	Escenaris de prova i resultats	50
5.4.1	Escenari A – Interceptació bàsica i visualització dins de MetaMask	50
5.4.2	Escenari B – Aprovació ERC20 limitada i revocació	51
5.4.3	Escenari C – Aprovació ERC20 pràcticament il·limitada	52
5.4.4	Escenari D – Permís global ERC721 sobre NFTs	52
5.4.5	Escenari E – Context local i adreces etiquetades	53
5.4.6	Escenari F – Explicació de la IA i control semàntic	54
5.4.7	Escenari G – Flux complet sobre Sepolia i Etherscan	55
5.4.8	Escenari H – Rendiment i comportament davant d'errors	55
5.5	Anàlisi dels resultats	57
5.5.1	Matriu de confusió i mètriques de classificació	57
5.5.2	Síntesi del compliment dels requisits	60
5.5.3	Abast i interpretació dels resultats	62
6	Conclusions	63
6.1	Treball futur	63
6.2	Competència CT7: principis ètics i de responsabilitat social	64
6.2.1	Igualtat	64
6.2.2	Medi ambient	65
6.2.3	Responsabilitat social	65
6.2.4	Ètica	66
	Referències	67

A	Instruccions d'instal·lació i execució	70
A.1	Requisits previs	70
A.2	Descàrrega del repositori	70
A.3	Instal·lació de les dependències	70
A.4	Instal·lació del model local	71
A.5	Configuració de les variables d'entorn	71
A.6	Execució dels components	71
A.6.1	Backend local	71
A.6.2	Snap	72
A.6.3	DApp local	72
A.7	Ordre recomanat d'inicialització	72
B	Estructura de les peticions i respostes JSON	72
B.1	Petició enviada pel Snap	73
B.2	Resposta representativa del backend	73
B.3	Persistència i detall	74
C	Configuració de Sepolia i contractes despleats	74
C.1	Configuració de la xarxa	74
C.2	Contractes despleats	75
C.3	Verificació dels contractes	75

Índex d'exemples de codi

1	Fragment representatiu del <i>prompt</i> utilitzat per generar explicacions amb Ollama	36
2	Fragment simplificat de la funció <code>approveSpending</code> del contracte de prova	38

Índex de figures

1	Planificació general del projecte per fases	4
2	Visió general del sistema d'assistència abans de la confirmació d'una transacció	14
3	Flux complet d'execució del prototip, des de la generació de la transacció fins a la decisió final de l'usuari	15
4	Diagrama de seqüència dels casos CU1 i CU4: anàlisi prèvia i decisió final	17
5	Diagrama de seqüència del cas CU2: anàlisi d'una aprovació ERC20 . .	17
6	Diagrama de seqüència del cas CU3: activació o revocació d'un permís global NFT	18
7	Diagrama UML lògic dels mòduls, serveis i dependències principals del prototip	26
8	Estructura de la taula <code>analysis_history</code> a la base de dades SQLite local	30
9	Registres d'anàlisi persistits a la base de dades SQLite local	30
10	Consulta i filtratge del conjunt local d'adreces conegudes	31
11	<i>Pipeline</i> intern del <i>backend</i> d'anàlisi	32
12	Contracte <code>SecurityTestContract</code> verificat a Etherscan sobre la xarxa Sepolia	40
13	Execució d'una operació sobre el contracte des de la interfície	41
14	Monitorització agregada dels resultats obtinguts durant l'avaluació . . .	46
15	Inspecció del veredict i dels indicadors d'una aprovació ERC20 il·limitada	46
16	Evidència de descodificació, revisió complementària, veredict i rendiment	47
17	Insight del Snap mostrat abans de confirmar la transacció	51
18	Detecció d'una aprovació ERC20 limitada iniciada des d'Etherscan . . .	51
19	Aprovació ERC20 amb <code>MaxUint256</code> classificada com a risc alt abans de confirmar-la	52
20	Diferenciació entre l'activació i la revocació d'un permís global ERC721	53
21	Incorporació d'una etiqueta local de risc al veredict de l'escenari E . .	54
22	Validació del sanejament semàntic aplicat a una transferència simple . .	55
23	Transacció confirmada a Sepolia i activitat corresponent a MetaMask .	56
24	Resposta determinista després d'aturar Ollama i aplicar el fallback local	56
25	Matriu de confusió de la classificació de risc	59

Índex de taules

1	Comparativa resumida entre l'enfocament predominant en eines de seguretat Web3 i l'enfocament adoptat en la proposta	8
2	Casos d'ús principals del sistema	16
3	Serveis locals del prototip, ports assignats i funció principal	21
4	Responsabilitats principals dels mòduls del <i>backend</i>	26
5	Configuració de l'entorn utilitzat durant l'avaluació	42
6	Traçabilitat entre requisits i mecanismes de validació	48
7	Puntuacions base assignades pel motor determinista a cada patró . . .	49

8	Ajustos aplicats a la puntuació segons el context d'adreces conegudes .	49
9	Classificació dels casos utilitzats per construir la matriu de confusió . .	58
10	Mètriques obtingudes a partir de la matriu de confusió	60
11	Síntesi del compliment dels requisits del sistema	61
12	Configuració de la xarxa utilitzada durant les proves	74
13	Contractes intel·ligents desplegats a Sepolia	75
14	Informació tècnica dels contractes desplegats	75

Resum

L'augment de l'ús d'aplicacions descentralitzades basades en blockchain ha incrementat la necessitat de millorar la seguretat durant la signatura de transaccions. En molts casos, els usuaris autoritzen operacions sense comprendre completament les implicacions dels permisos concedits a contractes intel·ligents, especialment en casos com les aprovacions il·limitades de tokens o els permisos globals sobre actius NFT.

Aquest treball presenta el disseny i la implementació d'un assistent de seguretat Web3 integrat dins de MetaMask mitjançant MetaMask Snaps. El sistema intercepta transaccions abans de la seva confirmació, n'analitza la informació rellevant i genera un veredict basat en regles deterministes. Un model d'intel·ligència artificial local, executat amb Ollama, aporta una revisió complementària i explicacions en llenguatge natural per facilitar la comprensió de l'operació.

La proposta adopta una arquitectura modular formada per un Snap, un backend local d'anàlisi, una base de dades SQLite per mantenir historial i context local, i contractes intel·ligents de prova desplegats a Sepolia. El sistema permet identificar patrons de risc relacionats amb aprovacions ERC20 i permisos globals ERC721, integrant el resultat directament dins de la interfície de confirmació de MetaMask.

L'avaluació de 80 execucions controlades va obtenir una exactitud del 91,25 % i va identificar set falsos negatius en aprovacions extraordinàriament elevades, però diferents de `MaxUint256`. El flux complet es va confirmar sobre Sepolia. Els resultats delimiten amb precisió la cobertura actual i situen l'ampliació de les regles i l'optimització del model local com a treball futur.

Paraules clau— Web3, MetaMask Snaps, Seguretat, Blockchain, Contractes Intel·ligents, Intel·ligència Artificial Generativa, IA Local, Privadesa.

Resumen

El aumento del uso de aplicaciones descentralizadas basadas en blockchain ha incrementado la necesidad de mejorar la seguridad durante la firma de transacciones. En muchos casos, los usuarios autorizan operaciones sin comprender por completo las implicaciones de los permisos concedidos a contratos inteligentes, especialmente en casos como las aprobaciones ilimitadas de tokens o los permisos globales sobre activos NFT.

Este trabajo presenta el diseño y la implementación de un asistente de seguridad Web3 integrado en MetaMask mediante MetaMask Snaps. El sistema intercepta transacciones antes de su confirmación, analiza su información relevante y genera un veredicto basado en reglas deterministas. Un modelo de inteligencia artificial local, ejecutado con Ollama, aporta una revisión complementaria y explicaciones en lenguaje natural para facilitar la comprensión de la operación.

La propuesta adopta una arquitectura modular formada por un Snap, un backend local de análisis, una base de datos SQLite para mantener historial y contexto local, y contratos inteligentes de prueba desplegados en Sepolia. El sistema permite identificar patrones de riesgo relacionados con aprobaciones ERC20 y permisos globales ERC721, integrando el resultado directamente dentro de la interfaz de confirmación de MetaMask.

La evaluación de 80 ejecuciones controladas obtuvo una exactitud del 91,25 % e identificó siete falsos negativos en aprobaciones extraordinariamente elevadas, pero distintas de `MaxUint256`. El flujo completo se confirmó sobre Sepolia. Los resultados delimitan con precisión la cobertura actual y sitúan la ampliación de las reglas y la optimización del modelo local como trabajo futuro.

Palabras Clave — Web3, MetaMask Snaps, Seguridad, Blockchain, Contratos Inteligentes, Inteligencia Artificial Generativa, IA Local, Privacidad.

Abstract

The rise of decentralized blockchain-based applications has increased the need to improve security during transaction signing. In many cases, users authorize operations without fully understanding the implications of the permissions granted to smart contracts, especially in cases with unlimited token approvals or global permissions over NFT assets.

This project presents the design and implementation of a Web3 security assistant integrated with MetaMask using MetaMask Snaps. The system intercepts transactions before confirmation, analyzes the relevant information, and generates a verdict based on deterministic rules. A local AI model, executed with Ollama, provides a complementary review and natural-language explanations to help users understand the operation.

The proposal adopts a modular architecture consisting of a Snap, a local analysis backend, an SQLite database to maintain history and local context, and test smart contracts deployed to Sepolia. The system identifies risk patterns related to ERC20 approvals and ERC721 global permissions, integrating the results directly into the MetaMask confirmation interface.

The evaluation of 80 controlled executions achieved 91.25 % accuracy and identified seven false negatives for extraordinarily high approvals below `MaxUint256`. The complete flow was confirmed on Sepolia. These results accurately delimit the current coverage and identify rule expansion and local-model optimization as future work.

Keywords — Web3, MetaMask Snaps, Security, Blockchain, Smart Contracts, Generative Artificial Intelligence, Local AI, Privacy.

1 Introducció

En els darrers anys, l'ús d'aplicacions basades en *blockchain* s'ha consolidat i ha donat lloc al que sovint s'anomena *Web3*, és a dir, un conjunt d'aplicacions i serveis que permeten interactuar amb xarxes descentralitzades per transferir valor o executar lògica programable sense un control central únic [1, 2]. En aquest context, el concepte de *descentralització* fa referència a un model on el registre i la validació d'operacions no depèn d'una sola entitat, sinó d'una xarxa de participants; en contraposició, els sistemes *centralitzats* deleguen la custòdia i el control a un intermediari (p. ex., una plataforma o un banc).

Una de les conseqüències d'aquest canvi és que l'usuari passa a gestionar directament els seus *actius digitals* mitjançant una *cartera digital* (*wallet*), que és el programari que administra les claus criptogràfiques i permet autoritzar operacions a la xarxa [1]. Les aplicacions descentralitzades (*DApps*) solen comunicar-se amb aquestes carteres a través d'una interfície estàndard al navegador. A la pràctica, això significa que quan l'usuari interactua amb una *DApp*, aquesta pot sol·licitar accions com l'enviament d'una *transacció* (que no deixa de ser una operació que modifica l'estat a la *blockchain* i pot implicar transferència de valor) o altres autoritzacions associades a contractes intel·ligents.

Tot i les oportunitats que ofereix aquest ecosistema, una problemàtica recurrent és que molts usuaris autoritzen operacions sense comprendre'n el contingut real. Aquest fenomen es coneix com a *blind signing* (signatura a cegues): l'usuari aprova una operació sense disposar d'una descripció clara del que implica, sovint perquè la cartera només mostra dades tècniques o incompletes [3, 4]. Aquesta manca de comprensió és especialment crítica quan la transacció inclou crides a contractes intel·ligents, ja que poden incorporar permisos persistents o accions complexes que no són evidents a simple vista.

Els informes de seguretat del sector assenyalen pèrdues econòmiques significatives associades a estafes, *hacks* i explotacions en l'àmbit *Web3*. Per exemple, Chainalysis estima que els fons robats a plataformes cripto van augmentar i van assolir xifres de l'ordre de milers de milions de dòlars en el darrer any analitzat [5, 6], i CertiK reporta pèrdues agregades també de diversos milers de milions en incidents *on-chain* en el mateix període [7]. Aquestes dades reflecteixen que, més enllà dels atacs tècnics, una part del risc es materialitza en el moment en què l'usuari accepta una operació que no entén prou bé.

Davant d'aquest escenari, es fa necessari disposar d'eines que augmentin la transparència i la comprensió en el pas previ a la confirmació. En aquest sentit, les carteres digitals poden esdevenir un punt d'intervenció especialment rellevant, ja que constitueixen l'espai on l'usuari acaba validant l'operació. Més concretament, MetaMask incorpora un sistema de funcionalitats addicionals, anomenat *MetaMask Snaps*, que permet estendre el comportament de la cartera i desenvolupar mecanismes capaços d'aportar context, explicacions i *transaction insights* abans que l'usuari signi [8–11].

En aquest treball es proposa i s'implementa un assistent de seguretat integrat com a Snap, capaç d'interceptar transaccions abans de la confirmació, analitzar-les mitjançant regles deterministes per identificar patrons de risc i generar explicacions en llenguatge natural. L'objectiu és reduir la signatura a cegues i facilitar decisions in-

formades, mantenint la privadesa mitjançant execució local dels components d'anàlisi i d'explicació.

1.1 Objectius

L'objectiu principal d'aquest treball és dissenyar i implementar un sistema capaç d'assistir l'usuari durant el procés de signatura de transaccions en entorns Web3, proporcionant informació clara sobre les implicacions de cada acció abans de la seva confirmació.

Per assolir aquest objectiu general, el projecte planteja diverses fites específiques. En primer lloc, desenvolupar un mecanisme d'interceptació de transaccions que permeti analitzar-les abans que siguin executades. En segon lloc, implementar un sistema d'anàlisi capaç de detectar patrons potencialment perillosos associats a autoritzacions excessives o operacions de risc elevat. En tercer lloc, generar explicacions en llenguatge natural que tradueixin la informació tècnica a un format comprensible per a usuaris no especialitzats. Finalment, validar el sistema en un entorn de proves realista que permeti avaluar-ne el comportament, el rendiment i les limitacions.

El projecte es concep com una solució modular i extensible, amb la voluntat de servir com a base per a futures ampliacions i millores en l'àmbit de la seguretat i l'explicabilitat (és a dir, la capacitat d'explicar de manera clara i entenedora per què una transacció pot ser arriscada i què implica) en aplicacions descentralitzades.

1.2 Justificació

L'ecosistema *blockchain* i el mercat dels actius digitals han experimentat un creixement sostingut durant els darrers anys. Segons dades de Triple-A, l'any 2024 el nombre de persones que posseïen criptomonedes al món superava els 560 milions, amb un increment interanual del 34% respecte de 2023 [12]. Aquest augment fa que cada vegada més usuaris accedeixin a serveis basats en *blockchain* sense una formació tècnica específica, fet que incrementa la probabilitat d'errors d'interpretació i les decisions poc informades en el moment de signar operacions.

Aquest increment d'adopció no només amplia l'ús de les tecnologies descentralitzades, sinó també la seva superfície d'exposició al risc. Informes recents de Chainalysis i CertiK mostren que les pèrdues associades a robatoris, estafes i explotacions dins l'ecosistema cripto continuen assolint xifres molt elevades, amb milers de milions de dòlars compromesos anualment [5–7]. En molts casos, aquests incidents no depenen únicament d'un error tècnic del protocol, sinó també del fet que l'usuari autoritza transaccions o permisos sense entendre amb precisió què impliquen.

Aquesta situació posa en evidència una mancança important en les eines actuals d'interacció amb Web3. Tot i que existeixen solucions comercials orientades a la detecció de riscos, moltes basen el seu funcionament en serveis externs, criteris de classificació opacs o avisos genèrics que adverteixen, però no expliquen [8, 11]. Això limita la capacitat de l'usuari per comprendre el motiu real del risc i, en conseqüència, per prendre decisions informades. En aquest sentit, la proposta es justifica no sols per la necessitat de reforçar la seguretat, sinó també per la d'augmentar la comprensió i la transparència en el procés de signatura de transaccions.

A partir d'aquest context, el treball se centra en tres eixos principals: privadesa, explicabilitat i transparència. La privadesa s'entén com la voluntat de minimitzar l'exposició de dades sensibles a tercers; l'explicabilitat, com la capacitat del sistema d'indicar no només si una acció pot ser arriscada, sinó també per què ho és d'una manera clara i comprensible; i la transparència, com l'ús de criteris d'avaluació entenedors i auditable.

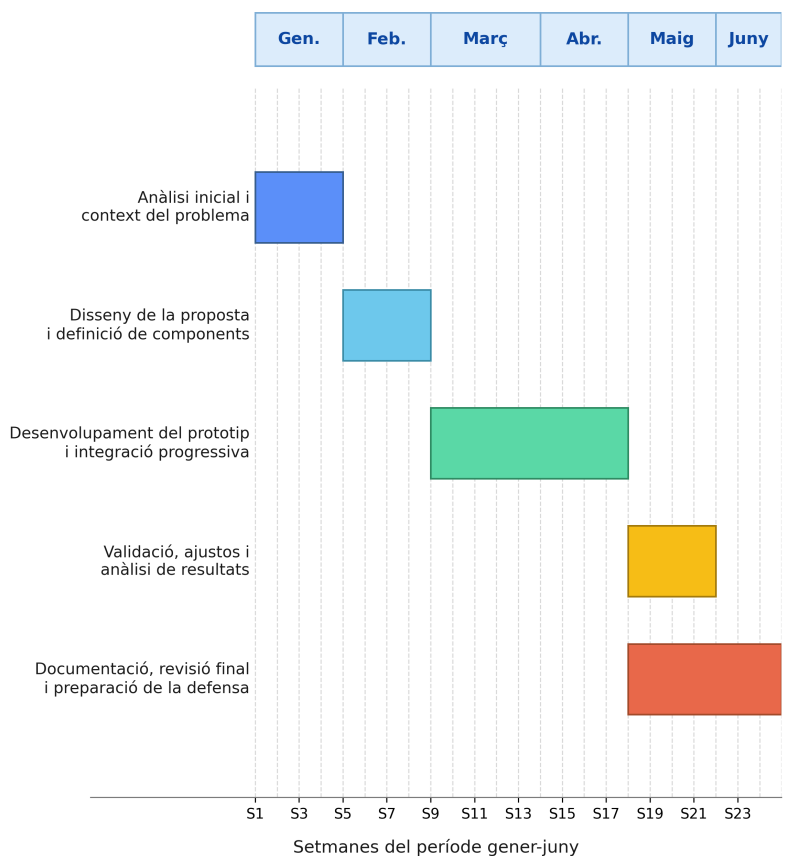
Des d'un punt de vista acadèmic, aquest sistema resulta rellevant perquè combina àmbits d'interès actual com la seguretat informàtica, les aplicacions descentralitzades i la intel·ligència artificial aplicada. A més, es planteja dins un marc tècnicament viable, basat en eines de codi obert, entorns de prova públics i una arquitectura modular que permet abordar el problema de manera progressiva. Aquest plantejament fa possible desenvolupar una solució funcional amb recursos assumibles, alhora que obre la porta a futures ampliacions i línies de treball posteriors.

1.3 Planificació

La planificació del projecte s'ha plantejat de manera progressiva al llarg de diversos mesos, des de la fase inicial d'anàlisi fins a la redacció final de la memòria. Atès que es tracta d'un treball amb una forta component pràctica i d'investigació, l'organització temporal no s'ha orientat a una execució estrictament lineal, sinó a una evolució per fases que permeti avançar de forma incremental.

En una primera etapa s'ha previst la definició del problema, l'estudi del context tecnològic i la identificació de les necessitats que justifiquen la proposta. A continuació, es planteja una fase centrada en el disseny del sistema i la definició dels seus components principals. Posteriorment, es preveu el desenvolupament del prototip i la integració dels diferents elements necessaris per al seu funcionament. Finalment, el procés es completa amb la validació experimental, l'anàlisi dels resultats i la preparació de la documentació definitiva.

Planificació general del projecte per fases



Cada marca de l'eix horitzontal correspon a una setmana. La figura mostra únicament les fases principals; el desglossament detallat de subtasques es desenvolupa en el text de la memòria.

Figura 1: Planificació general del projecte per fases

La Figura 1 mostra la planificació general del projecte distribuïda en fases principals. Per facilitar-ne la lectura, el diagrama s'ha simplificat a un nivell macro, mentre que el detall de subtasques i activitats específiques es descriu en el text. Cada marca de l'eix horitzontal correspon a una setmana del període comprès entre gener i juny.

Des d'un punt de vista organitzatiu, aquesta planificació permet distingir clarament entre les fases de comprensió del problema, definició de la proposta, desenvolupament, validació i tancament. Tot i això, cal tenir en compte que en un projecte d'aquestes característiques poden aparèixer iteracions entre fases, especialment entre el disseny, la implementació i les proves. Per aquest motiu, el diagrama s'ha d'interpretar com una previsió orientativa que estructura el treball i en facilita el seguiment, més que no pas com una seqüència rígida i tancada.

1.4 Organització de la memòria

La memòria s'estructura en sis capítols que presenten de manera progressiva el context, el disseny, la implementació i l'avaluació del sistema desenvolupat.

El Capítol 2 proporciona el context tecnològic necessari per comprendre la proposta: Web3, blockchain, Ethereum, contractes intel·ligents, carteres digitals i MetaMask Snaps. També hi revisa algunes solucions de seguretat existents i els elements diferenciadors del sistema proposat.

El Capítol 3 presenta el disseny de la proposta. S'hi defineixen els requisits funcionals i no funcionals, els actors, l'arquitectura general, el flux de comunicació i els casos d'ús principals, i s'hi justifiquen les decisions de disseny adoptades.

El Capítol 4 descriu la implementació tècnica del prototip: l'entorn d'execució, la DApp local, el Snap, el backend d'anàlisi, la base de dades local i la integració amb Ollama.

El Capítol 5 se centra en l'avaluació. S'hi descriu l'estratègia i el protocol de proves, es presenten els escenaris amb els resultats observats i s'analitza la capacitat de classificació mitjançant una matriu de confusió, juntament amb el grau de compliment dels requisits.

El Capítol 6 valora l'assoliment dels objectius, resumeix els resultats i els problemes detectats, proposa línies de treball futur i inclou una reflexió sobre els aspectes ètics, socials i ambientals. Finalment, la memòria incorpora les referències bibliogràfiques utilitzades durant el desenvolupament.

2 Background

Aquesta secció introdueix, de manera breu, els conceptes, eines i tecnologies que serveixen de base per al desenvolupament de la proposta. L'objectiu no és aprofundir-hi com en un manual tècnic, sinó oferir al lector el context mínim necessari per entendre els elements que intervenen en el sistema i el paper que cadascun d'ells té dins del projecte.

2.1 Tecnologia

La proposta s'emmarca dins l'ecosistema *Web3*, un conjunt d'aplicacions i serveis que utilitzen tecnologies descentralitzades per transferir valor o executar lògica programable sense dependre d'un intermediari únic. La base d'aquest ecosistema és la *blockchain*, un registre distribuït on les operacions es validen i s'emmagatzemen de manera compartida entre els participants de la xarxa. Cada operació confirmada queda registrada de forma persistent i pot ser consultada posteriorment.

Dins d'aquest context, una transacció és una petició signada digitalment que pot transferir actius, executar una funció d'un contracte intel·ligent o modificar l'estat de la xarxa. Aquestes transaccions són especialment rellevants en el projecte, ja que poden incloure instruccions que no resulten evidents per a l'usuari, com ara autoritzacions perquè un contracte extern gestioni tokens o actius NFT.

Ethereum és una plataforma *blockchain* que permet executar *smart contracts*, és a dir, programes desplegats a la xarxa que poden gestionar actius o implementar lògica de negoci de manera descentralitzada [1, 13]. Moltes de les aplicacions construïdes sobre Ethereum es coneixen com a aplicacions descentralitzades o *DApps*, i acostumen a comunicar-se amb la cartera de l'usuari mitjançant l'estàndard EIP-1193, que defineix una interfície comuna per als proveïdors Ethereum al navegador [14].

Per interactuar amb aquestes aplicacions, els usuaris utilitzen carteres digitals, que són les eines encarregades de custodiar les claus criptogràfiques i autoritzar operacions a la xarxa. En aquest projecte s'utilitza MetaMask, una de les carteres més esteses en l'ecosistema Ethereum i, més concretament, la seva extensibilitat mitjançant MetaMask Snaps, una funcionalitat llançada públicament per Consensus el 2023 [11]. Els Snaps permeten ampliar el comportament de la cartera mitjançant mòduls que operen en un entorn aïllat i sotmès a permisos específics, incloent la generació de *transaction insights*, és a dir, missatges o indicacions que aporten context i informació rellevant sobre una transacció abans que l'usuari la signi [8–10].

Una part important de les transaccions dirigides a contractes intel·ligents consisteix a concedir permisos. En els tokens fungibles, habitualment basats en l'estàndard ERC20 [15], una operació d'aprovació pot autoritzar una altra adreça a utilitzar una quantitat determinada de tokens en nom de l'usuari. En els actius no fungibles o NFTs, estàndards com ERC721 [16] permeten concedir permisos globals mitjançant operacions com `setApprovalForAll`, que autoritzen un operador a gestionar tots els actius d'una col·lecció concreta. Aquest tipus d'autoritzacions constitueix un dels principals patrons de risc analitzats en aquest treball.

Des del punt de vista del desenvolupament, en aquest projecte els contractes intel·ligents de prova s'han escrit en Solidity, el llenguatge més habitual dins l'ecosistema

Ethereum, i s'han gestionat amb Hardhat, l'eina utilitzada per compilar, provar i desplegar els contractes durant el desenvolupament [13, 17]. Aquesta combinació permet construir escenaris controlats sobre una xarxa de prova i validar el comportament del sistema en condicions pròximes a un cas real.

Ateses les limitacions de l'entorn d'execució dels Snaps, el sistema es planteja amb una arquitectura modular en què la cartera i el Snap assumeixen la intercepció i la presentació de la informació, mentre que l'anàlisi i la generació d'explicacions es deleguen a components auxiliars. En aquest marc, la capa explicativa es recolza en models de llenguatge extensos (*Large Language Models*, LLM), és a dir, models d'**intel·ligència artificial generativa** capaços de produir text en llenguatge natural a partir del context disponible. Al llarg de la memòria, els termes *LLM*, *model de llenguatge* i *IA generativa* s'utilitzen de manera equivalent per referir-se a aquest component. Per a l'execució local d'aquests models, el projecte utilitza Ollama [18, 19].

En conjunt, el sistema combina dos mecanismes complementaris: d'una banda, un conjunt de regles deterministes per detectar patrons de risc; de l'altra, un model de llenguatge local per transformar els resultats tècnics en explicacions comprensibles per a l'usuari.

2.2 Solucions existents

En els darrers anys han aparegut diverses eines orientades a reforçar la seguretat en carteres i interaccions Web3. Entre les aproximacions més habituals es troben les extensions de navegador orientades a detectar estafes o *wallet drainers*, com Wallet Guard i Pocket Universe [20, 21]; les plataformes de simulació i validació de transaccions, com Blockaid [22]; i els serveis que agreguen intel·ligència de risc a partir de fonts externes o integren mecanismes propis de protecció dins la cartera, com Blockfence o Rabby [23, 24]. Aquestes solucions evidencien que el problema és real i que existeix una demanda clara de mecanismes d'assistència abans de la signatura.

Tot i això, moltes d'aquestes eines comparteixen algunes limitacions recurrents. En primer lloc, sovint depenen de serveis externs per classificar o simular transaccions, fet que introdueix qüestions de privadesa i dificulta entendre amb claredat els criteris utilitzats en l'anàlisi. En segon lloc, en nombrosos casos la interacció amb l'usuari se centra en l'alerta o el bloqueig, però no en l'explicació detallada del perquè una acció és arriscada. Finalment, l'extensibilitat del sistema acostuma a quedar condicionada pel model del proveïdor i per la poca visibilitat sobre el funcionament intern de les seves eines.

2.3 Diferenciació de la proposta

A partir de les limitacions observades en les eines existents, la proposta d'aquest projecte se centra a cobrir tres mancances principals: la dependència de serveis externs, la manca d'explicacions comprensibles per a l'usuari i la dificultat d'entendre, revisar o justificar els criteris de detecció aplicats.

En aquest sentit, la solució plantejada adopta un enfocament basat en processament local sempre que és possible, ús de regles deterministes per a la detecció de patrons de risc i generació d'explicacions en llenguatge natural amb l'objectiu d'ajudar l'usuari a entendre què està autoritzant abans de confirmar una transacció. Aquest plantejament

no pretén substituir completament altres eines del sector, sinó oferir una resposta específica a algunes de les seves mancances més habituals, especialment en els àmbits de la privadesa, la transparència i l'explicabilitat.

La Taula 1 resumeix aquesta diferenciació des d'un punt de vista sintètic, posant el focus en les diferències d'enfocament entre les solucions habituals del sector i la proposta desenvolupada en aquest projecte.

Aspecte	Solucions existents (tendència general)	Proposta del projecte
Moment d'intervenció	Habitualment durant la revisió de la transacció o immediatament abans de la signatura, sovint en forma d'avisos o alertes	Intervenció prèvia a la confirmació: l'usuari rep context abans de signar
Criteris de detecció	Sovint opacs o poc explicats (heurístiques internes o reputació)	Regles deterministes auditable (p. ex. permisos il·limitats i permisos globals)
Explicació a l'usuari	Alertes breus o tècniques, poc orientades a comprensió	Explicació en llenguatge natural per facilitar decisió informada
Privadesa i dades	Dependència freqüent de serveis externs per enriquir o classificar	Processament local sempre que és possible (inclosa IA local), reduint exposició de dades
Integració amb la cartera	Extensió externa o servei web independent	Integració dins l'experiència de la cartera mitjançant Snap (<i>insight</i> abans de confirmar)
Extensibilitat	Limitada pel proveïdor i el seu model d'actualitzacions	Arquitectura modular: motor de regles i capa d'explicació ampliables amb nous casos

Taula 1: Comparativa resumida entre l'enfocament predominant en eines de seguretat Web3 i l'enfocament adoptat en la proposta

La comparació s'ha plantejat en termes d'enfocament general, ja que l'objectiu no és elaborar una revisió exhaustiva del mercat, sinó identificar les mancances més rellevants que la proposta intenta abordar.

3 Disseny de la proposta

En aquest capítol es descriuen els requisits del sistema i l'arquitectura proposada, així com els actors principals, les funcionalitats i les decisions de disseny adoptades.

3.1 Requisits funcionals

RF1 – Interceptació de transaccions

El sistema ha de ser capaç d'interceptar les sol·licituds de transaccions abans de la seva confirmació dins la cartera digital. Aquesta funcionalitat constitueix el punt d'entrada per a l'anàlisi de seguretat.

RF2 – Anàlisi de risc basat en regles

El sistema ha d'avaluar cada transacció a partir d'un conjunt de regles i heurístiques que permetin estimar-ne el nivell de risc i detectar patrons especialment sensibles, com ara aprovacions il·limitades o permisos globals sobre col·leccions.

RF3 – Generació d'explicacions comprensibles

El sistema ha de traduir el resultat tècnic de l'anàlisi a una explicació en llenguatge natural que permeti a l'usuari entendre les implicacions de l'operació. En aquest requisit, es considera comprensible una explicació que pugui ser interpretada per una persona sense coneixements previs de Web3: ha d'indicar l'acció principal i la seva conseqüència amb frases breus, emprar vocabulari planer i evitar, o aclarir quan siguin imprescindibles, tecnicismes com ara *calldata*, *ABI*, *wei* o selectors de funció. També ha de destacar de manera explícita qualsevol permís o risc rellevant per facilitar una decisió informada abans de confirmar la transacció.

RF4 – Integració dins la interfície de la cartera

La informació generada ha de mostrar-se abans de la confirmació de la transacció, integrada dins la interfície de l'usuari.

3.2 Requisits no funcionals

RNF1 – Rendiment

El temps total d'anàlisi i generació de la resposta ha de ser prou reduït per mantenir una experiència d'ús fluida. Atès que el sistema integra diversos components, es considera acceptable una resposta en pocs segons, sempre que la interfície proporcioni *feedback* clar quan el processament no sigui immediat [25].

RNF2 – Privadesa

Les dades analitzades han de romandre, sempre que sigui possible, dins l'entorn local de l'usuari, minimitzant l'enviament d'informació a serveis externs durant el procés d'avaluació.

RNF3 – Fiabilitat

En cas d'error d'algun component, el sistema no ha d'impedir l'execució de la transacció.

RNF4 – Extensibilitat

L'arquitectura ha de permetre incorporar noves regles d'anàlisi o millores futures sense redissenyar el sistema complet.

RNF5 – Usabilitat

Les explicacions generades han de ser comprensibles per a usuaris sense coneixements tècnics avançats.

Aquests requisits constitueixen la base sobre la qual es defineix l'arquitectura del sistema i les decisions de disseny adoptades en els apartats següents.

3.3 Model d'amenaques i supòsits de confiança

Atès que el projecte se centra en la seguretat de transaccions Web3, és necessari delimitar les amenaces que el sistema pretén detectar, els actius que es volen protegir i els elements que es consideren fiables durant el funcionament del prototip. Aquest model d'amenaques no pretén cobrir tots els riscos existents dins de l'ecosistema blockchain, sinó establir un marc concret i coherent amb l'abast funcional del treball.

L'assistent actua durant el moment previ a la confirmació d'una transacció. Per tant, el seu objectiu principal no és impedir tècnicament qualsevol operació maliciosa, sinó aportar informació que permeti a l'usuari identificar determinats patrons de risc i prendre una decisió més informada abans de confirmar o cancel·lar l'acció.

3.3.1 Actius que es volen protegir

El sistema considera com a actius protegits tant els recursos digitals de l'usuari com la seva capacitat per prendre decisions informades. Els principals actius contemplats són els següents:

- **Tokens fungibles.** Actius habitualment implementats mitjançant l'estàndard ERC20, que poden quedar exposats quan l'usuari concedeix permisos de despesa a una adreça externa.
- **Actius no fungibles.** NFTs associats principalment a contractes ERC721, que poden ser gestionats per tercers quan l'usuari activa permisos globals mitjançant operacions com `setApprovalForAll`.
- **Permisos concedits a tercers.** Autoritzacions que permeten que una adreça actuï en nom de l'usuari, ja sigui sobre una quantitat concreta de tokens o sobre tots els actius d'una col·lecció NFT.
- **Capacitat de decisió de l'usuari.** Informació necessària per entendre les implicacions de l'operació abans de confirmar-la. Aquest element es considera especialment rellevant, ja que una transacció pot ser tècnicament vàlida però comportar conseqüències que no siguin evidents a partir de la interfície habitual de la cartera.

En aquest sentit, el sistema no protegeix únicament el valor econòmic dels actius, sinó també la comprensió del procés d'autorització. L'objectiu és reduir situacions de

blind signing, en què l'usuari accepta una operació sense disposar de prou informació sobre el seu efecte real.

3.3.2 Amenaces contemplades

El model d'amenaques assumeix que una DApp o una adreça externa pot intentar obtenir permisos excessius o induir l'usuari a confirmar una operació que no comprèn completament. Les principals amenaces considerades són les següents:

- **DApp maliciosa o compromesa.** Una aplicació pot construir una transacció aparentment legítima que, en realitat, concedeixi permisos amplis a una adreça controlada per un atacant.
- **Aprovació ERC20 excessiva.** Una operació `approve(address,uint256)` pot concedir una quantitat molt elevada o pràcticament il·limitada de tokens a un *spender*. Si aquesta adreça és maliciosa o queda compromesa, podria utilitzar el permís concedit per transferir els actius autoritzats.
- **Permís global sobre NFTs.** Una operació `setApprovalForAll(operator,true)` autoritza un operador a gestionar tots els NFTs de l'usuari dins d'una col·lecció concreta. Aquesta autorització pot representar un risc elevat si l'operador no és legítim o si l'usuari no comprèn l'abast del permís.
- **Interacció amb adreces sospitoses.** La transacció pot involucrar una adreça de destinació, un *spender* o un *operator* que coincideixi amb una etiqueta de risc procedent de les fonts de context disponibles.
- **Operació desconeguda o amb informació insuficient.** La *calldata* pot correspondre a una funció que el sistema no és capaç de descodificar. En aquests casos, la manca de context constitueix un factor de cautela, encara que no sigui una prova que la transacció sigui maliciosa.
- **Explicació incorrecta generada per la IA.** El model de llenguatge pot produir una resposta ambigua, excessivament alarmista o incompatible amb les dades reals de la transacció. Per reduir aquest risc, la IA es manté subordinada al motor determinista i a la capa de control semàntic.

El sistema diferencia entre la presència d'un indicador de risc i la confirmació d'una activitat maliciosa. Per exemple, una aprovació il·limitada es considera una operació sensible per l'amplitud del permís concedit, però no implica necessàriament que el contracte destinatari sigui fraudulent.

3.3.3 Supòsits de confiança

Per delimitar correctament el problema, el prototip parteix d'un conjunt de supòsits sobre els components que intervenen en el sistema:

- **MetaMask i l'entorn del Snap es consideren fiables.** Es pressuposa que MetaMask Flask invoca correctament el Snap, presenta la transacció real que s'ha de confirmar i manté la integritat dels components executats dins del seu entorn.

- **El backend local no ha estat manipulat.** Es considera que el servei d'anàlisi, el motor de regles i la base de dades SQLite executen el codi corresponent a la versió documentada del projecte.
- **El dispositiu de l'usuari no està compromès.** El sistema assumeix que no existeix programari maliciós amb capacitat per modificar el codi local, interceptar les comunicacions internes o controlar la cartera de l'usuari.
- **Les dades blockchain consultades són representatives de l'estat de la xarxa.** Les consultes RPC s'utilitzen com a font de context sobre la xarxa, tot i que la disponibilitat del proveïdor extern no depèn directament del prototip.
- **Les etiquetes externes no són una autoritat absoluta.** Les llistes d'adreces conegudes poden ser incompletes, contenir informació desactualitzada o no incloure amenaces recents. Per aquest motiu, s'utilitzen com a context complementari i no com a únic criteri de decisió.
- **La IA pot generar errors.** El model de llenguatge és probabilístic i pot produir respostes imprecises. En conseqüència, no es considera una font de confiança suficient per determinar de manera autònoma el risc final. Les regles deterministes mantenen la prioritat en els patrons explícitament implementats.

Aquests supòsits permeten centrar l'anàlisi en els riscos derivats del contingut de la transacció i dels permisos concedits, sense estendre el projecte a la protecció integral del dispositiu, la cartera o la infraestructura blockchain.

3.3.4 *Elements fora de l'abast*

El prototip no pretén proporcionar una protecció completa davant de totes les amenaces possibles de l'ecosistema Web3. Queden fora de l'abast del treball els casos següents:

- **Robatori o filtració de la clau privada.** El sistema no pot protegir l'usuari si un atacant obté directament les claus criptogràfiques o la frase de recuperació de la cartera.
- **Malware al dispositiu.** No es contemplen atacs en què el sistema operatiu, el navegador, MetaMask o el backend local hagin estat modificats per programari maliciós.
- **Auditoria completa de contractes intel·ligents.** El prototip no analitza exhaustivament el codi font ni detecta vulnerabilitats internes complexes dels contractes, com errors de lògica, reentrades o manipulacions econòmiques avançades.
- **Atacs a la infraestructura blockchain.** No es cobreixen atacs sobre el consens d'Ethereum, manipulacions de la xarxa, reorganitzacions de blocs o vulnerabilitats pròpies del protocol blockchain.

- **Decodificació universal de transaccions.** El sistema se centra en selectors i patrons concrets. Una interacció desconeguda pot generar una advertència de manca de context, però no pot ser interpretada amb el mateix nivell de precisió que les funcions implementades.
- **Detecció perfecta de qualsevol estafa Web3.** Una adreça maliciosa nova pot no aparèixer als datasets utilitzats, i una transacció aparentment segura pot formar part d'un atac més ampli que no sigui visible a partir de la petició analitzada de manera individual.
- **Substitució de la decisió de l'usuari.** El sistema no confirma ni bloqueja automàticament la transacció. La seva funció és proporcionar un veredict, una recomanació i una explicació, però la decisió final continua corresponent a l'usuari.

Aquesta delimitació permet interpretar correctament els resultats del projecte. L'assistent s'ha de considerar una capa addicional de suport abans de la confirmació, i no una garantia absoluta de seguretat. La seva aportació principal consisteix a detectar patrons concrets, enriquir-los amb context i presentar-ne les implicacions d'una manera més comprensible per a l'usuari.

3.4 Actors principals

En aquest sistema hi intervenen diversos actors amb rols diferenciats. Alguns formen part directa del flux d'execució (usuari, DApp, cartera), mentre que d'altres aporten serveis auxiliars (anàlisi local i infraestructura externa).

Usuari Persona que interactua amb una DApp i ha de decidir si confirma o rebutja una transacció. L'objectiu del sistema és reduir el risc associat a decisions preses sense comprendre les implicacions de permisos i operacions habituals en Web3.

DApp (Aplicació descentralitzada) Aplicació web que sol·licita a la cartera la signatura i enviament d'una transacció mitjançant l'estàndard EIP-1193 (`window.ethereum`). En el projecte s'utilitza una DApp de proves per generar escenaris controlats.

MetaMask Flask (Cartera) Extensió del navegador que actua com a cartera i punt de signatura. Rep les sol·licituds de la DApp i, quan detecta un Snap instal·lat amb els permisos adequats, pot invocar-lo per obtenir *transaction insights* abans de la confirmació.

Snap (Mòdul de seguretat) Component executat dins MetaMask que intercepta la petició de transacció mitjançant el *handler onTransaction*. El Snap prepara la informació rellevant i consulta el *backend* local per obtenir un veredict i una explicació, que es mostren a l'usuari dins la UI de MetaMask.

Backend Analyzer (Servei local) Servei local encarregat de centralitzar l'anàlisi. Normalitza la transacció, intenta decodificar la *calldata*, aplica regles deterministes per detectar patrons de risc i consulta informació de suport a través d'una base de dades SQLite local. També integra el component d'IA local per generar explicacions en llenguatge natural i, quan escau, aportar una revisió complementària del resultat.

LLM (IA local) Servei d'inferència local que executa un model de llenguatge. En el projecte s'utilitza com a *explicador*: genera una explicació humana a partir dels resultats de l'anàlisi determinista, sense substituir la lògica de decisió basada en regles.

Base de dades local Component de persistència utilitzat pel *backend* per emmagatzemar l'historial d'anàlisis, adreces observades i informació procedent de fonts externes. Aquesta capa permet introduir memòria local al sistema i enriquir futures anàlisis sense dependre exclusivament de la transacció rebuda en aquell moment.

Infraestructura externa i fonts de context Conjunt de serveis i fonts externes utilitzats per complementar l'anàlisi. Inclou l'accés RPC a xarxes de prova com Sepolia per fer consultes *on-chain*, així com datasets o llistes d'adreces conegudes que poden aportar informació addicional sobre contractes o adreces sospitoses.

3.5 Arquitectura del sistema

La proposta combina components executats dins del navegador, serveis locals d'anàlisi i fonts externes vinculades a l'ecosistema Web3. La Figura 2 delimita aquest context i mostra com l'usuari, les interfícies d'origen i la xarxa blockchain es relacionen amb l'entorn local que conté MetaMask, el Snap, el backend, el model de llenguatge local i la base de dades local.

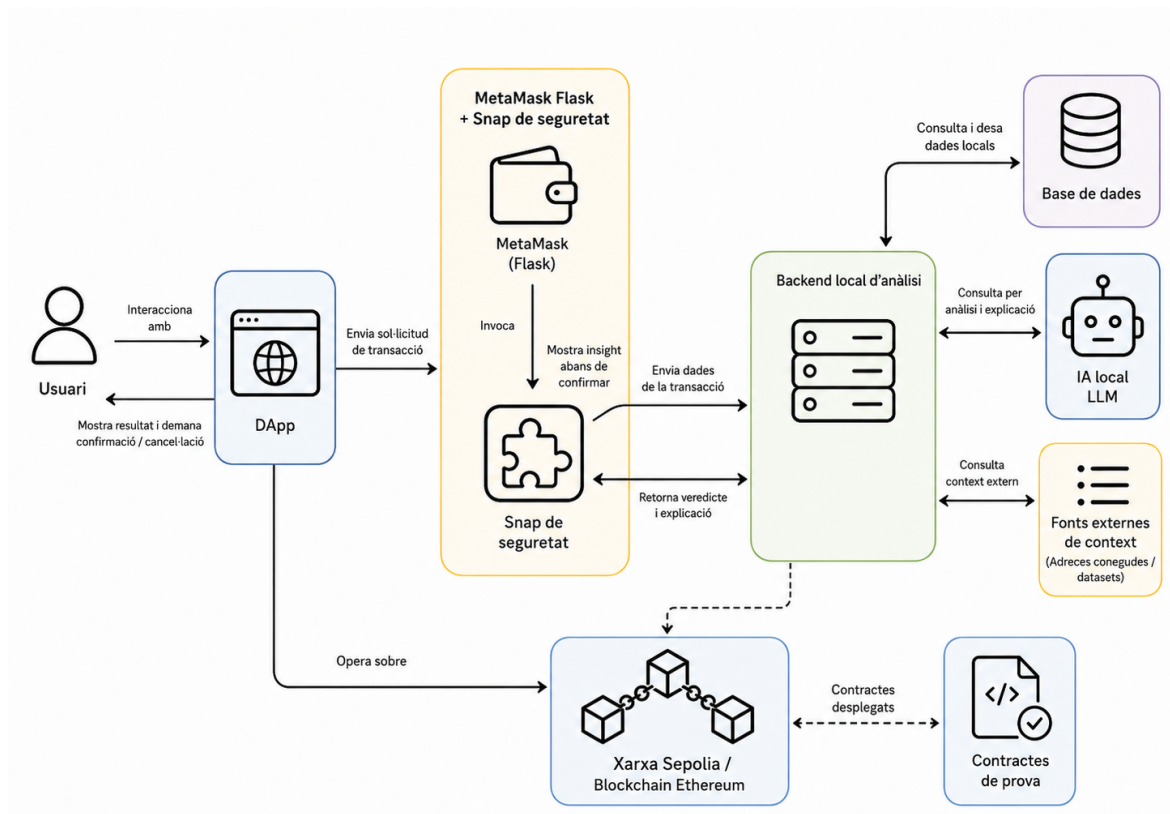


Figura 2: Visió general del sistema d'assistència abans de la confirmació d'una transacció

Flux resumit

Tal com mostra la Figura 2, el flux comença quan l'usuari interactua amb una DApp i aquesta sol·licita una transacció a MetaMask. Abans de presentar-ne la confirmació

definitiva, MetaMask activa el Snap mitjançant el punt d'entrada `onTransaction`. El Snap recull les dades disponibles de l'operació, les prepara en un format coherent i les envia al *backend* local perquè en faci l'anàlisi.

Un cop rebuda la sol·licitud, el *backend* normalitza i descodifica la transacció, aplica les regles deterministes i consulta, quan és necessari, el context disponible. Aquest context combina la informació *on-chain* amb les adreces conegudes, els conjunts de dades externs i la memòria d'anàlisis anteriors emmagatzemada a la base de dades local. A continuació, el model de llenguatge aporta una revisió i una explicació en llenguatge natural, sempre subordinades als fets verificats pel motor determinista. Amb tots aquests elements, el *backend* construeix el veredict final i el retorna al Snap.

Finalment, el Snap adapta la resposta al format admès per MetaMask i mostra l'*insight* de seguretat abans que l'usuari prengui la decisió. D'aquesta manera, la persona pot revisar el nivell de risc, els motius detectats i les conseqüències principals de l'operació abans de confirmar-la o cancel·lar-la. La mateixa arquitectura permet conservar el resultat per enriquir anàlisis posteriors sense alterar el paper de MetaMask com a punt final de decisió.

3.5.1 Flux de comunicació

Després de delimitar els components i les seves responsabilitats en la visió general, la Figura 3 presenta l'ordre temporal de la comunicació, des de la sol·licitud inicial fins a la decisió de l'usuari.

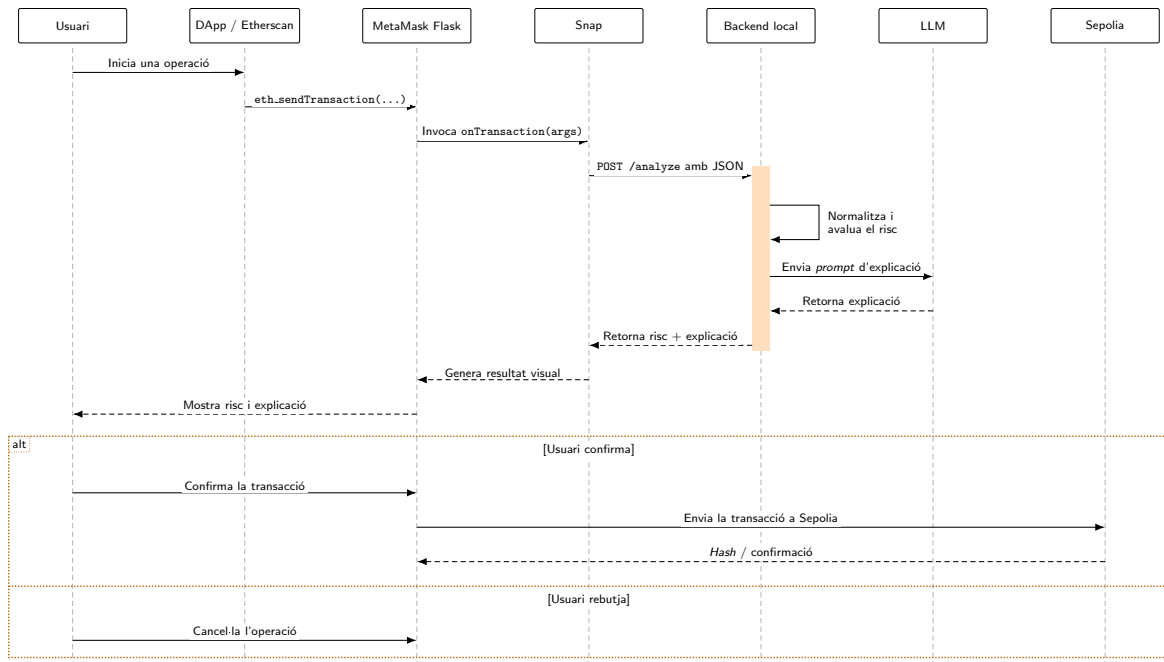


Figura 3: Flux complet d'execució del prototip, des de la generació de la transacció fins a la decisió final de l'usuari

3.5.2 Casos d'ús principals

Mentre que els requisits funcionals descrits anteriorment defineixen les capacitats que ha de proporcionar el sistema, els casos d'ús següents mostren com aquestes capa-

citats s'apliquen des de la perspectiva dels actors principals. En tots els casos, l'usuari continua mantenint la decisió final sobre la confirmació o cancel·lació de l'operació.

La Taula 2 resumeix els casos d'ús considerats en la proposta.

Cas d'ús	Actor principal	Descripció
CU1 – Anàlisi prèvia d'una transacció	Usuari	L'usuari inicia una operació des d'una DApp o una interfície externa compatible. MetaMask rep la transacció, activa el Snap i mostra el resultat de l'anàlisi abans de la confirmació.
CU2 – Anàlisi d'una aprovació ERC20	Usuari	L'usuari intenta autoritzar una adreça per operar amb tokens fungibles. El sistema interpreta l'operació approve i diferencia entre revocacions, aprovacions limitades i aprovacions molt elevades o pràcticament il·limitades.
CU3 – Anàlisi d'un permís global NFT	Usuari	L'usuari intenta executar una operació setApprovalForAll sobre una col·lecció NFT. El sistema detecta si es concedeix un permís global a un operador o si l'operació correspon a una revocació.
CU4 – Consulta de l' <i>insight</i> i decisió final	Usuari	Abans de confirmar l'operació, l'usuari consulta el nivell de risc, l'acció recomanada, els elements detectats i l'explicació en llenguatge natural. Finalment, decideix si confirma o cancel·la la transacció.
CU5 – Supervisió de l'entorn local	Desenvolupador	Durant el desenvolupament i les proves, el desenvolupador consulta la DApp local per comprovar l'estat del <i>backend</i> , la base de dades SQLite i el servei d'Ollama abans d'executar nous escenaris.

Taula 2: Casos d'ús principals del sistema

Els diagrames següents desenvolupen els casos més representatius. El primer recull el recorregut general i la decisió final de l'usuari; els altres dos concreten les bifurcacions de seguretat pròpies de les aprovacions ERC20 i dels permisos globals NFT.

CU1 i CU4 – Anàlisi prèvia, presentació de l'*insight* i decisió final. L'usuari inicia l'operació, però MetaMask no en demana la decisió definitiva fins que el Snap ha obtingut del backend el veredict i l'explicació. La Figura 4 mostra aquesta coordinació entre els actors principals.

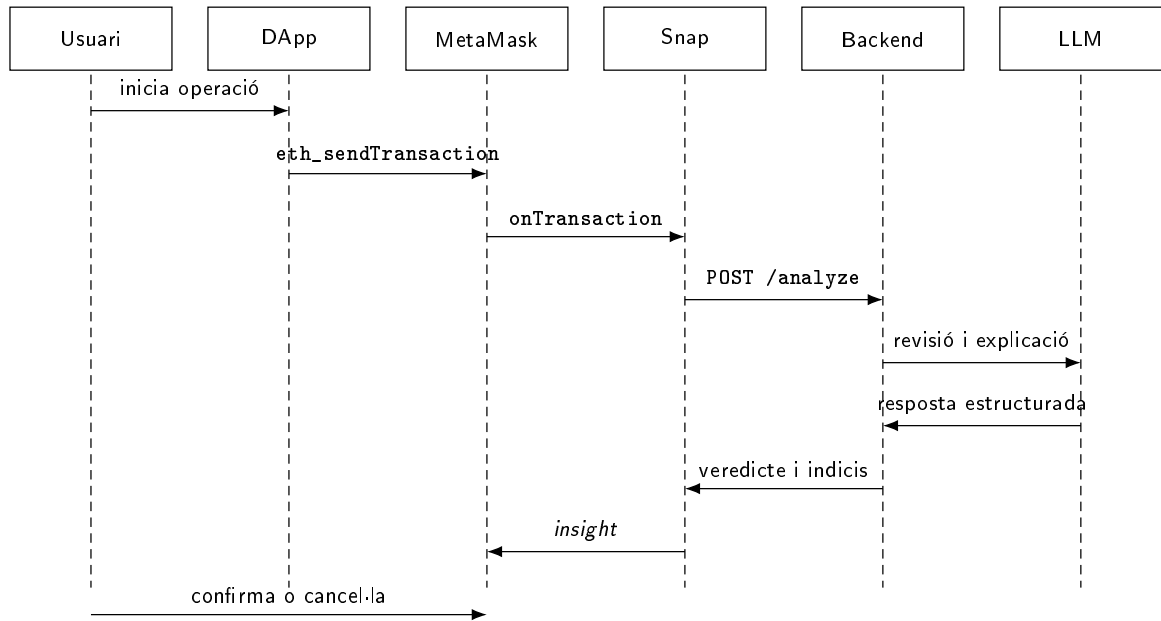


Figura 4: Diagrama de seqüència dels casos CU1 i CU4: anàlisi prèvia i decisió final

CU2 – Anàlisi d’una aprovació ERC20. En aquest cas, la descodificació de `approve` permet identificar l’adreça autoritzada i la quantitat. Les regles combinen aquests camps amb el context local per distingir una revocació, un permís limitat o una aprovació pràcticament il·limitada.

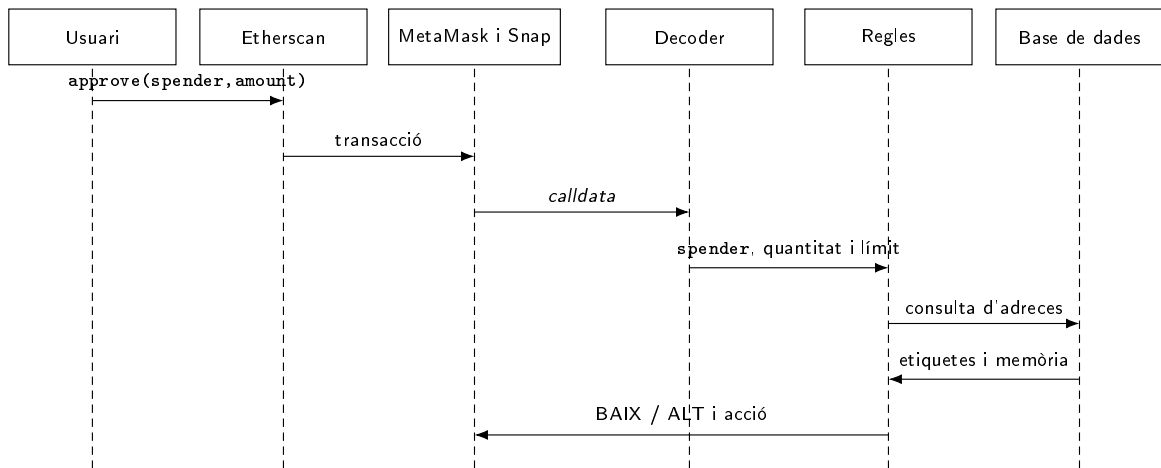


Figura 5: Diagrama de seqüència del cas CU2: anàlisi d’una aprovació ERC20

CU3 – Anàlisi d’un permís global NFT. La interpretació del booleà `approved` és determinant: el valor `true` activa un permís global d’alt risc, mentre que `false` revoca l’autorització i produeix un resultat de risc baix.

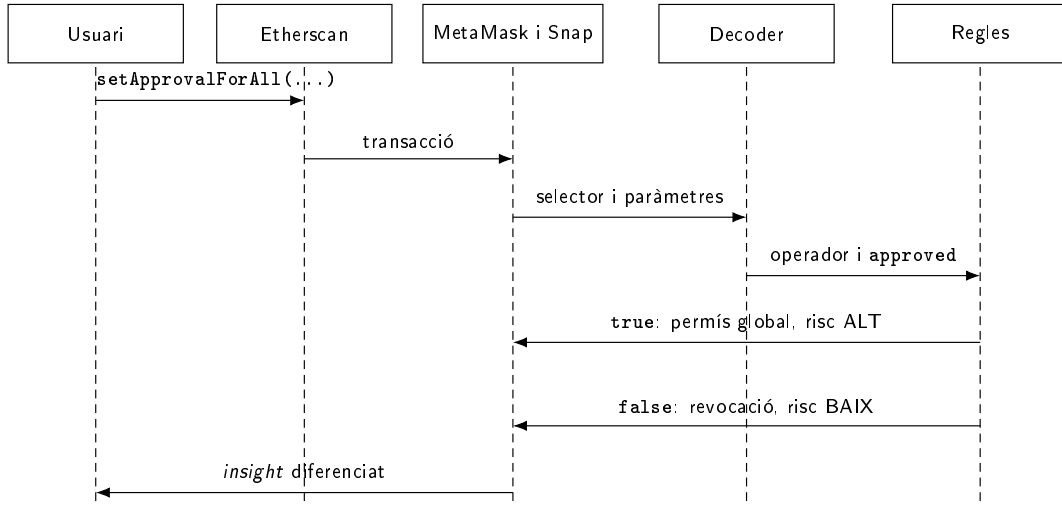


Figura 6: Diagrama de seqüència del cas CU3: activació o revocació d'un permís global NFT

3.6 Decisions de Disseny

Aquesta secció presenta les principals decisions arquitectòniques i funcionals adoptades durant el desenvolupament del prototip, així com els motius que justifiquen la separació de responsabilitats, la prioritat del motor determinista i l'ús complementari d'intel·ligència artificial local.

3.6.1 Separació de responsabilitats i Snap lleuger

Una de les principals decisions arquitectòniques ha estat mantenir el Snap com un component lleuger, encarregat únicament de les funcions que requereixen una integració directa amb MetaMask. Concretament, el Snap intercepta la transacció abans de la seva confirmació, extreu la informació rellevant, la transmet al backend local i adapta la resposta rebuda al format visual permès per MetaMask Snaps.

La lògica d'anàlisi no s'executa directament dins del Snap, sinó que es delega a un backend independent. Aquest component concentra la normalització de la transacció, la descodificació de la *calldata*, l'aplicació de les regles deterministes, la consulta de la base de dades local, l'enriquiment amb fonts externes de context i la comunicació amb el model de llenguatge.

Aquesta separació respon, en primer lloc, a les limitacions pròpies de l'entorn d'execució dels Snaps, que funciona dins d'un entorn aïllat i sotmès a un conjunt restringit de permisos. Incorporar tota la lògica d'anàlisi, persistència i generació de text dins del Snap augmentaria la complexitat del component i dificultaria tant el seu manteniment com la incorporació de noves funcionalitats.

En segon lloc, l'ús d'un *backend* independent permet desacoblar la interfície integrada dins de MetaMask del motor d'anàlisi. D'aquesta manera, és possible modificar les regles, incorporar noves fonts de reputació, substituir el model de llenguatge o ampliar la base de dades sense alterar necessàriament el comportament principal del Snap.

Aquesta arquitectura també facilita les proves. Els mòduls del backend poden validar-se de manera independent mitjançant entrades controlades, sense haver d'executar en cada cas el flux complet de MetaMask. Al mateix temps, el Snap pot centrar-se

en comprovar la intercepció, la comunicació i la presentació del resultat.

Per tant, la distribució de responsabilitats adoptada és la següent:

- **DApp:** genera les operacions i facilita l'execució d'escenaris controlats.
- **MetaMask Flask:** rep la sol·licitud de transacció i gestiona la decisió final de l'usuari.
- **Snap:** intercepta la transacció, prepara les dades, consulta el backend i mostra l'*insight*.
- **Backend:** centralitza l'anàlisi del risc, el context, la persistència i la construcció del resultat.
- **Ollama:** executa el model local utilitzat per generar explicacions i revisions complementàries.

Aquesta separació permet mantenir un baix acoblament entre els components i afavoreix l'extensibilitat del prototip. El Snap es manté centrat en la integració amb la cartera, mentre que el backend actua com a nucli funcional del sistema.

3.6.2 Prioritat del motor determinista

Una segona decisió central del disseny ha estat establir el motor de regles deterministes com a mecanisme principal de classificació del risc. La intel·ligència artificial s'utilitza com una capa complementària, però no substitueix els criteris explícits implementats al backend.

Les regles deterministes analitzen la informació normalitzada i descodificada de la transacció i produeixen un veredict inicial format pel nivell de risc, la puntuació associada, l'acció recomanada i els indicis que justifiquen el resultat. Aquest enfocament permet que els patrons coneguts siguin avaluats mitjançant criteris reproduïbles i auditables.

Per exemple, una aprovació ERC20 amb una quantitat igual a zero es considera una revocació, mentre que una aprovació equivalent a `MaxUint256` es tracta com una autorització pràcticament il·limitada. De manera similar, una operació `setApprovalForAll(operator,true)` s'interpreta com la concessió d'un permís global sobre una col·lecció NFT, mentre que el valor `false` indica una revocació.

En aquests casos, el resultat no depèn de la interpretació probabilística del model de llenguatge. El mateix patró d'entrada ha de produir el mateix resultat determinista, fet que facilita tant la verificació del comportament com la construcció de proves reproduïbles.

La revisió generada per la IA s'incorpora posteriorment com una font complementària. Aquesta revisió pot aportar una explicació més accessible, destacar elements que mereixen cautela o suggerir un nivell de risc més conservador en situacions amb informació ambigua. No obstant això, la IA no pot reduir un nivell de risc que ja hagi estat establert pel motor determinista.

Aquesta restricció és especialment important en els patrons crítics. Si les regles detecten una aprovació il·limitada, un permís global actiu o una coincidència amb una adreça etiquetada com a maliciosa, una resposta menys alarmista del model no pot rebaixar el veredict. D'aquesta manera, la decisió de seguretat no queda subordinada a una resposta probabilística que podria variar entre execucions.

De manera simplificada, la combinació dels dos mecanismes segueix els principis següents:

- les regles deterministes defineixen el veredict base;
- els patrons crítics detectats per regles mantenen la seva prioritat;
- la IA pot aportar una explicació en llenguatge natural;
- la IA pot suggerir un increment de cautela en casos no crítics o ambigus;
- la IA no pot reduir un risc determinista prèviament identificat;
- el resultat final es valida mitjançant una capa de control semàntic.

La capa de control semàntic comprova que les afirmacions generades pel model siguin compatibles amb els fets detectats pel backend. Per exemple, una explicació no ha d'afirmar que existeix una aprovació il·limitada si la quantitat analitzada és limitada, ni indicar que s'envia ETH quan el valor de la transacció és zero. Igualment, el sistema no ha de presentar una adreça com a maliciosa si no existeix una etiqueta que justifiqui aquesta afirmació.

Quan es detecta una contradicció, una resposta buida o una explicació que no compleix els criteris establerts, el backend pot sanejar-la o substituir-la per una explicació construïda a partir dels resultats deterministes. D'aquesta manera, la intel·ligència artificial queda limitada a un marc definit pels fets verificables de la transacció.

Aquesta decisió permet combinar els avantatges dels dos enfocaments. El motor determinista aporta consistència, traçabilitat i capacitat d'auditoria, mentre que el model de llenguatge millora la comunicació amb l'usuari. El resultat és un sistema en què la IA contribueix a l'explicabilitat, però no es converteix en l'única autoritat sobre la seguretat de l'operació.

3.6.3 Motivació de l'ús d'IA local

L'ús d'un model local es justifica principalment per criteris de privadesa, autonomia i cost. En primer lloc, evita la dependència d'APIs externes de pagament durant el desenvolupament i la validació del prototip. En segon lloc, permet mantenir el processament dins de l'entorn local, en coherència amb l'objectiu de reduir l'exposició de dades a tercers. Finalment, facilita l'experimentació amb models de llenguatge dins d'una arquitectura Web3 funcional sense introduir dependències externes innecessàries.

En el prototip implementat, Ollama s'executa com un servei local accessible al port 11434. El *backend* hi envia peticions mitjançant l'endpoint `/api/generate`, proporcionant el *prompt* corresponent i recuperant el text generat pel model.

4 Implementació

En aquest capítol es descriu la materialització tècnica de la proposta presentada anteriorment, detallant l'entorn de desenvolupament, la implementació dels components principals del sistema i la seva integració en un prototip funcional.

4.1 Entorn d'implementació i execució del prototip

El prototip s'executa en un entorn local de desenvolupament, amb Visual Studio Code com a espai principal de treball i diversos components que cooperen entre si. L'objectiu d'aquest entorn no és únicament programar el Snap, sinó reproduir un flux complet i realista en què una transacció es genera, s'intercepta, s'analitza i s'explica abans de la seva confirmació.

Per a la part de cartera i extensió s'utilitza MetaMask Flask, la variant orientada al desenvolupament i a la prova de funcionalitats experimentals com els Snaps. Dins d'aquest entorn s'executa el Snap, que constitueix la capa integrada dins MetaMask encarregada d'interceptar transaccions i mostrar els *insights* a l'usuari.

Cada component del prototip s'executa com un servei local independent i escolta en un port propi. La Taula 3 identifica cada servei amb una etiqueta breu, que s'utilitza com a referència en la resta del capítol, i en resumeix el port i la funció principal.

Id.	Servei	Port	Funció principal
S1	DApp local	8000	Interfície de proves, instal·lació del Snap i quadre de comandament de monitorització.
S2	Servidor del Snap	8080	Serveix el Snap en desenvolupament perquè MetaMask Flask el pugui instal·lar en local.
S3	<i>Backend</i> d'anàlisi	3000	Normalitza i descodifica la transacció, aplica les regles deterministes, gestiona la persistència i construeix el veredict.
S4	Servei d'IA (Ollama)	11434	Executa el model de llenguatge local que genera la revisió complementària i les explicacions.

Taula 3: Serveis locals del prototip, ports assignats i funció principal

Aquesta separació respon a una decisió de disseny deliberada. El Snap es manté com un component lleuger, integrat dins MetaMask i limitat a la interceptació, la preparació de dades i la presentació dels resultats. En canvi, el *backend* (S3) concentra la lògica d'anàlisi, les heurístiques de risc i la comunicació amb el servei d'IA (S4), i evita carregar el Snap amb tasques més costoses o més difícils de mantenir.

A més de l'entorn local, el projecte incorpora una infraestructura de prova sobre la xarxa Sepolia, que permet validar el comportament del sistema amb transaccions reals sobre blockchain sense utilitzar actius econòmics reals. Aquesta part, però, s'explica amb més detall a l'apartat dedicat als contractes intel·ligents i a l'entorn de proves.

4.1.1 Control de versions i repositori del projecte

El desenvolupament del prototip es gestiona mitjançant Git i es manté en un repositori de GitHub. Aquest repositori conserva l'historial de canvis, permet controlar l'evolució dels diferents components i manté sincronitzat el codi de la DApp, el Snap, el backend, els contractes intel·ligents i els scripts auxiliars.

El codi font actualitzat del projecte, juntament amb les instruccions necessàries per instal·lar les dependències i executar l'entorn de proves, es troba disponible al repositori següent:

https://github.com/marccarot0202/TFG_MarcCarotFigueres.git

Per facilitar la reproductibilitat, la versió del codi corresponent a aquesta memòria s'identificarà mitjançant una etiqueta o versió específica dins del repositori.

4.2 DApp local de proves i monitorització

La DApp local s'ha utilitzat com a interfície auxiliar per instal·lar el Snap, generar operacions de prova i verificar l'estat dels components principals del sistema. En les primeres versions del prototip, aquesta aplicació tenia una funció bàsica de connexió amb MetaMask i invocació manual del Snap. Posteriorment, es va ampliar per facilitar el seguiment de l'entorn local i actuar com a punt de control durant el desenvolupament.

En la versió actual, la DApp incorpora informació sobre l'estat del *backend*, la base de dades i el servei d'Ollama, obtinguda a través d'endpoints locals com `/health` i `/stats`. Aquesta funcionalitat no forma part del mecanisme principal d'anàlisi dins MetaMask, però resulta útil per comprovar que els components necessaris estan actius abans d'executar una transacció de prova.

A més de les accions ràpides de connexió i prova del Snap, la versió actual organitza el quadre de comandament en quatre vistes: resum, historial, adreces i proves. El resum concentra l'estat dels serveis, els comptadors i les distribucions de risc i mètodes. L'historial incorpora cerca i filtre per risc; cada fila obre un detall amb el veredicta llegible i, en blocs tècnics plegables, la transacció descodificada, els indicis (**findings**), la revisió de la IA, els senyals d'adreces, les mesures de rendiment i les metadades de l'avaluació.

La mateixa interfície permet afegir manualment una adreça al conjunt local, assignar-li una etiqueta i consultar-la posteriorment. Aquesta operació utilitza els endpoints `/known-addresses/manual` i `/known-addresses`; l'historial i els detalls es recuperen mitjançant `/analysis-history` i `/analysis-history/:id`. Les etiquetes visibles de risc, acció, tipus d'adreça i procedència es mostren en català, sense alterar els valors interns de l'API. La DApp no substitueix Etherscan per generar totes les operacions contractuals: les funcions reals `approve` i `setApprovalForAll` es poden iniciar des de *Write Contract*, mentre la DApp actua com a monitor local i permet activar una transacció simple per comprovar `onTransaction`. L'ús del quadre de comandament com a instrument de monitorització i les evidències visuals associades es presenten al Capítol 5.

4.3 Implementació del Snap

El Snap constitueix el punt d'entrada del sistema dins de MetaMask i actua com a capa d'intercepció i presentació dels resultats. La seva funció principal no és realitzar tota l'anàlisi de manera interna, sinó capturar la transacció abans de la confirmació, preparar-ne la informació rellevant, consultar el *backend* local i presentar el resultat a l'usuari dins la pròpia interfície de la cartera.

4.3.1 Estructura general del Snap

La implementació del Snap s'ha centralitzat principalment en el fitxer `packages/snap/src/index.tsx`, que conté tant la definició dels punts d'entrada del Snap com la lògica necessària per comunicar-se amb el *backend*. Aquesta organització simplifica el prototip i permet concentrar en un únic punt la intercepció de transaccions, la preparació de les dades i la construcció de la interfície mostrada a MetaMask.

En una primera fase, el Snap només disposava d'un mètode bàsic de prova, accessible des de la DApp local mitjançant `wallet_invokeSnap`. Aquest comportament inicial servia per validar la instal·lació del Snap, la comunicació amb la cartera i la generació de diàlegs simples dins MetaMask. Posteriorment, aquesta base es va ampliar per incorporar un flux real d'anàlisi de transaccions, primer mitjançant un mètode invocat manualment des de la DApp i després mitjançant la intercepció automàtica amb `onTransaction`.

4.3.2 Permisos i configuració

Perquè el Snap pogués operar dins del flux de transaccions, va ser necessari definir al *manifest* un conjunt de permisos específics. Entre els més importants hi ha `snap_dialog`, que permet mostrar diàlegs dins MetaMask; `endowment:network-access`, que habilita l'ús de `fetch()` per comunicar-se amb el *backend* local; i `endowment:transaction-insight`, que permet generar *transaction insights* abans de la confirmació de la transacció. En aquesta darrera capacitat també es fa servir l'opció `allowTransactionOrigin` per poder disposar d'informació sobre l'origen de la petició.

La configuració correcta d'aquests permisos va ser un pas crític en la implementació, ja que sense ells el Snap podia continuar mostrant diàlegs simples, però no podia ni consultar el *backend* ni interceptar automàticament transaccions reals dins MetaMask.

4.3.3 Interacció manual mitjançant `onRpcRequest`

Abans d'activar la intercepció automàtica, es va implementar una primera via de prova a través de `onRpcRequest`. Aquest mecanisme permetia que la DApp local invoqués explícitament el Snap amb un mètode personalitzat, anomenat `analyzeTransaction`, enviant una estructura simplificada de transacció. El Snap rebia aquestes dades, les reenviava al *backend* i mostrava el resultat amb un diàleg de MetaMask.

Aquesta fase va ser especialment útil per validar de manera incremental la integració del sistema. Gràcies a ella es va poder comprovar, abans d'entrar en la intercepció

real, que la comunicació `Snap` $\rightarrow$ *backend* $\rightarrow$ Ollama funcionava correctament i que la resposta podia representar-se dins de la UI limitada de MetaMask. Aquest enfocament també va facilitar el procés de depuració inicial, ja que permetia provar el *backend* sense dependre encara del flux complet d'una transacció real.

4.3.4 Intercepció automàtica de transaccions amb *onTransaction*

Un cop validada la connexió amb el *backend*, la implementació es va ampliar amb el punt d'entrada *onTransaction*, que és el mecanisme proporcionat per MetaMask Snaps per interceptar transaccions abans que l'usuari les confirmi. Aquest *handler* s'executa automàticament quan MetaMask detecta una transacció compatible i hi ha un Snap instal·lat amb els permisos adequats.

Dins d'aquest *handler*, el Snap extreu els camps principals de la transacció, entre els quals destaquen l'adreça d'origen, l'adreça de destinació, el valor enviat, la calldata, la xarxa utilitzada i l'origen de la transacció. Aquesta informació es transforma a una estructura JSON simplificada que després s'envia al *backend* local per ser analitzada. El fet de treballar amb una estructura pròpia i normalitzada facilita tant el tractament posterior com la possible extensió del sistema amb nous tipus d'anàlisi.

4.3.5 Comunicació amb el *backend*

Per comunicar-se amb el *backend*, el Snap utilitza una petició HTTP local mitjançant `fetch()` contra l'endpoint `http://localhost:3000/analyze`. Aquesta petició envia les dades de la transacció en format JSON i rep com a resposta una estructura amb el veredict final, l'acció recomanada, els indicis del camp `findings`, el context disponible, la revisió complementària de la IA i l'explicació final. El Snap no implementa directament la lògica heurística ni la generació de text, sinó que delega aquestes responsabilitats al *backend*, mantenint-se així com un component lleuger i centrat en la integració amb MetaMask.

Aquesta decisió respon tant a motius arquitectònics com a limitacions de l'entorn del Snap. D'una banda, l'aïllament i les restriccions de MetaMask Snaps fan poc convenient carregar-lo amb processament més pesat. De l'altra, separar la lògica d'anàlisi en un servei local independent facilita l'evolució del sistema, la reutilització de codi i la incorporació de millores futures sense haver de modificar constantment el Snap.

4.3.6 Presentació dels *insights* dins MetaMask

Un cop rebuda la resposta del *backend*, el Snap construeix la interfície que es mostra dins de MetaMask. Aquesta interfície es genera amb els components oficials del sistema de Snaps, com ara `Box`, `Text`, `Bold` i `Heading`, ja que l'entorn de MetaMask no permet utilitzar una interfície web arbitrària.

En les primeres versions del prototip, la informació presentada a l'usuari es limitava principalment al nivell de risc i a una explicació en llenguatge natural. Amb l'evolució del sistema, la resposta del *backend* s'ha ampliat i el Snap pot mostrar un conjunt més ric d'elements, com ara el veredict final, l'acció recomanada, els indicis principals, el context local detectat, la revisió complementària de la IA i la font que ha motivat el resultat.

La versió final unifica en català totes les etiquetes visibles i les explicacions noves. El Snap transforma els codis interns de risc `BAJO`, `MEDIO`, `ALTO` i `DESCONOCIDO` en *Baix*, *Mitjà*, *Alt* i *Desconegut*, i presenta `ALLOW`, `REVIEW` i `BLOCK` com *Permetre*, *Revisar* i *Bloquejar*. Els codis originals no es modifiquen dins del contracte JSON ni a SQLite, per mantenir la compatibilitat amb l'historial, les proves automatitzades i els consumidors de l'API.

Aquesta ampliació permet que l'usuari no rebi només una alerta genèrica, sinó una visió més estructurada del motiu pel qual una transacció pot ser considerada segura, sospitosa o arriscada. Tot i això, el Snap continua mantenint una responsabilitat limitada: no reconstrueix l'anàlisi intern ni aplica les regles de risc, sinó que adapta la resposta rebuda al format visual permès per MetaMask.

La limitació dels components disponibles condiciona el disseny de la interfície, però també ajuda a centrar el missatge en la informació essencial: el nivell de risc, els motius principals i l'explicació final que ha de servir de suport a la decisió de l'usuari.

4.4 Implementació del backend d'anàlisi

El *backend* d'anàlisi s'ha implementat com un servei local independent encarregat de concentrar la lògica que no resultava convenient executar dins del Snap. En les primeres versions del prototip, aquest component tenia una estructura simple, suficient per validar el flux inicial entre MetaMask, el Snap, el backend i Ollama.

A mesura que el sistema va incorporar noves funcionalitats, com la normalització de transaccions, la descodificació de *calldata*, el motor de regles, la persistència local i la consulta de fonts de context, es va fer necessari refactoritzar el *backend* en mòduls més específics. Aquesta evolució va permetre mantenir el Snap com una capa lleugera d'intercepció i presentació, mentre que el *backend* passava a assumir el paper de nucli d'anàlisi del sistema.

En la versió actual del prototip, aquest servei s'executa localment al port 3000 i exposa diversos *endpoints*, entre els quals destaca `/analyze`, utilitzat pel Snap per enviar les transaccions a analitzar.

4.4.1 Estructura general del backend

La versió actual del *backend* s'organitza en diversos mòduls amb responsabilitats diferenciades. Aquesta separació facilita el manteniment del codi, redueix l'acoblament entre parts del sistema i permet ampliar el prototip amb noves fonts de context o noves regles sense modificar tota la lògica existent.

El fitxer principal, `server.js`, actua com a punt d'entrada del servei i exposa les rutes HTTP. La resta de la lògica es delega a serveis interns encarregats de normalitzar la transacció, descodificar-ne el contingut, aplicar regles de risc, gestionar la persistència local i comunicar-se amb Ollama.

La Taula 4 resumeix els principals mòduls del *backend* en la versió actual del prototip.

Mòdul	Funció principal
<code>server.js</code>	Exposa les rutes HTTP del <i>backend</i> , incloent <code>/analyze</code> , <code>/health</code> i <code>/stats</code> .
<code>analyzer.js</code>	Orquestra el flux complet d'anàlisi, coordinant la normalització, la descodificació, les regles, la memòria local i la generació d'explicacions.
<code>normalizeTx.js</code>	Converteix la transacció rebuda des del Snap a una estructura interna coherent i més fàcil de processar.
<code>decoder.js</code>	Intenta descodificar la <i>calldata</i> de funcions conegudes, com <code>approve(address,uint256)</code> o <code>setApprovalForAll(address,bool)</code> .
<code>rules.js</code>	Aplica el motor determinista de regles per identificar patrons de risc i generar un veredict e estructurat.
<code>database.js</code>	Gestiona la base de dades SQLite local, l'historial d'anàlisis, la memòria d'adreces i les adreces conegudes.
<code>ollama.js</code>	Gestiona la comunicació amb Ollama i recupera les explicacions generades pel model local.

Taula 4: Responsabilitats principals dels mòduls del *backend*

Com que la implementació JavaScript s'organitza principalment mitjançant mòduls i funcions, la Figura 7 utilitza una representació UML lògica. Els estereotips indiquen el paper de cada element i les operacions enumerades corresponen als punts d'entrada més rellevants del codi, sense pressuposar una jerarquia de classes que el prototip no implementa.

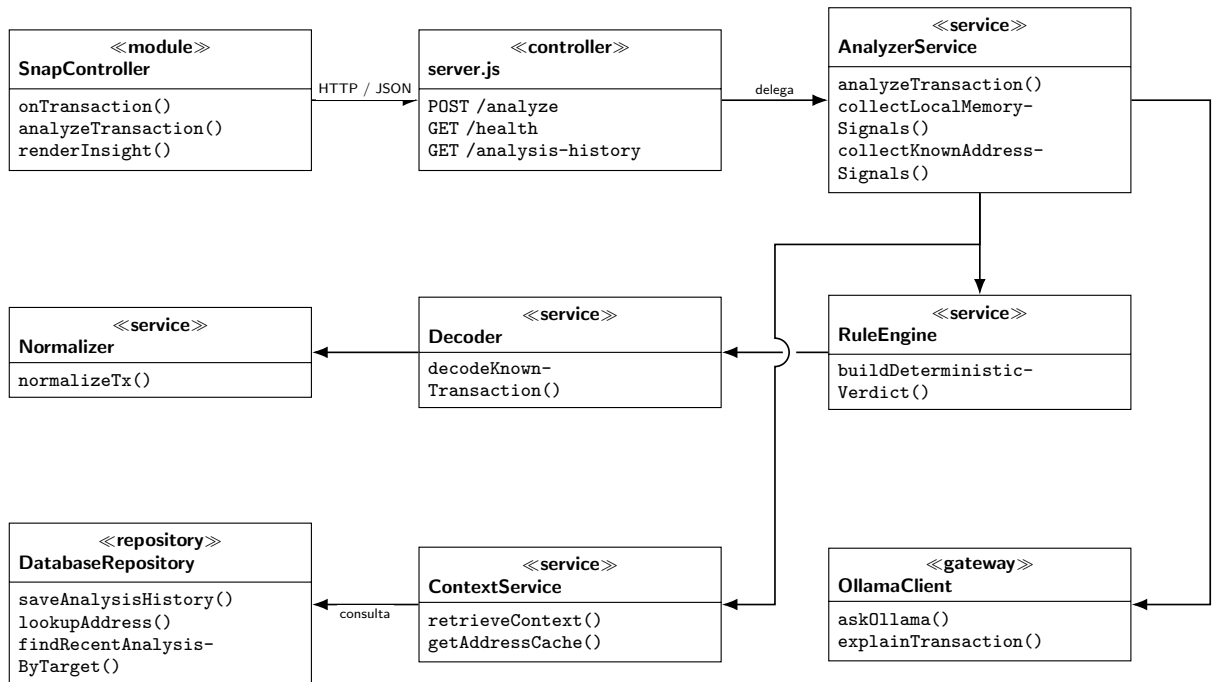


Figura 7: Diagrama UML lògic dels mòduls, serveis i dependències principals del prototip

4.4.2 Recepció de la transacció

El punt d'entrada principal del *backend* és una ruta HTTP de tipus **POST**, accessible a `http://localhost:3000/analyze`. El Snap hi envia una estructura JSON amb la informació essencial de la transacció, incloent camps com ara l'adreça d'origen, l'adreça de destinació, el valor, la *calldata* i la cadena sobre la qual s'està operant. Un cop rebuda la petició, el *backend* extreu aquesta informació del cos de la petició i la passa als serveis interns responsables d'analitzar-la.

Aquest model permet desacoblar la cartera del procés d'avaluació. El Snap no necessita conèixer el detall intern de l'anàlisi, sinó únicament enviar les dades i esperar una resposta estructurada. Això fa que la comunicació entre ambdós components sigui simple i extensible.

4.4.3 Normalització i descodificació de la petició

Un cop rebudes les dades, el *backend* normalitza la transacció a un format intern comú. Aquesta representació inclou camps com el tipus d'operació, la xarxa, l'adreça d'origen, l'adreça de destinació, el valor enviat, la *calldata*, l'origen de la petició i informació derivada, com ara el selector del mètode o la identificació d'una interacció amb un contracte.

La normalització permet que la resta de mòduls treballin sobre una estructura coherent, independentment de petites diferències en el format original rebut des del Snap. D'aquesta manera, el motor d'anàlisi pot aplicar les mateixes regles sobre totes les transaccions processades.

A partir d'aquesta estructura, el sistema intenta descodificar la *calldata* quan reconeix selectors de funcions conegudes. En la versió actual del prototip, el *backend* identifica principalment les operacions `approve(address,uint256)` i `setApprovalForAll(address,bool)`, especialment rellevants perquè poden concedir permisos amplis sobre tokens o col·leccions NFT.

En el cas de `approve(address,uint256)`, el sistema extreu l'adreça autoritzada, representada pel camp *spender*, i la quantitat concedida. En el cas de `setApprovalForAll(address,bool)`, s'obtenen l'adreça de l'operador i el valor booleà que indica si el permís global s'activa o es revoca.

Quan el selector no correspon a cap de les funcions conegudes, la transacció es manté identificada com una interacció amb un contracte no descodificada. Aquesta informació s'utilitza posteriorment pel motor de regles per aplicar un criteri més conservador.

4.4.4 Motor de regles deterministes

Sobre la informació normalitzada i descodificada, el *backend* aplica un conjunt de regles deterministes per estimar el risc de l'operació. Aquestes regles constitueixen el mecanisme principal de classificació del sistema i produeixen un resultat estructurat que pot incloure un nivell de risc, una puntuació, una acció recomanada i un conjunt d'indicis justificatius.

En les operacions ERC20, el sistema diferencia entre tres situacions principals. Una quantitat igual a zero s'interpreta com una revocació del permís i es considera

una operació de risc baix. Una aprovació amb una quantitat limitada rep igualment un tractament de risc reduït, sempre que no existeixin altres indicadors addicionals. En canvi, una aprovació equivalent a `MaxUint256`, o considerada pràcticament il·limitada, genera un nivell de risc alt i una recomanació de revisar l'operació abans de confirmarla.

En les operacions ERC721, la crida `setApprovalForAll(operator,true)` s'interpreta com la concessió d'un permís global sobre tots els NFTs de l'usuari dins d'una col·lecció concreta. Per aquest motiu, el sistema la classifica com una operació d'alt risc. En canvi, `setApprovalForAll(operator,false)` correspon a una revocació del permís global i rep un tractament de risc baix.

Quan la transacció correspon a una interacció amb un contracte que no pot ser descodificada mitjançant els selectors implementats, el sistema pot assignar un nivell de risc mitjà i recomanar una revisió manual. Aquest comportament permet advertir de la manca de context sense afirmar que l'operació sigui necessàriament maliciosa.

Aquesta anàlisi es manté separada de la generació de l'explicació en llenguatge natural. El nivell de risc, la puntuació, l'acció recomanada i els indicis provenen del procés determinista del *backend*, mentre que el text explicatiu es genera posteriorment amb el suport del mòdul d'intel·ligència artificial. D'aquesta manera, el sistema conserva una base d'anàlisi estructurada, reproduïble i auditable.

4.4.5 Persistència local i memòria d'anàlisi

Com a millora posterior a la primera versió funcional del *backend*, es va incorporar una base de dades SQLite local [26]. Aquesta capa de persistència permet conservar l'historial d'anàlisis realitzades, registrar adreces observades i emmagatzemar adreces conegudes procedents de fonts externes o introduïdes manualment.

Cada registre d'`analysis_history` conserva la petició original, la transacció normalitzada, la descodificació, els indicis del camp `findings`, el context resumit, els senyals de memòria local i d'adreces conegudes, el veredict determinista, la resposta d'IA, el veredict final i els fets semàntics. Durant l'avaluació s'hi van afegir també `performance_json` i `evaluation_json`, que permeten associar temps, escenari, repetició i classe real amb cada observació. Les migracions afegeixen aquestes columnes a bases existents sense eliminar l'historial anterior.

Aquesta informació no substitueix les regles deterministes, però aporta context addicional al procés d'anàlisi. Per exemple, el *backend* pot detectar si una adreça de destinació, un *spender* o un *operator* ja havia aparegut en anàlisis anteriors, o si coincideix amb una adreça etiquetada dins la base de dades local.

D'aquesta manera, el sistema deixa d'analitzar cada transacció com un cas completament aïllat i incorpora una forma inicial de memòria local. Aquesta funcionalitat també obre la porta a construir un conjunt de dades propi a partir de les transaccions analitzades durant les proves.

La Figura 8 mostra l'estructura real de la taula `analysis_history`, incloses les columnes destinades a la descodificació, els veredictes, els senyals contextuais, el rendiment i les metadades d'avaluació. La Figura 9 confirma que les execucions queden persistides amb el mètode detectat, el nivell i la puntuació de risc, l'acció recomanada

i l'origen de la sol·licitud.

4.4.6 *Fonts externes de context i adreces conegudes*

A més de l'historial generat pel mateix sistema, el *backend* pot utilitzar informació procedent de fonts externes per aportar context sobre les adreces que intervenen en una transacció. Aquesta funcionalitat té com a objectiu complementar l'anàlisi determinista amb etiquetes prèviament associades a adreces conegudes, com ara contractes legítims, adreces sospitoses o adreces relacionades amb activitats malicioses.

En la implementació actual s'ha incorporat informació procedent del repositori públic *ethereum-lists*, mantingut per MyEtherWallet [27]. Concretament, s'utilitzen les llistes `addresses-darklist.json` i `addresses-lightlist.json`, que contenen adreces etiquetades amb informació de reputació. La primera agrupa principalment adreces relacionades amb estafes, *phishing* o altres comportaments potencialment maliciosos, mentre que la segona permet identificar adreces conegudes o considerades legítimes dins de l'ecosistema Ethereum.

La importació d'aquestes dades es realitza mitjançant l'*script*:

```
backend/scripts/import_mew_ethereum_lists.js
```

Aquest procés transforma la informació de les llistes externes i l'emmagatzema a la taula local `known_addresses` de la base de dades SQLite. D'aquesta manera, el sistema no necessita consultar el servei extern durant cada anàlisi, sinó que pot treballar amb una còpia local de les dades importades. Aquest plantejament redueix la dependència de serveis remots, facilita la reproducció de les proves i manté la consulta de reputació dins de l'entorn local.

Durant l'anàlisi d'una transacció, el *backend* comprova les adreces més rellevants de l'operació. Aquestes poden incloure l'adreça de destinació de la transacció, el camp *spender* d'una aprovació ERC20 o l'*operator* d'un permís global ERC721. Quan alguna d'aquestes adreces coincideix amb un registre de `known_addresses`, el sistema incorpora la categoria, la descripció i la font de l'etiqueta al context de l'anàlisi.

La influència d'aquesta informació depèn del tipus d'etiqueta detectada. Una coincidència amb una adreça catalogada com a maliciosa, fraudulenta o inclosa en una llista negra pot generar un *finding* específic i elevar el nivell de risc del veredict. Les etiquetes de tipus advertiment o sospita aporten una senyal de cautela, mentre que les adreces conegudes, de confiança o associades als contractes de prova poden proporcionar context positiu sense anul·lar altres riscos detectats.

En qualsevol cas, la reputació externa no substitueix el motor de regles deterministes. Una etiqueta constitueix una font addicional de context, però no es considera per si sola una prova absoluta sobre la seguretat o perillositat d'una transacció. El veredict final continua tenint en compte el tipus d'operació, els permisos concedits, els patrons detectats i la resta d'informació disponible.

Aquesta separació permet combinar criteris explícits i reproduïbles amb informació contextual actualitzable. En futures versions, el mateix mecanisme podria ampliar-se amb noves fonts públiques de reputació sense modificar el Snap ni la resta del flux principal del sistema.

DB Browser for SQLite - C:\Users\marcc\Desktop\tfg_marc_v1\backend\database\web3_security.db

Archivo Editar Ver Herramientas Ayuda

Nueva base de datos Abrir base de datos Guardar cambios Revertir cambios Deshacer Abrir proyecto Guardar proyecto

Hoja de datos Editar pragmas Ejecutar SQL Estructura

Crear tabla Crear índice Modificar tabla Borrar tabla Imprimir Refrescar

Nombre	Tipo	Esquema
analysis_history		CREATE TABLE analysis_history (id INTEGER PRIMARY KEY AU
id	INTEGER	"id" INTEGER
created_at	INTEGER	"created_at" INTEGER DEFAULT (unixepoch())
chain_id	TEXT	"chain_id" TEXT
from_address	TEXT	"from_address" TEXT
to_address	TEXT	"to_address" TEXT
method_selector	TEXT	"method_selector" TEXT
decoded_method	TEXT	"decoded_method" TEXT
risk_level	TEXT	"risk_level" TEXT
risk_score	INTEGER	"risk_score" INTEGER
recommended_action	TEXT	"recommended_action" TEXT
origin	TEXT	"origin" TEXT
raw_tx_json	TEXT	"raw_tx_json" TEXT
normalized_tx_json	TEXT	"normalized_tx_json" TEXT
decoded_json	TEXT	"decoded_json" TEXT
findings_json	TEXT	"findings_json" TEXT
explanation	TEXT	"explanation" TEXT
context_summary	TEXT	"context_summary" TEXT
deterministic_verdict_json	TEXT	"deterministic_verdict_json" TEXT
local_memory_signals_json	TEXT	"local_memory_signals_json" TEXT
known_address_signals_json	TEXT	"known_address_signals_json" TEXT
ai_review_json	TEXT	"ai_review_json" TEXT
final_verdict_json	TEXT	"final_verdict_json" TEXT
semantic_facts_json	TEXT	"semantic_facts_json" TEXT
performance_json	TEXT	"performance_json" TEXT
evaluation_json	TEXT	"evaluation_json" TEXT

Figura 8: Estructura de la taula analysis_history a la base de dades SQLite local

DB Browser for SQLite - C:\Users\marcc\Desktop\tfg_marc_v1\backend\database\web3_security.db

Archivo Editar Ver Herramientas Ayuda

Nueva base de datos Abrir base de datos Guardar cambios Revertir cambios Deshacer Abrir proyecto Guardar proyecto Anexar base de datos Cerrar base de datos

Hoja de datos Editar pragmas Ejecutar SQL Estructura

Tablas: analysis_history Filtrar en cualquier columna

	method_selector	decoded_method	risk_level	risk_score	recommended_action	origin	raw_tx_json	normalized_tx_json
7	0x095ea7b3	approve	ALTO	90	REVIEW	https://sepolia.etherscan.io	{"type":"transaction","chainId":"eip...	{"type":"transaction","chainId":
8	0x095ea7b3	approve	ALTO	90	REVIEW	https://sepolia.etherscan.io	{"type":"transaction","chainId":"eip...	{"type":"transaction","chainId":
9	0x095ea7b3	approve	ALTO	90	REVIEW	https://sepolia.etherscan.io	{"type":"transaction","chainId":"eip...	{"type":"transaction","chainId":
10	0x095ea7b3	approve	ALTO	90	REVIEW	https://sepolia.etherscan.io	{"type":"transaction","chainId":"eip...	{"type":"transaction","chainId":
11	0x095ea7b3	approve	ALTO	90	REVIEW	https://sepolia.etherscan.io	{"type":"transaction","chainId":"eip...	{"type":"transaction","chainId":
12	0x095ea7b3	approve	ALTO	90	REVIEW	https://sepolia.etherscan.io	{"type":"transaction","chainId":"eip...	{"type":"transaction","chainId":
13	0x095ea7b3	approve	ALTO	90	REVIEW	https://sepolia.etherscan.io	{"type":"transaction","chainId":"eip...	{"type":"transaction","chainId":
14	0x095ea7b3	approve	MEDIO	45	REVIEW	https://sepolia.etherscan.io	{"type":"transaction","chainId":"eip...	{"type":"transaction","chainId":
15	0x095ea7b3	approve	MEDIO	45	REVIEW	https://sepolia.etherscan.io	{"type":"transaction","chainId":"eip...	{"type":"transaction","chainId":
16	0x095ea7b3	approve	BAJO	20	ALLOW	https://sepolia.etherscan.io	{"type":"transaction","chainId":"eip...	{"type":"transaction","chainId":
17	0x095ea7b3	approve	ALTO	90	REVIEW	https://sepolia.etherscan.io	{"type":"transaction","chainId":"eip...	{"type":"transaction","chainId":
18	0x095ea7b3	approve	MEDIO	45	REVIEW	https://sepolia.etherscan.io	{"type":"transaction","chainId":"eip...	{"type":"transaction","chainId":
19	0xa22cb465	setApprovalForAll	ALTO	100	REVIEW	https://sepolia.etherscan.io	{"type":"transaction","chainId":"eip...	{"type":"transaction","chainId":
20	0xa22cb465	setApprovalForAll	ALTO	100	REVIEW	https://sepolia.etherscan.io	{"type":"transaction","chainId":"eip...	{"type":"transaction","chainId":
21	0x095ea7b3	approve	BAJO	20	ALLOW	https://sepolia.etherscan.io	{"type":"transaction","chainId":"eip...	{"type":"transaction","chainId":
22	0x095ea7b3	approve	BAJO	20	ALLOW	https://sepolia.etherscan.io	{"type":"transaction","chainId":"eip...	{"type":"transaction","chainId":
23	0x095ea7b3	approve	BAJO	20	ALLOW	https://sepolia.etherscan.io	{"type":"transaction","chainId":"eip...	{"type":"transaction","chainId":
24	0x095ea7b3	approve	BAJO	10	ALLOW	https://sepolia.etherscan.io	{"type":"transaction","chainId":"eip...	{"type":"transaction","chainId":
25	0x095ea7b3	approve	BAJO	10	ALLOW	codex:/step-1-persistence-check	{"value":"0x0","data":"0x095ea7b3000...	{"type":"transaction","chainId":

7 - 25 de 56

Ir a: 1

UTF-8

Figura 9: Registres d'anàlisi persistits a la base de dades SQLite local

La Figura 10 mostra la consulta d'aquest conjunt des del quadre de comandament. La interfície permet cercar i filtrar les adreces, i identifica tant les entrades manuals com les importades de fonts externes mitjançant la seva etiqueta, el tipus i la procedència.

Assistent de Seguretat Web3
Monitorització del Snap, anàlisi de risc i memòria local.

Resum Historial **Adreces** Proves

Adreces conegudes
Consulta les fonts de context i incorpora etiquetes locals.

Cercar per adreça, etiqueta o font Tots els tipus Q Aplicar

Adreça	Etiqueta	Tipus	Font	Afegida
0xeeee...eeee	Controlled evaluation address E1	Estafa	Informe manual	17/7/2026 11:13:21
0xc0de...c0de	Prova manual Codex 2026-07-17	Contracte de prova	Informe manual	17/7/2026 9:39:27
0x8527...81aa	Contracte de prova	De confiança	Informe manual	27/5/2026 14:04:52
0x3474...7796	MEW darklist: Fake change bank crowdsale site	Advertiment	Llista pública MEW	7/4/2026 16:49:31
0x4da9...f71	MEW darklist: Fake chainlink crowdsale site	Advertiment	Llista pública MEW	7/4/2026 16:49:31
0x008f...eedc	MEW darklist: Fake Kyber crowdsale site kybernet.network	Advertiment	Llista pública MEW	7/4/2026 16:49:31
0x8b3b...f8a7	MEW darklist: Fake KIN crowdsale site kin.kikipro.co	Advertiment	Llista pública MEW	7/4/2026 16:49:31

Informe manual
Afegeix una adreça al conjunt de dades local per aportar context a les anàlisis posteriors.

Adreça Ethereum
0x...

Etiqueta o descripció
Context de l'adreça

Tipus
Advertiment

Afegir al conjunt local

Actualitzar

Figura 10: Consulta i filtratge del conjunt local d'adreces conegudes

4.4.7 Construcció de la resposta

Després de completar el procés d'anàlisi, el backend construeix una resposta estructurada en format JSON que s'envia novament al Snap. En les primeres versions del prototip, aquesta resposta contenia principalment dos camps: el nivell de risc i l'explicació generada. Amb l'evolució del sistema, però, l'estructura s'ha ampliat per incorporar més informació contextual i fer el resultat més complet i traçable.

En la versió actual, la resposta inclou el veredict final de risc, l'acció recomanada, la puntuació associada, els indicis detectats en el camp **findings**, la informació procedent de la memòria local i les coincidències amb adreces conegudes. També pot incorporar la revisió complementària generada per la IA mitjançant l'objecte **ai_review**, que conté camps com el nivell de risc suggerit, la confiança, els indicadors textuais detectats i un resum justificatiu.

El contingut textual generat a partir d'aquesta versió s'expressa en català, inclosos els indicis, els motius del veredict, els missatges d'error i les explicacions deterministes o assistides per Ollama. En canvi, els noms dels camps i els valors enumerats de risc i acció es mantenen estables per compatibilitat. La traducció d'aquests valors es realitza exclusivament a la capa de presentació de la DApp i del Snap.

El veredict final es construeix combinant el resultat determinista amb la revisió complementària de la IA. Les regles deterministes mantenen la prioritat en els patrons

de risc clarament identificats, mentre que la IA només pot aportar context addicional o elevar el nivell de cautela en determinats casos. D'aquesta manera, el model de llenguatge no pot reduir un risc detectat prèviament pel motor de regles.

Abans d'incorporar l'explicació i la revisió de la IA a la resposta definitiva, el backend aplica una capa de control semàntic. Aquesta capa comprova que les afirmacions generades siguin compatibles amb els fets detectats durant l'anàlisi, com ara l'existència d'una aprovació il·limitada, un permís global, una revocació, un enviament de valor o una coincidència amb una adreça etiquetada. Quan la resposta generada és buida, massa extensa o conté contradiccions, el sistema la substitueix per una explicació segura construïda de manera determinista.

La resposta final pot contenir, entre altres elements, els camps següents:

- el veredict final i el nivell de risc;
- la puntuació de risc;
- l'acció recomanada;
- els indicis principals del camp `findings`;
- el context procedent de la memòria local;
- les coincidències amb adreces conegudes;
- la revisió complementària de la IA;
- l'explicació final mostrada a l'usuari;
- les metadades bàsiques de la transacció, com la xarxa o l'origen;
- l'identificador persistent `analysis_id`, les mesures de rendiment i, quan correspon, les metadades d'avaluació.

Aquesta resposta ampliada permet mantenir el Snap com un component lleuger. El Snap no necessita reconstruir el raonament intern del backend ni aplicar les regles de risc, sinó que es limita a adaptar la informació rebuda al format visual permès per MetaMask Snaps. D'aquesta manera, el backend conserva la responsabilitat de l'anàlisi i el Snap se centra en la presentació del resultat dins de la interfície de confirmació.

La Figura 11 sintetitza el flux intern complet del *backend*, des de la recepció i normalització de la petició fins a la construcció de la resposta que es retorna al Snap. El diagrama mostra la intervenció dels principals mòduls d'anàlisi, persistència, context i generació d'explicacions.



Figura 11: *Pipeline* intern del *backend* d'anàlisi

4.5 Integració del mòdul d'intel·ligència artificial

El mòdul d'intel·ligència artificial s'ha integrat amb l'objectiu de millorar la comprensió de les transaccions analitzades. En les primeres versions del prototip, la IA s'utilitzava únicament per transformar el resultat tècnic del *backend* en una explicació en llenguatge natural. Posteriorment, aquesta capa es va ampliar amb una funció de revisió complementària, orientada a aportar una interpretació addicional del cas analitzat sense substituir el motor determinista de regles.

Aquesta evolució permet combinar dues aproximacions diferents: d'una banda, una anàlisi estructurada i auditable basada en regles; de l'altra, una capa de llenguatge natural capaç d'explicar el resultat i ajudar l'usuari a entendre millor què està autòritzant.

4.5.1 Paper de la IA dins del sistema

La IA no constitueix el mecanisme principal de decisió sobre el risc. Aquesta responsabilitat recau en el *backend*, que normalitza la transacció, aplica regles deterministes i construeix un veredict inicial a partir de criteris explícits. El model de llenguatge s'utilitza com a capa complementària, tant per generar una explicació comprensible com per aportar una revisió addicional en casos on el context disponible pot ajudar a matisar el resultat.

Aquesta separació és important perquè evita delegar completament la decisió de seguretat a un model probabilístic. Les regles continuen tenint prioritat en els patrons de risc clarament identificats, com ara aprovacions il·limitades o permisos globals. La IA, en canvi, actua com a suport interpretatiu i comunicatiu, especialment útil per convertir el resultat tècnic en una explicació més accessible per a l'usuari final.

4.5.2 Integració tècnica i selecció del model

La comunicació amb el model de llenguatge es realitza mitjançant el servei local d'Ollama. El backend utilitza el mòdul `ollama.js` per enviar peticions HTTP a l'endpoint `http://localhost:11434/api/generate`.

Cada petició inclou l'identificador del model, el *prompt* construït pel backend i l'opció `stream: false`. Aquesta configuració fa que Ollama retorni la resposta completa en format JSON abans que el backend continuï amb la construcció del resultat final.

El model configurat en el prototip és `llama3.2`, que en l'entorn utilitzat es resol com a `llama3.2:latest`. No s'han establert explícitament paràmetres de mostreig com `temperature`, `top_p` o `num_predict`, de manera que s'utilitzen els valors predefinits proporcionats per Ollama.

En l'entorn de desenvolupament utilitzat, aquest model ocupa aproximadament 2,0 GB segons la informació proporcionada per Ollama. La selecció no deriva d'una comparació experimental formal amb altres models locals, ja que no es van executar proves sistemàtiques de latència, consum de memòria i qualitat entre alternatives. Es va adoptar com una opció compatible amb els recursos disponibles i suficient per a la funció acotada del prototip: generar explicacions breus i aportar una revisió complementària d'un veredict construït principalment mitjançant regles deterministes.

La configuració es concentra al fitxer `backend/services/ollama.js`, que estableix `llama3.2` com a valor predeterminat. L'encapsulació de la comunicació dins d'aquest servei permet substituir el model o modificar-ne la configuració en iteracions futures sense alterar la implementació del Snap ni el motor determinista d'anàlisi.

4.5.3 Generació d'explicacions

La primera funció del mòdul d'IA és generar una explicació en llenguatge natural a partir del resultat de l'anàlisi. Per fer-ho, el *backend* construeix un *prompt* amb la informació principal de la transacció, el tipus d'operació detectada, el nivell de risc i els elements rellevants identificats durant el procés d'anàlisi.

El model utilitzat en el prototip és `llama3.2`, executat mitjançant Ollama. La resposta generada s'incorpora posteriorment al resultat final que el *backend* retorna al Snap, de manera que pugui mostrar-se dins de MetaMask com a part de l'*insight* de seguretat.

Aquest enfocament permet que l'usuari no rebi únicament una etiqueta de risc, sinó també una explicació breu sobre el significat de l'operació. Per exemple, davant d'una aprovació elevada, el sistema pot explicar que l'usuari està concedint permís a una altra adreça perquè pugui moure tokens en el seu nom.

4.5.4 Revisió complementària de la IA

Com a ampliació posterior, el sistema incorpora una revisió complementària generada pel model. Aquesta revisió no substitueix el veredict determinista, sinó que s'utilitza com una senyal addicional dins del procés d'anàlisi. El *backend* pot demanar al model que revisi el cas a partir del context disponible i retorni una valoració estructurada, amb camps com el nivell de risc suggerit, el grau de confiança, possibles indicadors detectats i un resum justificatiu.

En la implementació actual, aquesta informació es representa mitjançant una estructura de tipus `ai_review`, que pot incloure camps com `ai_risk_hint`, `confidence`, `ai_flags` i `reviewer_summary`. Posteriorment, el *backend* combina aquesta revisió amb el veredict determinista i amb els fets semàntics detectats per construir el `final_verdict`.

Aquest plantejament permet aprofitar la capacitat interpretativa del model sense convertir-lo en l'única font de decisió. En els casos crítics detectats per regles, el resultat determinista manté prioritat; en canvi, en casos més ambigus, la revisió de la IA pot ajudar a enriquir el context presentat a l'usuari.

4.5.5 Control semàntic de la resposta

La incorporació d'un model de llenguatge també introdueix el risc que la resposta generada sigui massa genèrica o que inclogui afirmacions no justificades pel contingut real de la transacció. Per reduir aquest problema, el *backend* construeix una capa de fets semàntics a partir de la informació detectada prèviament pel sistema.

Aquests fets indiquen, per exemple, si la transacció correspon a un `approve`, si l'aprovació és il·limitada, si es tracta d'un `setApprovalForAll`, si l'operació envia ETH o si alguna adreça coincideix amb una etiqueta de risc coneguda. Aquesta informació

serveix per limitar la interpretació del model i evitar contradiccions. Així, si el *backend* no ha detectat una aprovació il·limitada, la resposta final no hauria d'afirmar que l'usuari està concedint un permís il·limitat.

Aquest control permet mantenir la IA dins d'un marc més acotat i coherent amb l'anàlisi determinista. D'aquesta manera, el model pot aportar explicacions i revisions complementàries, però sempre condicionades pels fets estructurats que el *backend* ha pogut verificar.

4.5.6 Construcció dels prompts

Els *prompts* utilitzats pel sistema han evolucionat al llarg del desenvolupament. En una primera fase, eren força genèrics i només descrivien de manera bàsica el tipus d'operació, el contracte i alguns paràmetres simples. Aquesta aproximació va ser suficient per validar la comunicació amb Ollama, però generava respostes massa generals.

Posteriorment, els *prompts* es van anar ajustant per incloure més context i instruccions més precises. L'objectiu era obtenir respostes breus, comprensibles i adaptades al cas concret, evitant tecnicismes innecessaris i fent explícit qualsevol element de risc detectat.

El Codi 1 mostra una versió representativa del *prompt* utilitzat per generar explicacions amb Ollama.

Codi 1: Fragment representatiu del *prompt* utilitzat per generar explicacions amb Ollama

```
const prompt = `
Eres un asistente de seguridad para criptomonedas.
Explica EN ESPANOL y de forma MUY SIMPLE que hace esta
    transaccion.

CONTEXTO:
- Tipo: ${txType}
- ${context}
- Desde: ${txData.from || 'usuario'}
- Hacia: ${txData.to || 'contrato desconocido'}
- ${valueInEth}
- Origen: ${txData.origin || 'DApp desconocida'}

INSTRUCCIONES:
1. Explica en 2-3 frases cortas y simples
2. Habla como si le explicaras a alguien que NO sabe de cripto
3. NO uses palabras tecnicas como "0x", "wei", "gas", "ABI"
4. Si hay algo sospechoso, mencionalo claramente
`.trim();
```

5 Avaluació

Aquest capítol presenta l'avaluació del prototip a partir d'una bateria d'escenaris controlats i reproduïbles. L'objectiu és comprovar si el sistema compleix els requisits definits al Capítol 3 i si és capaç d'oferir assistència útil abans de la confirmació d'una transacció dins de MetaMask.

L'avaluació se centra en quatre aspectes principals: la intercepció de transaccions, la detecció de patrons de risc, la generació d'explicacions comprensibles i la integració completa entre la DApp, el Snap, el backend, la base de dades local, Ollama i els contractes desplegats a Sepolia.

Cada escenari s'exposa conjuntament amb el resultat esperat, el resultat observat i els requisits que permet validar. Aquesta organització permet relacionar de manera directa cada prova amb el comportament del sistema i amb el grau de compliment dels requisits.

5.1 Infraestructura i preparació de l'avaluació

Abans de presentar els escenaris de prova i els resultats obtinguts, cal descriure la infraestructura utilitzada per executar l'avaluació i el procediment seguit per preparar les operacions analitzades. Aquesta preparació permet garantir que les proves es duen a terme en un entorn controlat, reproduïble i prou proper a una interacció real amb la xarxa Ethereum.

L'entorn d'avaluació combina els components locals del prototip —la DApp de proves, MetaMask Flask, el Snap, el backend d'anàlisi, la base de dades SQLite i el servei local d'Ollama— amb una infraestructura blockchain externa basada en la xarxa de proves Sepolia.

Sobre aquesta xarxa es despleguen contractes intel·ligents específicament dissenyats per generar operacions representatives, com aprovacions ERC20 limitades o il·limitades i permisos globals sobre actius ERC721.

Aquesta secció descriu el disseny dels contractes de prova, la connexió amb Sepolia, el procés de compilació i desplegament, la verificació mitjançant Etherscan i el protocol utilitzat per generar les transaccions i recollir-ne les evidències. L'objectiu és establir les condicions experimentals necessàries abans d'analitzar, en els apartats posteriors, el comportament del sistema en cada escenari.

5.1.1 Contractes intel·ligents i entorn de proves

Per validar el sistema en un escenari proper a un ús real, es va complementar l'entorn local amb contractes intel·ligents desplegats sobre una xarxa pública de prova. Aquesta decisió permet generar transaccions reals sobre blockchain sense comprometre fons amb valor econòmic, mantenint alhora un entorn controlat i reproduïble.

L'objectiu d'aquesta part de la implementació és disposar d'un conjunt d'operacions representatives que permetin activar el flux complet del sistema: generació de la transacció, recepció a MetaMask, intercepció pel Snap, anàlisi al backend i presentació del resultat a l'usuari. Per aquest motiu, es van utilitzar dos contractes de prova amb finalitats complementàries: un orientat a aprovacions de tokens fungibles i un altre

orientat a permisos globals sobre actius NFT.

5.1.2 Disseny dels contractes de prova

Durant el desenvolupament es van utilitzar dos contractes de prova amb objectius diferenciats. El primer, `SecurityTestContract`, està orientat a generar escenaris relacionats amb tokens fungibles i aprovacions de despesa. El segon, `SecurityTestNFT`, permet generar operacions pròpies d'un contracte ERC721, especialment permisos globals mitjançant `setApprovalForAll(address, bool)`.

El contracte `SecurityTestContract` està escrit en Solidity, hereta ERC20 d'OpenZeppelin¹ [28] i incorpora funcionalitats de gestió bàsica de tokens, dipòsit i retirada d'ETH. Els escenaris avaluats utilitzen la funció estàndard heretada `approve(address, uint256)`, amb selector `0x095ea7b3`, que és la signatura reconeguda pel descodificador del backend. Una aprovació il·limitada pot exposar els actius de l'usuari si l'adreça autoritzada és maliciosa o queda compromesa.

El contracte també conserva `approveSpending(address, uint256)` com a funció auxiliar de demostració, però aquesta té un selector diferent i no forma part de la bateria de classificació. El Codi 2 en mostra una versió simplificada.

Codi 2: Fragment simplificat de la funció `approveSpending` del contracte de prova

```
function approveSpending(address spender, uint256 amount) public
    returns (bool) {
    _approve(msg.sender, spender, amount);

    if (amount >= type(uint256).max / 2) {
        emit DangerousApprovalMade(msg.sender, spender, amount);
    }

    return true;
}
```

Les transaccions de prova documentades es generen amb `approve`; la funció auxiliar només il·lustra com el mateix contracte pot emetre un esdeveniment quan rep una quantitat molt elevada.

De manera complementària, es va implementar el contracte `SecurityTestNFT`, basat en l'estàndard ERC721 d'OpenZeppelin. Aquest contracte defineix una col·lecció de prova amb nom *Security Test NFT* i símbol `STNFT`, i incorpora una funció `mint(address)` restringida al propietari del contracte per generar NFTs de prova.

La rellevància d'aquest segon contracte no es troba en la lògica de minteig, sinó en el fet que, en ser un ERC721 real, exposa les funcions pròpies de l'estàndard, entre les quals destaca `setApprovalForAll(address, bool)`. Aquesta funció permet autoritzar un operador perquè gestioni tots els NFTs de l'usuari dins d'una col·lecció concreta. Per aquest motiu, el cas `setApprovalForAll(true)` es considera especialment sensible i s'ha incorporat com un segon patró de risc dins de l'entorn de proves.

¹OpenZeppelin Contracts és una biblioteca de codi obert d'implementacions auditades dels estàndards més habituals d'Ethereum. Documentació disponible a <https://docs.openzeppelin.com/contracts>.

5.1.3 Connexió amb Sepolia i ús de l'RPC

Per a les proves del prototip es va utilitzar Sepolia [29], una xarxa de prova pública d'Ethereum que permet executar transaccions en un entorn similar al de la xarxa principal sense comprometre fons reals. Aquesta elecció proporciona un context adequat per validar el comportament del sistema en condicions properes a un entorn real, però amb un risc econòmic mínim.

La connexió RPC es va configurar mitjançant Google Cloud Web3 Portal, que actua com a punt d'accés extern a la xarxa. Aquesta infraestructura es va utilitzar per desplegar i executar els contractes de prova, així com per permetre consultes *on-chain*, és a dir, consultes directes a la informació registrada a la blockchain, quan el procés d'anàlisi ho requeria.

5.1.4 Compilació i desplegament amb Hardhat

La compilació i el desplegament dels contractes es van dur a terme amb Hardhat, utilitzat com a entorn principal de desenvolupament per a contractes EVM. La configuració del projecte inclou suport per a una xarxa local de desenvolupament i per a Sepolia, definint la *chainId* corresponent i una URL RPC externa per connectar-se a la xarxa.

Per motius de seguretat, la clau privada i la configuració del node RPC no es van incrustar directament al codi font, sinó que es van gestionar mitjançant variables d'entorn. Aquesta decisió evita exposar credencials sensibles dins del repositori o dels scripts de desplegament.

El procés de desplegament es va automatitzar amb scripts específics que compilen els contractes, els publiquen a Sepolia i mostren les adreces obtingudes per a la seva posterior utilització en les proves.

5.1.5 Verificació del contracte a Etherscan

Un cop desplegat, el contracte es va verificar a Etherscan. Aquest pas és especialment rellevant en el context del TFG, perquè converteix el contracte en un objecte públicament inspeccionable: el codi font, les funcions i la interfície de *Write Contract* queden accessibles i poden utilitzar-se tant per a auditar la implementació com per generar transaccions manualment. La verificació es va completar correctament i el contracte es va poder consultar i utilitzar mitjançant la interfície d'Etherscan.

La verificació aporta també un valor metodològic important. Permet demostrar que les proves no depenen exclusivament d'una DApp construïda a mida per al projecte, sinó que el sistema és capaç de reaccionar davant d'interaccions iniciades des d'una eina externa i coneguda pel sector, sempre que la signatura final passi per MetaMask.

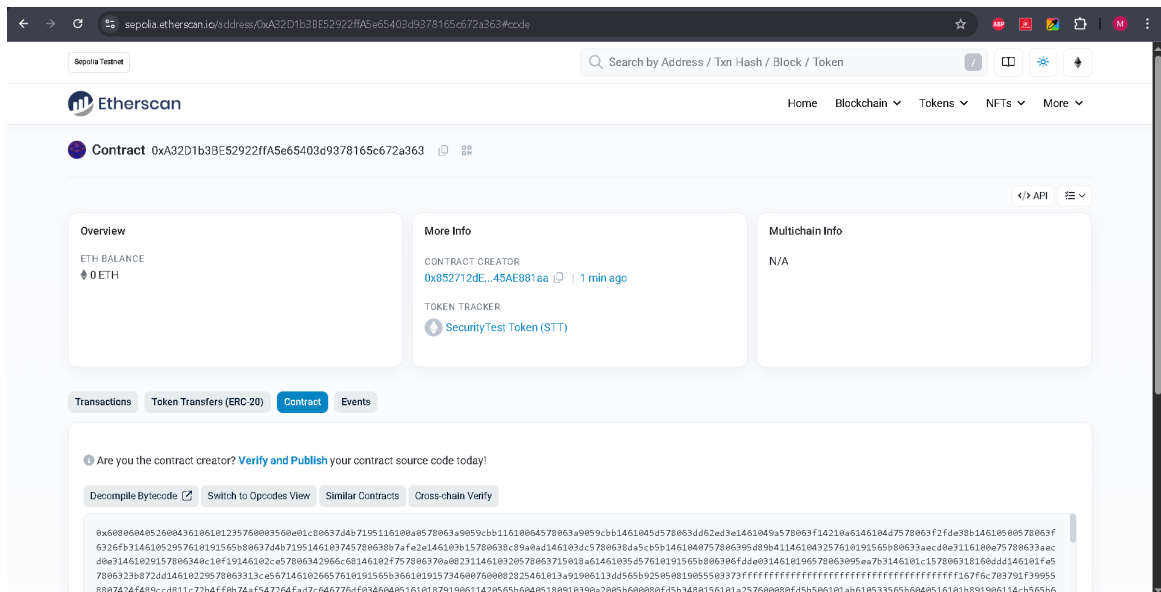


Figura 12: Contracte `SecurityTestContract` verificat a Etherscan sobre la xarxa Sepolia

5.1.6 Preparació de les operacions de prova

A partir dels contractes desplegats es van preparar diferents operacions representatives per activar el flux d'anàlisi del sistema. Els escenaris principals inclouen aprovacions limitades, aprovacions molt elevades o pràcticament il·limitades, permisos globals mitjançant `setApprovalForAll(address, bool)` i operacions de dipòsit d'ETH.

En el cas de `SecurityTestContract`, els escenaris se centren en operacions associades a tokens fungibles, especialment aprovacions de despesa. La DApp pot construir manualment la *calldata* corresponent a partir del selector de la funció i dels paràmetres codificats, cosa que permet generar transaccions controlades amb diferents nivells de risc.

En el cas de `SecurityTestNFT`, l'escenari principal és l'autorització global d'un operador mitjançant `setApprovalForAll(true)`. Aquesta operació és diferent d'una aprovació ERC20, ja que no autoritza una quantitat concreta de tokens, sinó la gestió de tots els NFTs de l'usuari dins d'una col·lecció. Per aquest motiu, el backend la tracta com un patró de risc específic quan el paràmetre `approved` és cert. En canvi, `setApprovalForAll(false)` es pot interpretar com una revocació del permís global.

Aquests escenaris constitueixen la base funcional sobre la qual es duen a terme les proves descrites posteriorment al Capítol 5.

Una part de les operacions no es genera des de la DApp, sinó des de la pestanya *Write Contract* d'Etherscan. Aquesta funcionalitat de l'explorador de blocs està disponible per a qualsevol contracte amb el codi font verificat i construeix un formulari a partir de l'ABI publicada: mostra la llista de funcions que modifiquen l'estat de la blockchain, un camp d'entrada per a cada paràmetre i un botó que prepara la transacció corresponent. Quan l'usuari confirma l'operació, Etherscan no la signa, sinó que la delega a la cartera connectada, que és qui demana la signatura final.

Aquest mecanisme té dos avantatges per a l'avaluació. D'una banda, permet invocar les funcions reals dels contractes desplegats sense escriure la *calldata* manualment, ja

que és el mateix explorador qui la codifica a partir dels valors introduïts. De l'altra, i més important, demostra que el sistema reacciona davant d'operacions iniciades des d'una eina externa i àmpliament utilitzada al sector, i no únicament des de la DApp construïda a mida per al projecte. La Figura 13 mostra aquesta interfície durant l'execució d'una operació sobre un dels contractes de prova.

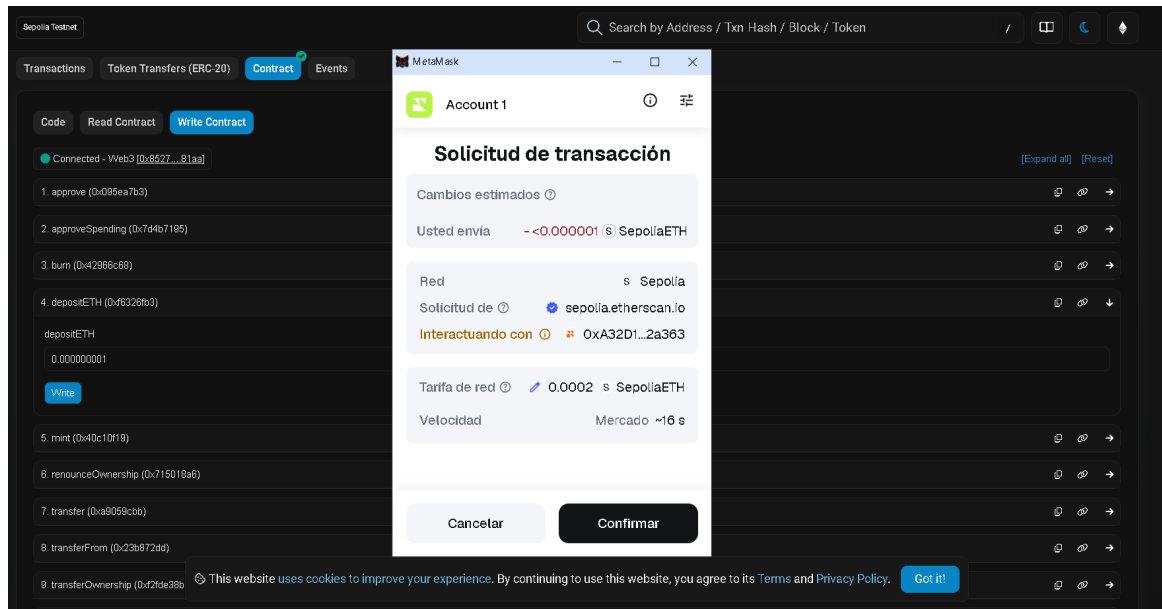


Figura 13: Execució d'una operació sobre el contracte des de la interfície

5.1.7 Protocol d'execució i recollida d'evidències

Amb l'objectiu de garantir que els resultats obtinguts siguin comparables i reproduïbles, s'ha definit un protocol comú per a l'execució dels diferents escenaris de prova. Aquest protocol estableix la configuració de l'entorn, l'estat inicial dels components, el nombre de repeticions, les dades que s'han de registrar i els criteris utilitzats per considerar una prova completada satisfactòriament.

Configuració de l'entorn Les proves s'executen sobre un mateix equip i mantenint una configuració estable durant tota la bateria d'avaluació. La Taula 5 resumeix els principals elements de l'entorn utilitzat.

Les versions indicades es van mantenir constants durant les proves dels dies 17 i 18 de juliol de 2026. El codi i les evidències estructurades es conserven conjuntament al repositori local del projecte.

Control de l'estat inicial Abans d'iniciar cada grup de proves es comprova que la DApp, el servidor del Snap, el backend i Ollama es troben en execució. També es verifica l'estat dels serveis mitjançant els endpoints locals `/health` i `/stats`.

Les proves s'executen, sempre que l'escenari no indiqui el contrari, amb el mateix compte de MetaMask i sobre les mateixes adreces dels contractes desplegats a Sepolia. Aquesta decisió permet reduir variables externes i comparar els resultats de diferents operacions sota unes condicions equivalents.

L'estat de la base de dades també es controla abans de cada grup de proves. Els

Element	Configuració utilitzada
Processador	AMD Ryzen 7 3700U with Radeon Vega Mobile Gfx
Memòria RAM	13,9 GB
Targeta gràfica	AMD Radeon RX Vega 10 Graphics
Sistema operatiu	Microsoft Windows 10 Home, versió 10.0.19045
Navegador	Google Chrome 149.0.7827.200
Entorn d'execució	Node.js 20.11.1 i npm 10.2.4
Cartera	MetaMask Flask 13.39.2-flask.0 amb el Snap instal·lat en local
Backend	Servei local executat al port 3000
Base de dades	SQLite local
Servei d'IA	Ollama 0.16.1, executat al port 11434
Model de llenguatge	llama3.2:latest, amb una mida aproximada de 2,0 GB
Xarxa blockchain	Xarxa de proves Sepolia
Proveïdor RPC	Google Cloud Web3 Portal
Contractes de prova	<code>SecurityTestContract</code> i <code>SecurityTestNFT</code> desplegats a Sepolia

Taula 5: Configuració de l'entorn utilitzat durant l'avaluació

escenaris destinats a validar exclusivament les regles deterministes parteixen d'un estat inicial conegut, evitant que l'historial acumulat alteri el resultat. En canvi, l'escenari dedicat a la memòria local i a les adreces etiquetades utilitza una base de dades preparada amb els registres necessaris per comprovar aquesta funcionalitat.

Quan una prova requereix un estat previ de la blockchain, les operacions s'executen en l'ordre corresponent. Per exemple, una prova de revocació necessita que el permís hagi estat concedit prèviament abans d'executar `approve(spender, 0)` o `setApprovalForAll(operator, false)`.

Nombre de repeticions L'avaluació quantitativa executa deu observacions per a cadascun dels vuit casos classificables A1, B1, B2, C1, C2, D1, D2 i E1, és a dir, 80 execucions del motor determinista. Un script reproduïble genera la *calldata*, executa el descodificador i les regles i desa cada observació en formats JSON i CSV. El cas C2 introdueix deu quantitats d'aprovació diferents per estudiar el comportament al voltant del límit: set valors superiors a 2^{255} , però diferents de `MaxUint256`, i tres imports acotats de control. El cas E1 utilitza una adreça controlada amb l'etiqueta `scam`. Els escenaris d'interfície i integració A, G i H es validen addicionalment amb execucions manuals i captures de MetaMask, ja que impliquen components externs que no formen part de l'executor automatitzat.

En particular, les repeticions resulten rellevants perquè les peticions actuals a Ollama no fixen explícitament una llavor de generació. Per tant, encara que la transacció i el veredict determinista siguin els mateixos, la formulació textual de la resposta pot presentar petites variacions entre execucions.

Cada observació automatitzada es registra als fitxers `evaluation-matrix.json` i `evaluation-matrix.csv`. Les execucions manuals del flux complet es registren també

a SQLite. Les 80 observacions combinen repeticions dels patrons principals amb la variació explícita de quantitats del cas C2; per tant, la matriu mesura la consistència dels patrons implementats i incorpora una prova de frontera, però no constitueix una estimació general de seguretat davant de qualsevol transacció desconeguda.

Procediment d'execució Per a cada prova se segueix la seqüència següent:

1. S'inicien la DApp, el servidor del Snap, el backend local i el servei d'Ollama.
2. Es comprova que tots els components necessaris responen correctament i que MetaMask Flask té instal·lada la versió corresponent del Snap.
3. Es verifica la xarxa seleccionada, el compte de proves i l'adreça del contracte o destinatari utilitzat.
4. S'estableix la classe real de l'operació abans d'observar el resultat del sistema. Aquesta classe indica si l'operació es considera positiva, perquè conté un patró de risc, o negativa, perquè no presenta cap dels riscos contemplats.
5. S'inicia l'operació des de la DApp local o des de la interfície *Write Contract* d'Etherscan.
6. MetaMask Flask rep la petició i activa el Snap mitjançant `onTransaction`.
7. El Snap envia les dades al backend i espera la resposta estructurada.
8. Es registra el veredict determinista, la revisió complementària de la IA, el veredict final i l'explicació mostrada.
9. Es captura l'*insight* presentat dins de MetaMask abans de confirmar o cancel·lar l'operació.
10. Es registra si la transacció s'ha cancel·lat o confirmat i, quan es confirma, s'emmagatzema també el seu identificador o *hash* a Sepolia.

Mesura del temps de resposta Per avaluar el rendiment es diferencien dos temps. El primer és el temps de processament del backend, mesurat des de la recepció de la petició a l'endpoint `/analyze` fins a la generació de la resposta JSON. El segon és el temps total d'anàlisi, mesurat des de l'activació de `onTransaction` fins que el Snap disposa del resultat que es mostrarà a MetaMask.

La mesura principal de rendiment no inclou el temps posterior necessari perquè una transacció confirmada sigui incorporada a un bloc de Sepolia, ja que aquesta espera depèn de l'estat de la xarxa i es produeix després de l'anàlisi de seguretat. Quan sigui rellevant, el temps de confirmació a Sepolia es registra de manera separada.

Per al conjunt de set anàlisis representatives executades amb Ollama es calcula el temps mínim, el temps màxim i la mitjana:

$$\bar{T} = \frac{1}{n} \sum_{i=1}^n T_i$$

on T_i representa el temps registrat en cada execució i n és el nombre total de repeticions.

Dades recollides Per a cada execució es registren, com a mínim, les dades següents:

- **Identificació:** escenari, número de repetició, data i hora, origen de l'operació (DApp o Etherscan) i xarxa utilitzada.
- **Transacció:** adreça de destinació, selector, tipus d'operació detectada i paràmetres rellevants.
- **Classificació determinista:** classe real assignada prèviament, nivell i puntuació de risc, acció recomanada, indicis del camp `findings` i context local o etiquetes d'adreces.
- **Capa d'IA:** contingut d'`ai_review`, veredict final i explicació mostrada a l'usuari.
- **Execució:** temps de processament, resultat de la prova, decisió de confirmar o cancel·lar, *hash* de la transacció quan escaigui i missatge d'error si no finalitza correctament.

Les dades estructurades es complementen amb registres del backend, consultes a SQLite i captures de la interfície de MetaMask. Les captures s'utilitzen com a evidència visual, però no substitueixen els valors registrats de manera estructurada.

Confirmació o cancel·lació de les operacions La major part dels escenaris tenen com a objectiu validar el comportament del sistema abans de la confirmació. En aquests casos, després de recollir l'*insight* i la resta d'evidències, la transacció es pot cancel·lar sense necessitat de modificar l'estat de la blockchain.

No obstant això, les proves que requereixen validar el flux complet sobre Sepolia o establir un estat previ es confirmen. Això inclou, entre d'altres, les operacions necessàries per concedir un permís abans de provar-ne la revocació i l'escenari de validació integral iniciat des d'Etherscan.

Totes les transaccions confirmades es realitzen exclusivament sobre Sepolia i amb contractes i actius de prova, de manera que no impliquen l'ús de fons amb valor econòmic real.

Criteris de finalització i compliment Una execució funcional es considera completada quan es compleixen les condicions següents:

- MetaMask invoca correctament el Snap;
- el Snap envia la petició al backend;
- el backend genera una resposta estructurada;
- el resultat es mostra dins de MetaMask abans de la confirmació;
- les dades i evidències de l'execució queden registrades.

La prova es considera **completa** quan el comportament observat coincideix amb el resultat esperat i no es produeixen errors que impedeixin el flux principal. Es considera **parcialment completa** quan la funcionalitat principal s'executa, però algun resultat secundari, com la classificació, l'explicació o el temps de resposta, no compleix completament el criteri establert. Finalment, es considera **no completa** quan el sistema no pot executar el flux requerit o produeix un resultat incompatible amb l'objectiu de la prova.

En l'escenari de tolerància a errors, la indisponibilitat intencionada d'un component no es considera per si mateixa un error de la prova. En aquest cas, el resultat satisfactori consisteix a comprovar que el sistema informa de la incidència de manera controlada i que no impedeix injustificadament que l'usuari continuï gestionant la transacció.

Aquest protocol permet executar els escenaris següents sota unes condicions homogènies i relacionar els resultats observats amb els requisits funcionals i no funcionals definits prèviament.

5.1.8 Monitorització i inspecció dels resultats

Durant l'avaluació, el quadre de comandament de la DApp es va utilitzar per supervisar l'estat dels components, comprovar l'acumulació de resultats i inspeccionar els registres persistits després de cada prova. Aquesta vista complementa les evidències mostrades dins de MetaMask, ja que permet observar de manera agregada la distribució dels nivells de risc, els mètodes detectats i l'historial recent d'anàlisis.

La Figura 14 mostra el quadre de comandament utilitzat durant la bateria de proves. Els comptadors i gràfics permeten contrastar que les execucions queden registrades i que els veredictes obtinguts es distribueixen d'acord amb els casos segurs i de risc definits en el protocol.

Per a cada registre, la interfície proporciona una vista detallada que facilita l'auditoria del resultat. Les Figures 15 i 16 corresponen a una aprovació ERC20 il·limitada classificada amb risc alt. La primera permet verificar el veredict, la puntuació, l'acció recomanada i els indicadors principals; la segona presenta la descodificació de l'operació, la revisió complementària de la IA, el criteri determinista aplicat i les mesures de rendiment.

Aquestes vistes es van utilitzar com a mecanisme de suport per revisar la coherència entre l'entrada descodificada, els indicadors emmagatzemats i la decisió final del sistema. Per tant, la seva funció dins del Capítol 5 és documentar la traçabilitat de cada resultat i no únicament descriure la implementació visual de la DApp.

5.2 Estratègia d'avaluació i traçabilitat dels requisits

L'avaluació combina proves funcionals sobre transaccions reals, verificacions qualitatives de les explicacions generades i comprovacions estructurals de l'arquitectura local. No es pretén realitzar una comparació estadística amb productes comercials, sinó demostrar la viabilitat del prototip dins d'un entorn de proves controlat.

La Taula 6 relaciona els requisits definits al Capítol 3 amb els escenaris o verificacions utilitzats per comprovar-los. La correspondència és bidireccional: cada escenari de l'apartat 5.4 indica els requisits que valida i, inversament, aquesta taula recull tots

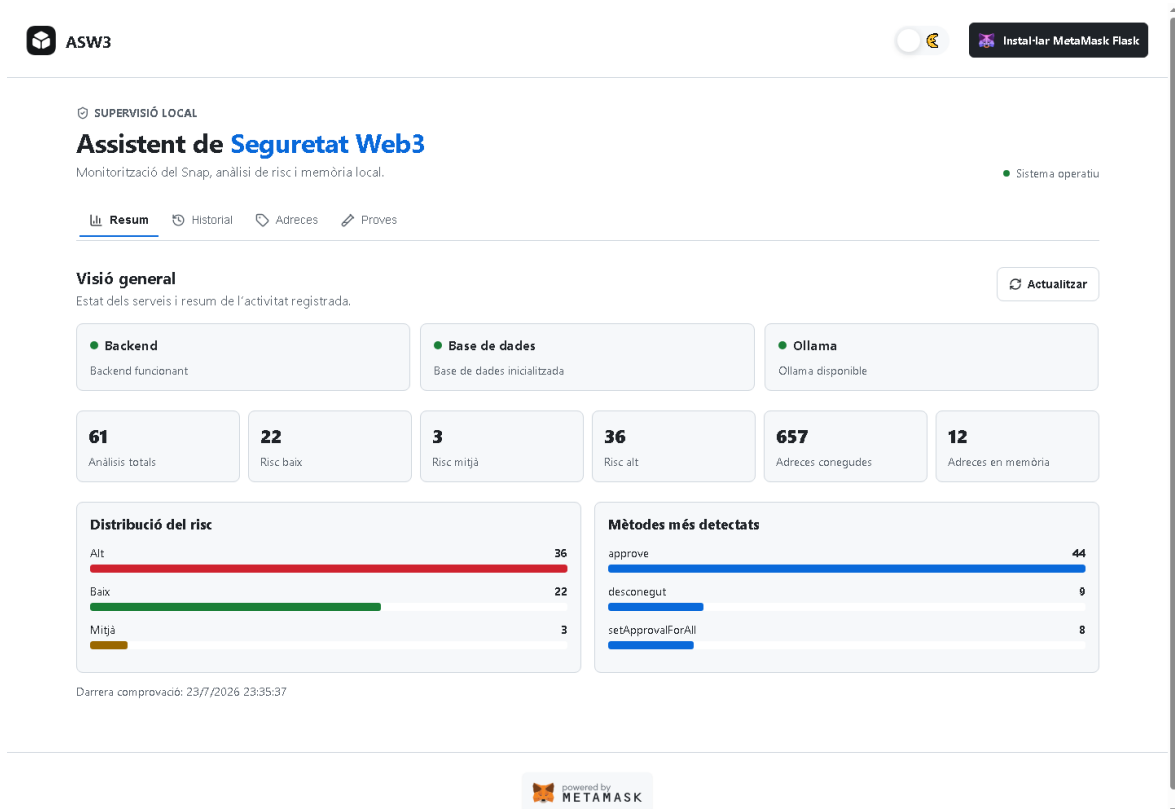


Figura 14: Monitorització agregada dels resultats obtinguts durant l'avaluació

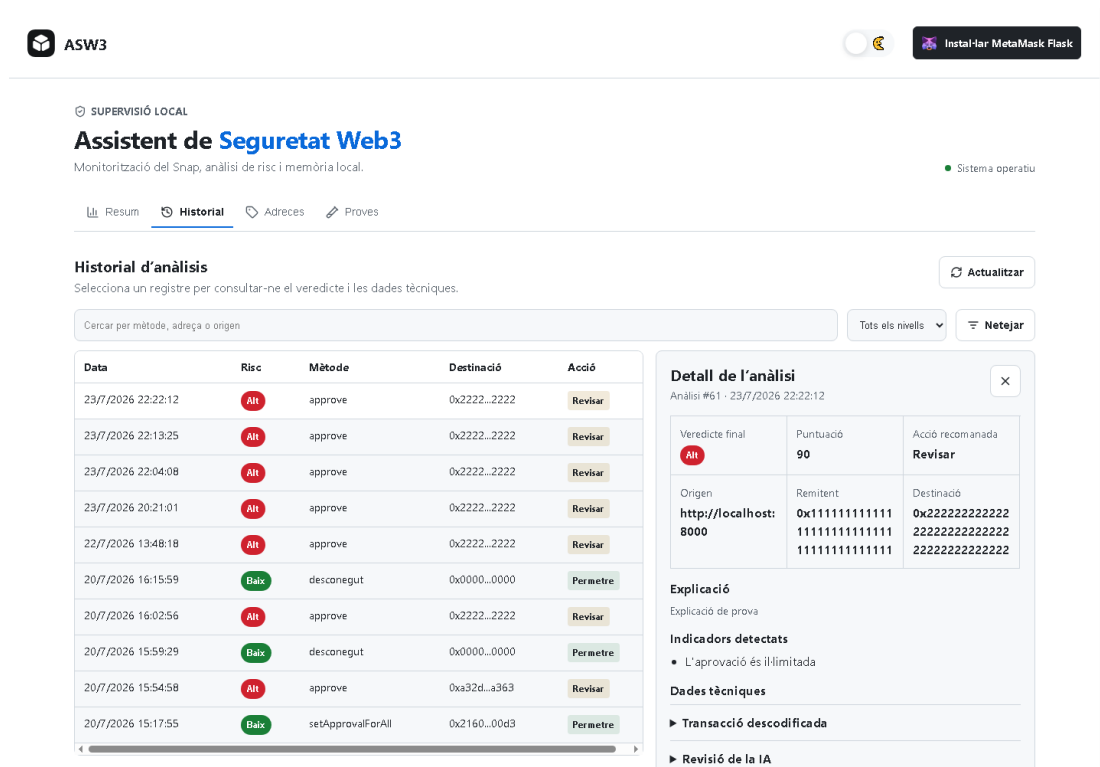
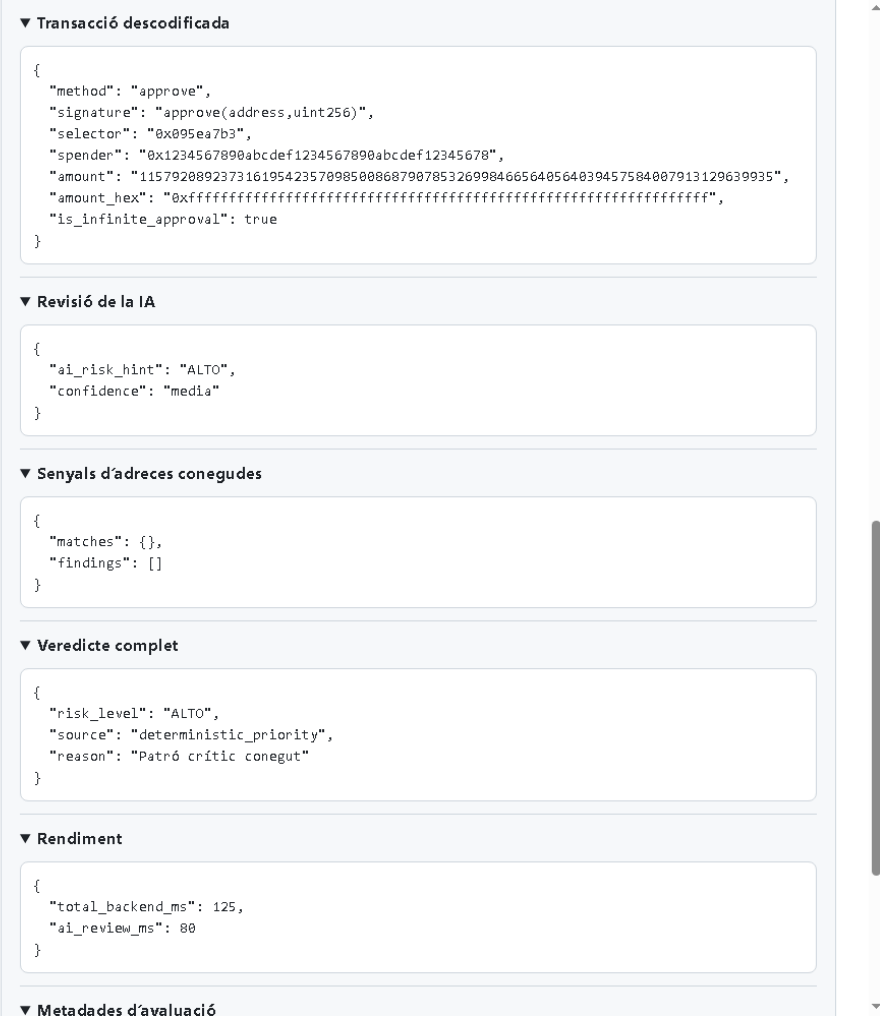


Figura 15: Inspecció del veredict i dels indicadors d'una aprovació ERC20 il·limitada



▼ Transacció descodificada

```
{
  "method": "approve",
  "signature": "approve(address,uint256)",
  "selector": "0x095ea7b3",
  "spender": "0x1234567890abcdef1234567890abcdef12345678",
  "amount": "115792089237316195423570985008687907853269984665640564039457584007913129639935",
  "amount_hex": "0xffffffffffffffffffffffffffffffffffffffffffffffffffffffffffffffff",
  "is_infinite_approval": true
}
```

▼ Revisió de la IA

```
{
  "ai_risk_hint": "ALTO",
  "confidence": "media"
}
```

▼ Senyals d'adreces conegudes

```
{
  "matches": {},
  "findings": []
}
```

▼ Veredict complet

```
{
  "risk_level": "ALTO",
  "source": "deterministic_priority",
  "reason": "Patró crític conegut"
}
```

▼ Rendiment

```
{
  "total_backend_ms": 125,
  "ai_review_ms": 80
}
```

▼ Metadades d'avaluació

Figura 16: Evidència de descodificació, revisió complementària, veredict i rendiment

els escenaris que intervenen en la validació de cada requisit.

Requisit	Mètode de validació	Escenari o evidència
RF1 – Intercepció de transaccions	Comprovació que el Snap s’activa abans de la confirmació dins de MetaMask.	Escenaris A i G.
RF2 – Anàlisi de risc basat en regles	Execució d’operacions ERC20 i ERC721 amb nivells de risc diferents.	Escenaris B, C, D, E i G.
RF3 – Generació d’explicacions comprensibles	Revisió qualitativa de la coherència, la claredat i la utilitat de l’explicació generada.	Escenaris B, C, D, E i F.
RF4 – Integració dins la interfície de la cartera	Comprovació que l’ <i>insight</i> es mostra dins de MetaMask abans de confirmar.	Escenaris A, B, C, D i G.
RNF1 – Rendiment	Mesura del temps complet de resposta des de la petició fins a la visualització del resultat.	Escenari H i, parcialment, G.
RNF2 – Privadesa	Verificació que l’anàlisi, la persistència i la generació de text s’executen localment sempre que és possible.	Escenaris E i G, i revisió arquitectònica.
RNF3 – Fiabilitat	Comprovació del comportament del sistema quan el backend o el servei d’IA no estan disponibles.	Escenari H i, parcialment, A.
RNF4 – Extensibilitat	Revisió de la separació modular entre normalització, decodificació, regles, persistència i IA.	Escenaris E i F, i revisió de la implementació (Capítol 4).
RNF5 – Usabilitat	Valoració qualitativa del llenguatge i de la utilitat de la informació mostrada a l’usuari.	Escenari F.

Taula 6: Traçabilitat entre requisits i mecanismes de validació

5.3 Escala de puntuació del risc

Els resultats dels escenaris següents s’expressen mitjançant tres valors complementaris: un nivell de risc (**BAJO**, **MEDIO** o **ALTO**), una puntuació numèrica entre 0 i 100, i una acció recomanada (**ALLOW** o **REVIEW**). Aquest apartat descriu com s’assignen aquests valors, de manera que les puntuacions observades a l’avaluació es puguin interpretar correctament.

Naturalesa de la puntuació La puntuació no és una probabilitat ni una estimació estadística de la perillositat d’una operació. Es tracta d’una **escala ordinal** en què cada patró reconegut pel motor determinista té assignat un valor fix, escollit de manera que l’ordre relatiu entre patrons reflecteixi l’abast del permís que es concedeix. Aquesta decisió és coherent amb la prioritat del motor determinista descrita al Capítol 3: davant

de la mateixa entrada, el sistema ha de produir sempre la mateixa puntuació, sense que intervingui cap component probabilístic.

El criteri que ordena l'escala és la **capacitat de disposició sobre els actius** que l'operació atorga a un tercer. Com més ampli i més durador és el permís, més alta és la puntuació.

Puntuacions base del motor determinista La Taula 7 recull el valor assignat a cada patró reconegut.

Patró detectat	Nivell	Punt.	Acció
<code>setApprovalForAll(operator, true)</code> — permís global sobre una col·lecció	ALTO	95	REVIEW
<code>approve</code> amb quantitat igual a <code>MaxUint256</code> — aprovació il·limitada	ALTO	90	REVIEW
Interacció amb un contracte que el descodificador no reconeix	MEDIO	50	REVIEW
<code>approve</code> amb una quantitat limitada	BAJO	20	ALLOW
Transferència simple, sense crida a contracte	BAJO	10	ALLOW
<code>approve</code> amb quantitat 0 — revocació d'un permís	BAJO	5	ALLOW
<code>setApprovalForAll(operator, false)</code> — revocació del permís global	BAJO	5	ALLOW

Taula 7: Puntuacions base assignades pel motor determinista a cada patró

L'ordre d'aquests valors respon a criteris concrets. El permís global ERC721 rep la puntuació més alta (95) perquè autoritza un operador a disposar de *tots* els actius de l'usuari dins d'una col·lecció, sense cap límit de quantitat i fins que es revoqui explícitament. L'aprovació il·limitada ERC20 (90) és igualment persistent, però queda circumscrita a un únic token, motiu pel qual se situa immediatament per sota. La franja intermèdia (50) correspon a les crides que el descodificador no reconeix: no hi ha evidència de perill, però tampoc context suficient per descartar-lo, i per això el sistema recomana una revisió manual sense afirmar que l'operació sigui maliciosa. Finalment, les revocacions reben la puntuació més baixa (5) perquè *redueixen* l'exposició de l'usuari, per sota fins i tot d'una transferència simple (10).

Ajust per context d'adreces Sobre la puntuació base, el sistema aplica un ajust quan alguna de les adreces implicades —destinació, *spender* o *operator*— coincideix amb un registre de la taula d'adreces conegudes. La Taula 8 en resumeix els valors.

Tipus d'etiqueta	Ajust	Efecte sobre el nivell
<code>scam, blacklist</code>	+50	Força el nivell a ALTO i l'acció a REVIEW.
<code>warning, suspicious</code>	+25	Eleva a MEDIO si el nivell era BAJO.
<code>trusted, known_protocol, test_contract</code>	-10	Cap. Aporta context de confiança, però no rebaixa el nivell.

Taula 8: Ajustos aplicats a la puntuació segons el context d'adreces conegudes

El resultat de la suma es limita sempre a l'interval $[0, 100]$. És important remarcar que una etiqueta de confiança redueix la puntuació però **no pot rebaixar el nivell de risc** ja establert pel motor: una aprovació il·limitada dirigida a un contracte de prova continua sent **ALTO**. Aquesta asimetria és deliberada i evita que una etiqueta incorrecta o desactualitzada emmascari un patró crític.

Interpretació dels valors observats Amb aquestes regles, les puntuacions que apareixen als escenaris següents queden completament explicades. Una puntuació de 95 correspon sempre a l'activació d'un permís global i una de 90 a una aprovació il·limitada, tots dos patrons crítics detectats directament per les regles. Una puntuació de 60, com la de l'escenari E, és el resultat de combinar una transferència simple (10) amb una etiqueta **scam** (+50): el patró tècnic és inofensiu, però el destinatari està marcat com a maliciós, i és el context el que eleva el veredict. De manera anàloga, una aprovació limitada dirigida a una adreça etiquetada assoleix 70, resultat de sumar la base 20 i el mateix ajust.

Finalment, l'acció recomanada es deriva directament del nivell. Els nivells **MEDIO** i **ALTO** produeixen **REVIEW**, mentre que **BAJO** produeix **ALLOW**. Aquesta correspondència és la que s'utilitza a l'apartat 5.5 per agrupar les prediccions en dues classes i construir la matriu de confusió.

5.4 Escenaris de prova i resultats

Els escenaris següents s'han dissenyat per exercitar els patrons de transacció més rellevants implementats al prototip. Cada prova inclou el seu objectiu, els requisits associats, la preparació necessària, el resultat esperat i l'evidència que s'ha de recollir.

5.4.1 Escenari A – Interceptació bàsica i visualització dins de MetaMask

Objectiu. Verificar que MetaMask Flask invoca correctament el Snap abans de la confirmació d'una transacció.

Requisits validats. RF1, RF4 i parcialment RNF3.

Preparació. S'inicia una transacció des de la DApp local amb MetaMask Flask, el Snap i el backend en execució.

Resultat esperat. El Snap ha d'interceptar la transacció, enviar-ne les dades al backend i mostrar un *insight* dins de MetaMask abans de la confirmació final.

Resultat observat. Les deu repeticions automatitzades del cas A1 van produir deu vertaders negatius amb risc **BAJO**, puntuació 10 i acció **ALLOW**. En la validació d'interfície, MetaMask va activar el Snap abans de la confirmació i va mostrar el mateix resultat. L'execució manual va quedar registrada a SQLite amb l'identificador 43. La primera captura es va obtenir accidentalment a *mainnet*; el flux sobre Sepolia es va confirmar posteriorment a l'escenari G.

Evidència. Captura de MetaMask amb l'*insight* visible (Figura 17), registre del backend i resposta JSON generada.

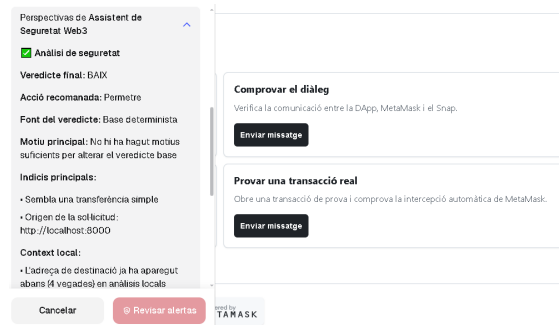


Figura 17: Insight del Snap mostrat abans de confirmar la transacció

5.4.2 Escenari B – Aprovació ERC20 limitada i revocació

Objectiu. Comprovar que el sistema diferencia una aprovació limitada d'una revocació de permisos mitjançant una quantitat igual a zero.

Requisits validats. RF2, RF3 i RF4.

Preparació. S'executen dues operacions ERC20: una aprovació limitada mitjançant `approve(spender, amount)` i una revocació mitjançant `approve(spender, 0)`.

Resultat esperat. El sistema ha d'identificar el tipus d'operació, indicar el destinatari del permís i classificar la revocació com una operació de risc baix. L'aprovació limitada ha de rebre un tractament menys restrictiu que una aprovació il·limitada.

Resultat observat. Les deu repeticions de B1 van identificar `approve(address,uint256)` amb una quantitat de 10^{18} unitats com una aprovació limitada: risc BAJO, puntuació 20 i ALLOW. Les deu repeticions de B2, amb quantitat zero, es van descriure com una revocació i van obtenir risc BAJO, puntuació 5 i ALLOW. Els registres manuals de referència corresponen als identificadors 36 i 37; una comprovació des d'Etherscan Sepolia va quedar registrada amb l'identificador 45.

Evidència. Captures dels *insights* (Figura 18), dades descodificades de la transacció i registres del motor de regles.

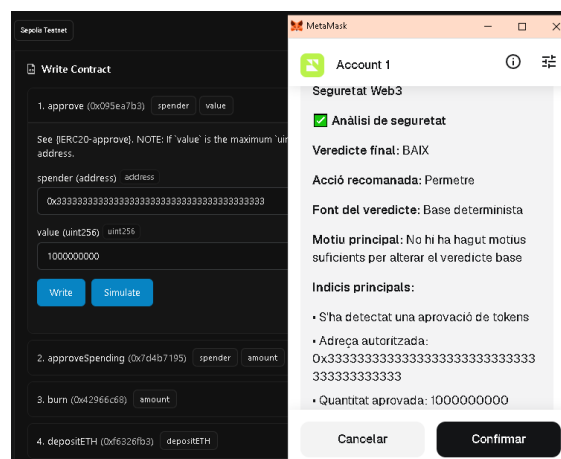
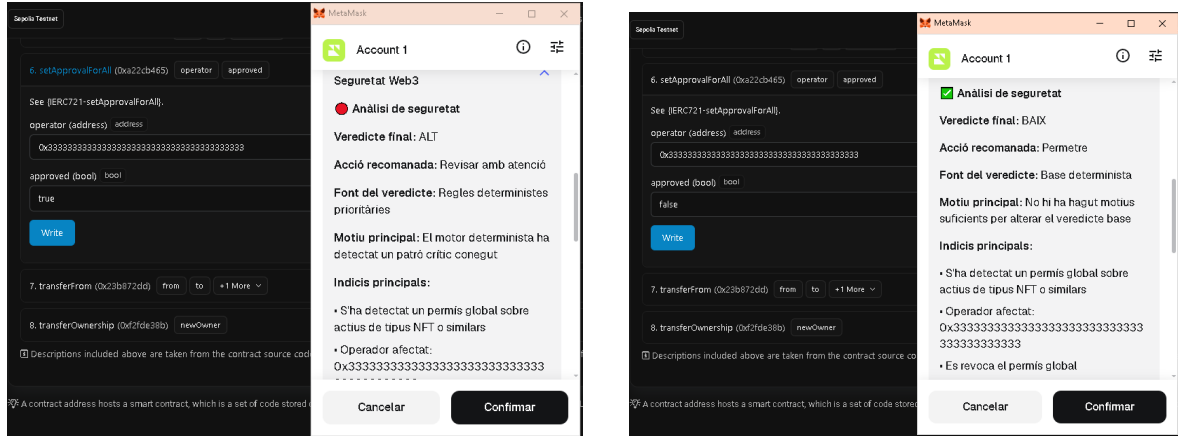


Figura 18: Detecció d'una aprovació ERC20 limitada iniciada des d'Etherscan

ració d'alt risc, ja que l'operador podria gestionar tots els NFTs de la col·lecció. La revocació ha de ser descrita com una acció de risc baix.

Resultat observat. Les deu repeticions de l'activació del permís global (D1) van obtenir risc **ALTO**, puntuació 95 i **REVIEW**; les deu repeticions de la revocació (D2) van obtenir risc **BAJO**, puntuació 5 i **ALLOW**. Les execucions manuals de referència corresponen als registres 39 i 40.

Evidència. Captures de MetaMask per als dos sentits del permís (Figura 20), dades descodificades, indicis generats i resposta final del backend.



(a) Activació del permís global: risc **ALTO**

(b) Revocació del permís: risc **BAJO**

Figura 20: Diferenciació de `setApprovalForAll(true)` i `setApprovalForAll(false)` sobre el contracte NFT de Sepolia

5.4.5 Escenari E – Context local i adreces etiquetades

Objectiu. Verificar que el sistema incorpora informació procedent de la base de dades local i de les etiquetes d'adreces conegudes dins del veredict.

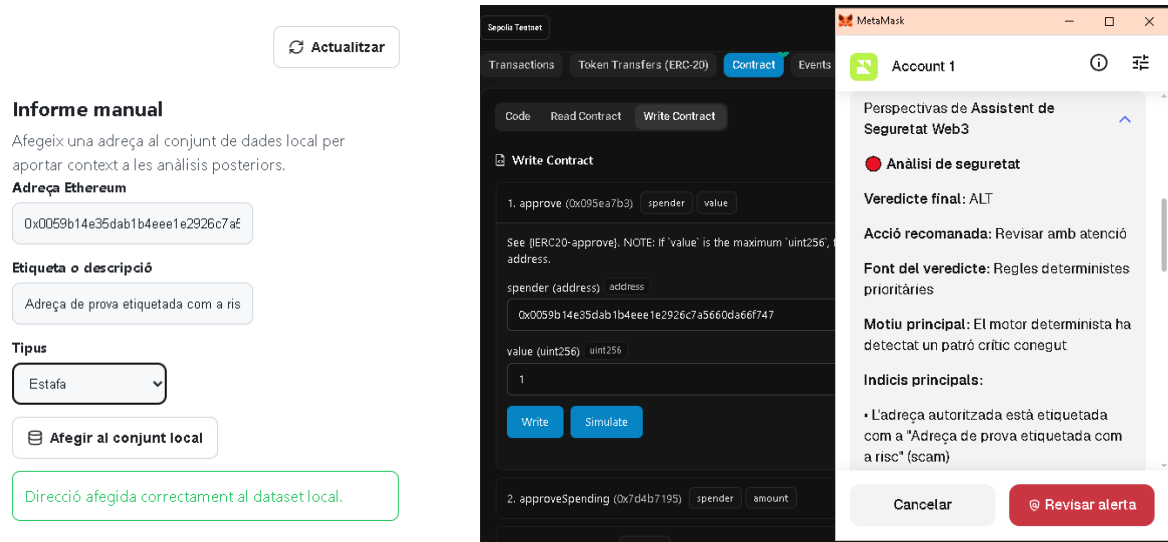
Requisits validats. RF2, RF3, RNF2 i RNF4.

Preparació. S'analitza una transacció dirigida a una adreça registrada prèviament a la base de dades o etiquetada per una font externa com a adreça de risc.

Resultat esperat. El backend ha d'afegir context rellevant sobre l'adreça, reflectir-lo en els indicis i evitar que aquest context es presenti com una prova absoluta si només constitueix una alerta informativa.

Resultat observat. Es va registrar una adreça controlada amb l'etiqueta **scam**. Les deu repeticions d'E1 van incorporar aquesta condició, van aplicar l'ajust de context i van obtenir risc **ALTO** amb puntuació 60. Una execució manual que inclou la coincidència i la font als indicis es conserva al registre 41.

Evidència. Registres de SQLite, coincidències amb etiquetes conegudes, resposta JSON i captura de l'*insight* mostrat a MetaMask (Figura 21).



(a) Alta manual de l'adreça controlada amb tipus scam

(b) Aprovació limitada elevada a risc ALT0 pel context de l'adreça

Figura 21: Incorporació d'una etiqueta local de risc al veredict de l'escenari E

5.4.6 Escenari F – Explicació de la IA i control semàntic

Objectiu. Avaluar si la IA genera explicacions comprensibles i comprovar que la capa de control semàntic evita afirmacions incompatibles amb els fets detectats.

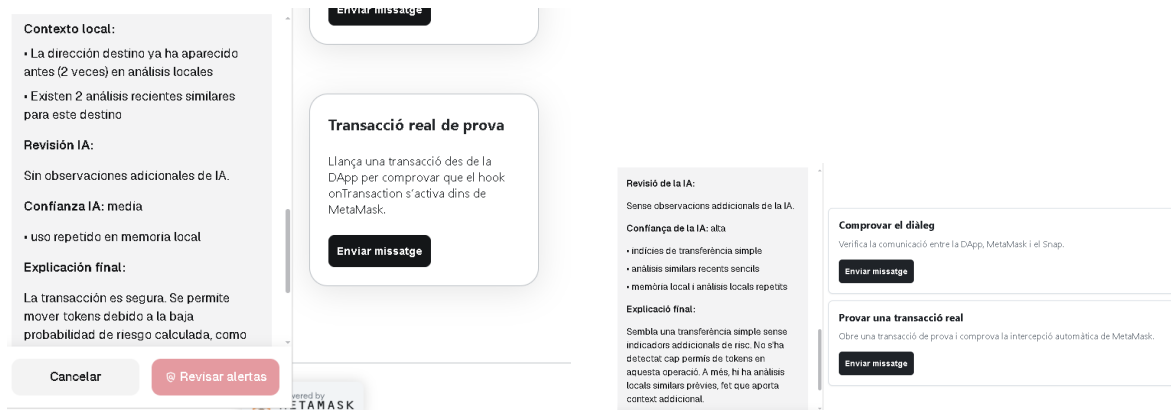
Requisits validats. RF3, RNF4 i RNF5.

Preparació. S'analitzen transaccions representatives dels escenaris anteriors i es comparen les explicacions generades amb els fets tècnics confirmats pel motor de regles.

Resultat esperat. L'explicació ha d'indicar correctament el tipus d'operació i el risc associat. No ha de mencionar aprovacions il·limitades, permisos globals, enviament d'ETH o adreces malicioses quan aquests elements no estiguin presents a la transacció analitzada.

Resultat observat. El pilot inicial amb Ollama va revelar que el model proposava ALT0 fins i tot per transferències simples i revocacions, fet que generava quatre falsos positius. Es va reforçar el control semàntic perquè una IA complementària no pugui elevar un risc BAJ0 sense una aprovació il·limitada, un permís global actiu o una etiqueta objectiva de risc. També es va ampliar el sanejament després de detectar una referència inventada a un permís de tokens en una transferència simple. En la revisió visual final va aparèixer una nova variant, “*Se permite mover tokens*”, que expressava la mateixa autorització inexistente sense utilitzar la paraula *permiso*. Es van afegir variants semàntiques equivalents a la regla i una prova de regressió. Després de reiniciar els serveis, la mateixa operació va conservar el veredict BAJ0 i va generar una explicació local segura: una transferència simple sense permisos de tokens. Les 80 observacions automatitzades van permetre confirmar la consistència dels patrons principals i detectar, separatament, el límit de classificació documentat al cas C2.

Evidència. Prompts, respostes d'Ollama, camps `ai_review`, explicació final i resultats de la capa de sanejament semàntic, amb la comparació abans i després a la Figura 22.



(a) Abans: autorització de tokens inventada per la IA (b) Després: explicació local coherent amb els fets

Figura 22: Validació del sanejament semàntic aplicat a una transferència simple

5.4.7 Escenari G – Flux complet sobre Sepolia i Etherscan

Objectiu. Validar el recorregut complet del sistema sobre una transacció real generada des d'Etherscan i dirigida a un contracte desplegat a Sepolia.

Requisits validats. RF1, RF2, RF4, RNF2 i parcialment RNF1.

Preparació. S'utilitza la interfície *Write Contract* d'Etherscan per generar una transacció sobre un dels contractes de prova desplegats a Sepolia.

Resultat esperat. La transacció ha de ser rebuda per MetaMask Flask, interceptada pel Snap, analitzada pel backend i presentada com un *insight* abans de la confirmació.

Resultat observat. Es va executar `approve(spender,1)` des d'Etherscan sobre el contracte `0xA32D...a363`. MetaMask va mostrar l'anàlisi abans de confirmar, el backend el va desar com a registre 46 i la transacció va quedar confirmada al bloc 11299926 amb el *hash* `0x1246bec0...a988d9c`. El veredict va ser `BAJO`, puntuació 20 i `ALLOW`.

Evidència. Captura d'Etherscan, captura de MetaMask, resposta del backend i identificador de la transacció confirmada a Sepolia (Figura 23).

5.4.8 Escenari H – Rendiment i comportament davant d'errors

Objectiu. Mesurar el temps de resposta del flux complet i observar el comportament del sistema quan algun component local no està disponible.

Requisits validats. RNF1 i RNF3.

Preparació. Es realitzen diverses execucions representatives amb tots els serveis actius. Posteriorment, es repeteix la prova aturant temporalment Ollama o el backend local.

Resultat esperat. Amb tots els serveis actius, la resposta s'ha de generar en un temps compatible amb una interacció fluida. Davant d'un error, el sistema ha d'informar de la indisponibilitat del component sense bloquejar de manera injustificada la transacció.

Resultat observat. Amb Ollama actiu, els set casos van requerir entre 135,4 i 169,9 segons, amb una mitjana de 158,1 segons. En aturar Ollama, la primera prova va revelar

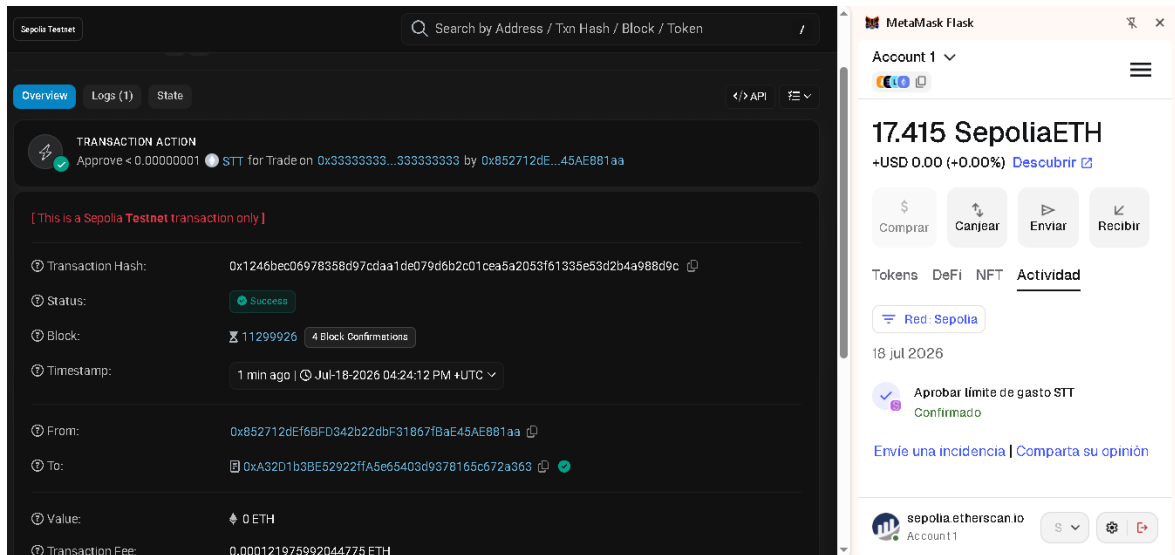
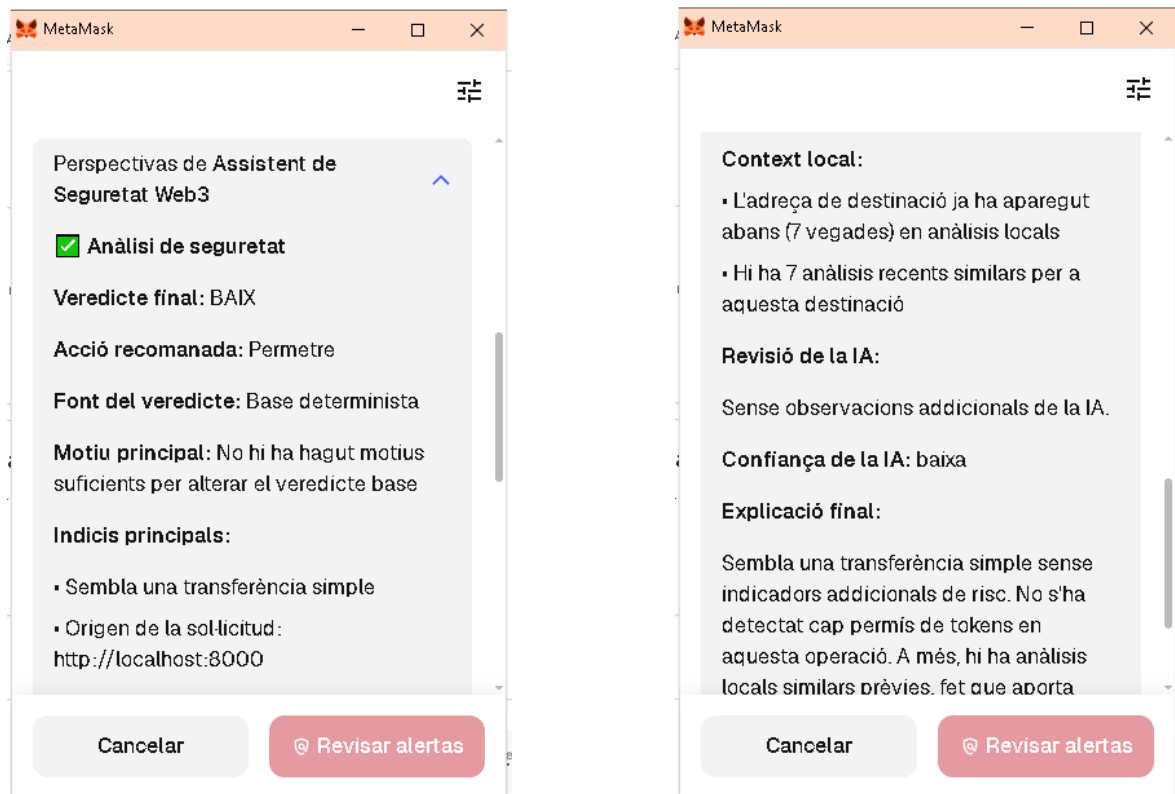


Figura 23: Transacció confirmada a Sepolia i activitat corresponent a MetaMask

que la generació de l'explicació no capturava l'error i provocava HTTP 500; el Snap va mostrar un fallback **DESCONOCIDO** sense bloquejar la cancel·lació. Després d'afegir una explicació local de reserva, la repetició va conservar el veredict determinista **BAJO** i va completar el backend en 93 ms. Aquest resultat correspon al registre 48.

Evidència. Registre dels temps mesurats, captures de la interfície (Figura 24), registres del backend i observació del comportament de MetaMask.



(a) Conservació del veredict determinista

(b) Explicació local sense observacions de la IA

Figura 24: Resposta determinista després d'aturar Ollama i aplicar el fallback local

5.5 Anàlisi dels resultats

Un cop presentats els escenaris i les evidències recollides, aquest apartat analitza els resultats des de tres perspectives complementàries. En primer lloc, es quantifica la capacitat de classificació del sistema mitjançant una matriu de confusió i les mètriques derivades. A continuació, es contrasta cada requisit definit al Capítol 3 amb les evidències obtingudes. Finalment, es delimita l'abast dels resultats i s'interpreten els casos límit detectats.

5.5.1 Matriu de confusió i mètriques de classificació

Per complementar l'anàlisi individual dels escenaris, s'ha utilitzat una matriu de confusió amb l'objectiu d'avaluar la capacitat del sistema per diferenciar entre operacions potencialment perilloses i operacions que no requereixen una alerta de seguretat elevada.

Per construir aquesta matriu, els nivells de risc proporcionats pel sistema s'han agrupat en dues classes. Una predicció es considera positiva quan el veredict final és **MEDIO** o **ALTO**, o quan l'acció recomanada és revisar l'operació abans de confirmarla. En canvi, una predicció es considera negativa quan el resultat és **BAJO** i l'acció recomanada permet continuar sense una alerta elevada.

La classe real de cada prova s'ha definit prèviament a partir de la naturalesa de l'operació executada dins de l'entorn controlat. Es consideren casos positius les aprovacions ERC20 il·limitades, els permisos globals NFT actius i les interaccions amb adreces etiquetades com a malicioses o d'alt risc. Es consideren casos negatius les revocacions de permisos, les aprovacions limitades dirigides als contractes de prova i les transferències simples sense indicadors addicionals de risc.

Aquesta simplificació binària permet calcular els quatre resultats habituals d'una matriu de confusió:

- **Vertader positiu (VP):** una operació realment perillosa és classificada pel sistema com a operació de risc.
- **Fals positiu (FP):** una operació considerada segura dins de l'escenari controlat és classificada com a operació de risc.
- **Vertader negatiu (VN):** una operació segura és classificada correctament com a risc baix.
- **Fals negatiu (FN):** una operació realment perillosa és classificada incorrectament com a risc baix.

La Taula 9 mostra els casos utilitzats per construir la matriu. Cada fila es va executar deu vegades i cada repetició es comptabilitza com una observació independent. La columna **Classe real** no representa la resposta produïda pel sistema, sinó l'etiqueta de referència assignada abans de la prova segons l'efecte conegut de l'operació. La classe real és **positiva** quan l'operació hauria de provocar una alerta perquè concedeix un permís crític o implica una adreça de risc; és **negativa** quan correspon a una operació limitada, una revocació o una transferència sense indicadors de perill. Aquesta etiqueta

de referència es compara amb la predicció del prototip per determinar si el resultat és un VP, un VN, un FP o un FN.

Cas	Operació analitzada	Classe real	Predicció del sistema	Resultat
A1	Transacció simple sense indicadors de risc	Negativa	BAJO	VN
B1	Aprovació ERC20 limitada a un contracte de prova	Negativa	BAJO	VN
B2	Revocació ERC20 mitjançant <code>approve(spender, 0)</code>	Negativa	BAJO	VN
C1	Aprovació ERC20 il·limitada mitjançant <code>MaxUint256</code>	Positiva	ALTO	VP
C2	Aprovacions ERC20 de frontera amb deu quantitats variables	7 positives / 3 negatives	BAJO	7 FN / 3 VN
D1	Activació d'un permís global mitjançant <code>setApprovalForAll(operator, true)</code>	Positiva	ALTO	VP
D2	Revocació del permís global mitjançant <code>setApprovalForAll(operator, false)</code>	Negativa	BAJO	VN
E1	Interacció amb una adreça etiquetada com a maliciosa o d'alt risc	Positiva	ALTO	VP
G1	Transacció real limitada sobre Sepolia	Negativa	BAJO	VN (integració)

Taula 9: Classificació dels casos utilitzats per construir la matriu de confusió

A partir dels resultats individuals, s'obté la matriu de confusió representada a la Figura 25. La intensitat del color de cada cel·la és proporcional al nombre d'observacions que conté, de manera que la concentració dels encerts a la diagonal principal i l'absència de falsos positius resulten immediatament visibles.

A partir de la matriu es poden calcular diverses mètriques quantitatives. L'exactitud representa la proporció total de classificacions correctes:

$$\text{Exactitud} = \frac{VP + VN}{VP + VN + FP + FN}$$

La precisió indica quina proporció de les operacions marcades com a risc eren realment positives:

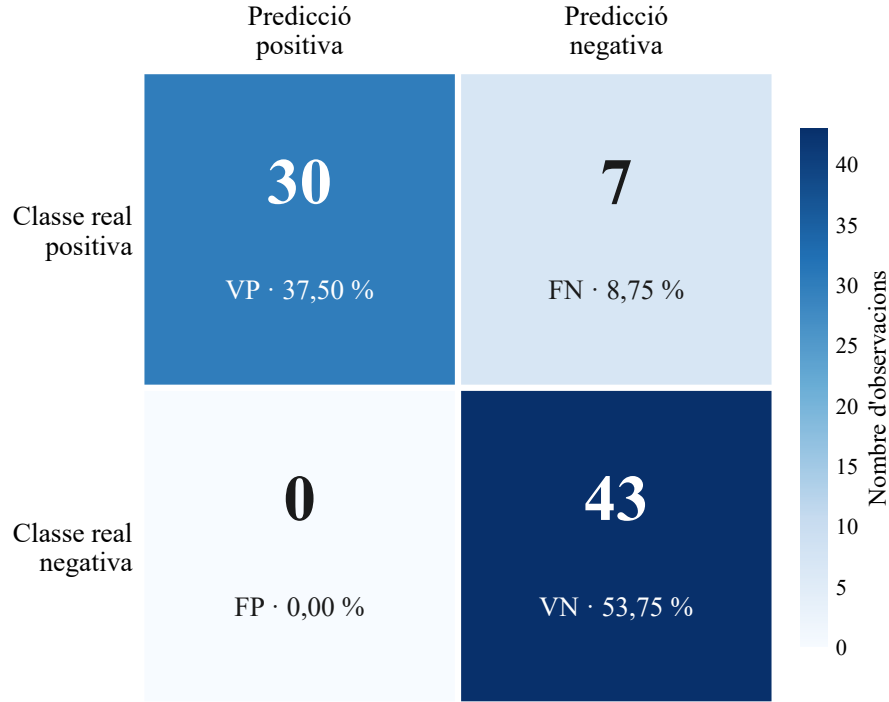


Figura 25: Matriu de confusió de la classificació de risc

$$\text{Precisió} = \frac{VP}{VP + FP}$$

La sensibilitat o *recall* mesura la capacitat del sistema per detectar les operacions realment perilloses:

$$\text{Sensibilitat} = \frac{VP}{VP + FN}$$

L'especificitat mesura la capacitat de classificar correctament les operacions segures:

$$\text{Especificitat} = \frac{VN}{VN + FP}$$

Finalment, la mètrica F1 combina la precisió i la sensibilitat en un únic valor:

$$F1 = 2 \cdot \frac{\text{Precisió} \cdot \text{Sensibilitat}}{\text{Precisió} + \text{Sensibilitat}}$$

Els resultats finals obtinguts són els següents:

La matriu es calcula sobre vuit casos i un total de 80 observacions: 37 positives i 43 negatives. El cas C2 aporta set falsos negatius reals: el descodificador només marca com a il·limitada una aprovació exactament igual a `MaxUint256`, de manera que quantitats lleugerament inferiors, però encara superiors a 2^{255} , conserven un veredicta `BAJO`. Les tres quantitats acotades del mateix cas es classifiquen correctament. G1 valida la integració real i no es torna a comptabilitzar perquè reproduïx una aprovació limitada ja representada per B1.

Mètrica	Resultat
Exactitud	0,9125 (91,25 %)
Precisió	1,0000 (100 %)
Sensibilitat	0,8108 (81,08 %)
Especificitat	1,0000 (100 %)
F1	0,8955 (89,55 %)

Taula 10: Mètriques obtingudes a partir de la matriu de confusió

El resultat mostra que el motor és precís quan genera una alerta, ja que no produeix falsos positius en aquest conjunt, però també identifica una àrea concreta de millora en la sensibilitat davant d'aprovacions extraordinàriament elevades que no coincideixen exactament amb el màxim representable.

5.5.2 Síntesi del compliment dels requisits

Un cop executats els escenaris de prova i analitzats els resultats obtinguts, es pot valorar el grau de compliment dels requisits funcionals i no funcionals definits al Capítol 3. Aquesta síntesi permet relacionar les funcionalitats previstes inicialment amb les evidències recollides durant l'avaluació.

Es considera que un requisit està **complet** quan la capacitat definida s'ha implementat i existeix almenys una evidència funcional que en demostra el comportament dins de l'abast del prototip. Les oportunitats d'ampliació detectades durant les proves s'analitzen separadament i no es confonen amb l'absència de la funcionalitat requerida.

Requisit	Estat	Justificació	Evidència principal
RF1 – Intercepció de transaccions	Complert	El Snap es va activar abans de la confirmació tant des de la DApp com des d'Etherscan.	Escenaris A i G.
RF2 – Anàlisi de risc basat en regles	Complert	El motor aplica regles reproduïbles sobre aprovacions ERC20, permisos ERC721 i adreces etiquetades, i la prova de frontera n'ha delimitat la cobertura.	Escenaris B, C, D i E.
RF3 – Generació d'explicacions comprensibles	Complert	El sistema genera explicacions breus i planeres, i el control semàntic comprova que siguin compatibles amb els fets detectats.	Escenari F.
RF4 – Integració dins la interfície de la cartera	Complert	MetaMask va mostrar risc, acció, indicis principals i explicació abans de confirmar o cancel·lar.	Escenaris A i G.
RNF1 – Rendiment	Complert	El sistema registra els temps de cada etapa i conserva una resposta determinista operativa quan el servei d'IA no està disponible.	Escenari H i registres temporals.
RNF2 – Privadesa	Complert	Backend, SQLite i Ollama s'executen localment; les connexions externes es limiten a Sepolia, Etherscan i les fonts de context.	Revisió arquitectònica i Escenari G.
RNF3 – Fiabilitat	Complert	La indisponibilitat d'Ollama conserva el veredict determinista, proporciona una explicació local i no bloqueja MetaMask.	Escenari H.
RNF4 – Extensibilitat	Complert	Les correccions es van incorporar al sanejament i al fallback sense redissenyar el Snap, les regles ni la persistència.	Arquitectura i implementació del Capítol 4.
RNF5 – Usabilitat	Complert	La interfície presenta primer el veredict, l'acció recomanada i els motius, i amplia després el context i l'explicació.	Escenaris A, F i G.

Taula 11: Síntesi del compliment dels requisits del sistema

La Taula 11 resumeix l'estat de cada requisit i les evidències principals utilitzades per justificar-ne la valoració.

Els resultats mostren que tots els requisits definits disposen d'una implementació funcional i d'evidències associades. La valoració correspon a l'abast establert per al prototip; les ampliacions identificades durant l'avaluació es recullen com a línies d'evolució al Capítol 6.

5.5.3 Abast i interpretació dels resultats

L'avaluació confirma el funcionament coordinat de la DApp, MetaMask, el Snap, el *backend*, SQLite, Ollama i els contractes desplegats a Sepolia. Les 80 observacions automatitzades, les proves manuals i la confirmació d'una transacció real permeten validar els requisits del prototip i mesurar de manera reproducible el comportament dels patrons implementats.

La prova de frontera C2 aporta una delimitació especialment útil: el motor detecta l'aprovació exactament igual a `MaxUint256`, però no eleva el risc d'altres quantitats extraordinàriament elevades. Aquest resultat no afecta la resta de regles verificades i defineix una ampliació concreta del criteri d'aprovacions ERC20 per a una iteració posterior. De manera similar, la cobertura es pot estendre en el futur a les signatures de dades tipades EIP-712 [30], a les aprovacions per signatura o *permit* [31], a les multicrides que agrupen diverses operacions dins d'una mateixa transacció [28] i a operacions pròpies de protocols DeFi. Aquestes extensions es detallen al Capítol 6.

Els resultats de rendiment corresponen a l'equip local i al model `llama3.2:latest` utilitzats durant les proves. La separació entre el motor determinista i la capa d'IA permet conservar el veredict i una explicació local quan Ollama no està disponible, mentre que equips més potents, models més compactes o una única consulta estructurada podrien reduir el temps de generació.

Per tant, les mètriques descriuen el conjunt controlat avaluat i no pretenen certificar totes les amenaces possibles de l'ecosistema Web3. Dins d'aquest abast, el prototip demostra una arquitectura funcional, reproducible i extensible, i els casos límit observats proporcionen objectius tècnics precisos per continuar-ne l'evolució.

6 Conclusions

El projecte ha assolit l'objectiu de desenvolupar un prototip funcional d'assistent de seguretat Web3 integrat a MetaMask mitjançant un Snap. El sistema intercepta les sol·licituds abans de la confirmació, normalitza i descodifica la informació disponible, aplica regles deterministes, incorpora context local i utilitza un model de llenguatge com a capa complementària. El resultat es presenta a l'usuari mitjançant un *insight* que resumeix el nivell de risc, els motius principals, l'acció recomanada i una explicació entenedora.

L'arquitectura proposada s'ha materialitzat en components diferenciats per a la DApp, el Snap, el backend, el motor de regles, la descodificació, la persistència SQLite [26], les fonts de context i Ollama. Aquesta separació facilita la traçabilitat de les decisions, permet conservar una resposta determinista quan la IA no està disponible i possibilita evolucionar cada component sense redissenyar el flux complet.

El conjunt controlat de 80 observacions va obtenir una exactitud del 91,25 % i una mètrica F1 del 89,55 %. Els set errors observats corresponen a aprovacions de quantitat molt elevada, però diferents de `MaxUint256`. Per tant, identifiquen una limitació concreta de cobertura i no un comportament aleatori del sistema. També es va validar el recorregut complet d'una operació real sobre la xarxa de proves Sepolia [29], des d'Etherscan fins a MetaMask, el Snap i el backend, així com el funcionament del *fallback* quan Ollama no està disponible.

El desenvolupament ha seguit un procés iteratiu. Cada versió es va construir a partir dels resultats i les limitacions de l'anterior. Primer es va establir la intercepció, després s'hi van incorporar la descodificació i les regles, i posteriorment la persistència, el context local, la IA i els controls de coherència. Les proves van permetre detectar i corregir elevacions de risc sense evidència, explicacions incompatibles amb l'operació analitzada i un error de connexió durant la segona consulta a Ollama. D'aquesta manera, cada iteració no només va ampliar funcionalitats, sinó que va reforçar la robustesa i la capacitat d'auditoria del prototip.

En conjunt, el treball demostra que és viable combinar regles verificables, memòria local i intel·ligència artificial generativa per aportar context abans de signar una operació Web3. La contribució principal no és substituir la decisió de l'usuari, sinó reduir l'opacitat de la signatura i oferir una advertència justificable en el mateix punt en què encara es pot cancel·lar l'acció.

6.1 Treball futur

Les limitacions identificades defineixen línies d'evolució concretes. La prioritat és millorar el temps de resposta de la capa d'IA. Les mesures es van obtenir en un ordinador portàtil d'ús general, executant el model localment i sense infraestructura dedicada d'inferència. En aquest context, Ollama concentra gairebé tota la latència, mentre que el motor determinista i la persistència responen amb rapidesa. Per això, el rendiment observat no invalida l'arquitectura, però sí que indica que una versió orientada a ús quotidià hauria de combinar les dues consultes al model, reduir els *prompts*, emprar models més lleugers, reutilitzar resultats equivalents i aplicar un temps màxim després del qual es mostri immediatament el veredict determinista.

També convé ampliar la cobertura del motor de regles, que actualment només decodifica `approve` i `setApprovalForAll` sobre els estàndards ERC20 [15] i ERC721 [16]. Les extensions més rellevants són les següents:

- **Llindars configurables per a aprovacions elevades.** Actualment només es considera il·limitada una quantitat exactament igual a `MaxUint256`. Un llindar parametrizable permetria cobrir els casos de frontera detectats a l'escenari C2.
- **Signatures EIP-712 [30].** L'estàndard EIP-712 defineix com signar dades estructurades i tipades en lloc de cadenes de bytes opaques. Aquestes signatures no són transaccions i, per tant, no arriben al punt d'entrada `onTransaction`, però poden autoritzar operacions amb conseqüències econòmiques reals.
- **Aprovacions per signatura o *permit* [31].** L'extensió EIP-2612 permet concedir una aprovació ERC20 mitjançant una signatura fora de cadena, sense enviar cap transacció d'`approve`. És un vector especialment rellevant, perquè l'usuari pot atorgar un permís de despesa sense que la cartera li mostri una operació d'aprovació convencional.
- **Multicrides (*multicall*).** Es tracta d'agrupar diverses crides a contracte dins d'una única transacció [28]. El descodificador actual només interpreta el selector exterior, de manera que una operació de risc pot quedar amagada dins del lot.
- **Protocols DeFi i més selectors estàndard,** com ara operacions d'intercanvi, préstec o dipòsit en agrupacions de liquiditat.

Aquesta ampliació s'hauria d'acompanyar d'un conjunt de proves més extens i divers, amb repeticions automatitzades, contractes reals i comparació entre models i configuracions de maquinari.

Finalment, un estudi amb usuaris permetria mesurar la comprensió real dels *insights*, ajustar-ne el llenguatge i validar-ne l'accessibilitat. Una altra millora funcional seria afegir un canal posterior a la confirmació que associés automàticament el *hash* de la transacció amb el registre previ de l'anàlisi. Aquestes línies permetrien transformar el prototip validat en una eina més completa, ràpida i preparada per a un entorn d'ús real.

6.2 Competència CT7: principis ètics i de responsabilitat social

Aquest apartat analitza el projecte des de la competència transversal CT7, «Aplicar els principis ètics i de responsabilitat social com a ciutadà o ciutadana i com a professional». Per a cadascun dels quatre indicadors que la componen es valora si el treball hi té implicacions i, quan és així, de quina manera s'han tingut en compte.

6.2.1 Igualtat

El nucli de decisió del sistema és determinista i opera exclusivament sobre dades tècniques de la transacció, com ara el selector de la funció, l'adreça de destinació, la quantitat aprovada o el valor booleà d'un permís global. Aquestes dades no contenen cap atribut demogràfic, de manera que el motor de regles no pot introduir un biaix

de gènere: davant de la mateixa entrada produeix sempre la mateixa sortida, amb independència de qui signi l'operació.

La capa d'intel·ligència artificial generativa sí que constitueix un punt de risc, perquè els models de llenguatge hereten els biaixos presents en les dades amb què s'han entrenat. En aquest projecte l'exposició es redueix per disseny: el model no decideix el nivell de risc, no rep cap dada personal de l'usuari i la seva sortida se sotmet a una capa de control semàntic que la descarta quan contradiu els fets verificats. Tot i això, el llenguatge de les explicacions generades no s'ha auditat específicament des d'una perspectiva de gènere, i aquesta seria una comprovació necessària abans d'un desplegament real.

Pel que fa a l'accés, l'assistent utilitza llenguatge planer i presenta primer la decisió i els motius principals, la qual cosa pot reduir la barrera d'entrada de les persones amb menys formació tècnica. Aquest punt és rellevant perquè l'ecosistema de les criptomonedes presenta una bretxa de participació per gènere àmpliament documentada, i les eines que exigeixen coneixements especialitzats tendeixen a reforçar-la. No obstant això, no s'ha dut a terme cap estudi d'accessibilitat ni cap prova amb participants diversos, de manera que no es pot afirmar que la interfície sigui igualment comprensible per a tots els perfils. Una evolució responsable hauria d'incloure proves d'accessibilitat, compatibilitat amb tecnologies assistives i disponibilitat en més idiomes.

6.2.2 *Medi ambient*

El projecte té dues implicacions ambientals clares. La primera deriva de la decisió d'executar la intel·ligència artificial en local. Aquesta opció evita enviar dades a centres de processament remots, però trasllada el consum energètic al dispositiu de l'usuari. Les mesures obtingudes mostren que aquest consum no és menyspreable: cada anàlisi requereix dues inferències consecutives i un temps mitjà de 158,1 segons, un ús clarament ineficient dels recursos disponibles.

Aplicar la perspectiva mediambiental a la solució proposada implica, per tant, tractar l'eficiència com un requisit i no com una simple millora de rendiment. Les línies de treball futur ja identificades —unificar les dues consultes al model, escurçar els *prompts*, emprar models més compactes, reutilitzar resultats equivalents i activar la IA només quan aportí informació que les regles no cobreixen— redueixen simultàniament la latència i l'energia consumida per operació.

La segona implicació és indirecta i afecta l'objecte mateix del treball. Les xarxes blockchain tenen una petjada energètica associada a la validació de transaccions. Un assistent que ajuda l'usuari a detectar i cancel·lar operacions abusives abans de signar-les evita transaccions innecessàries i, amb elles, el consum corresponent. Tota l'avaluació s'ha fet, a més, sobre una xarxa de proves, sense consumir recursos de la xarxa principal.

6.2.3 *Responsabilitat social*

La necessitat social que motiva el treball és concreta i documentada: cada any es perden milers de milions de dòlars en estafes i explotacions dins l'ecosistema Web3 [5, 7], i una part significativa d'aquestes pèrdues no es deriva d'un error del protocol, sinó del fet que una persona autoritza una operació que no comprèn. El col·lectiu més

exposat és precisament el que té menys coneixements tècnics.

La resposta del projecte a aquesta problemàtica consisteix a intervenir en el moment previ a la signatura, que és l'últim punt en què la decisió encara es pot revertir, i a explicar el motiu del risc en lloc de limitar-se a emetre una alerta. Aquest enfocament comporta, però, una responsabilitat afegida. El sistema es planteja com una ajuda a la decisió i mai com una garantia de seguretat, i el capítol de disseny delimita explícitament les amenaces que queden fora del seu abast. Els *insights* han de comunicar aquestes limitacions i evitar l'alarmisme, ja que un excés de falses alertes acabaria provocant que l'usuari les ignorés sistemàticament.

Finalment, el fet que el prototip s'hagi construït amb eines de codi obert i s'hagi publicat en un repositori accessible permet que altres persones el revisin, el critiquin o el reutilitzin, cosa que reverteix el resultat del treball en la comunitat.

6.2.4 Ètica

Dins de l'àmbit de la seguretat informàtica, el principi deontològic més directament implicat en aquest treball és el de no atribuir conductes malicioses sense evidència suficient. Assenyalar una adreça com a fraudulenta té conseqüències reals per a qui n'és titular. Per aquest motiu, les etiquetes procedents de fonts externes [27] es tracten com a context complementari i no com una prova absoluta, i la memòria fa explícit que aquestes llistes poden contenir errors o informació desactualitzada.

El segon compromís ètic afecta l'ús de la intel·ligència artificial. El model de llenguatge s'ha emprat com a component del prototip i també com a suport durant el desenvolupament i la redacció de la memòria. En cap dels dos casos se n'han acceptat els resultats de manera automàtica. Dins del sistema, les respostes es contrasten amb els fets semàntics detectats, se'n filtren les contradiccions i es conserva la resposta original per garantir la traçabilitat de la decisió. Aquesta subordinació de la IA al motor determinista no és només una decisió tècnica, sinó també una manera d'assumir que una eina de seguretat ha de poder justificar els seus veredictes davant de qui els rep.

El tercer element és la privadesa. Processar les transaccions en local evita exposar a tercers informació sobre l'activitat econòmica de l'usuari, coherentment amb el principi de minimització de dades. Les úniques connexions externes són les estrictament necessàries per consultar l'estat de la xarxa.

Assumir aquestes decisions implica també reconèixer-ne les conseqüències. La més rellevant és que el sistema pot generar falsos negatius, com els set documentats a l'escenari C2. Presentar aquest límit de manera explícita, en lloc de reportar únicament les mètriques favorables, forma part de l'ús responsable dels resultats obtinguts.

Referències

- [1] V. Buterin, “Ethereum whitepaper,” [En línia]. Disponible a: <https://ethereum.org/whitepaper/>, 2014, consulta: 23 de juliol de 2026.
- [2] Chainalysis, “2024 crypto crime trends: Illicit activity down as scamming and stolen funds fall, but ransomware and darknet markets see growth,” [En línia]. Disponible a: <https://www.chainalysis.com/blog/2024-crypto-crime-report-introduction/>, 2024, consulta: 23 de juliol de 2026.
- [3] Coinbase, “What is crypto blind signing?” [En línia]. Disponible a: <https://www.coinbase.com/es-la/learn/crypto-glossary/what-is-crypto-blind-signing>, 2024, consulta: 23 de juliol de 2026.
- [4] Ledger Academy, “Blind signing explained,” [En línia]. Disponible a: <https://www.ledger.com/academy/cryptos-greatest-weakness-blind-signing-explained>, 2021, consulta: 23 de juliol de 2026.
- [5] Chainalysis, “\$2.2 billion stolen from crypto platforms in 2024,” [En línia]. Disponible a: <https://www.chainalysis.com/blog/crypto-hacking-stolen-funds-2025/>, 2024, consulta: 23 de juliol de 2026.
- [6] Chainalysis, “2025 crypto crime report: Introduction,” [En línia]. Disponible a: <https://www.chainalysis.com/blog/2025-crypto-crime-report-introduction/>, 2025, consulta: 23 de juliol de 2026.
- [7] CertiK, “Hack3d: The Web3 security report 2024,” [En línia]. Disponible a: <https://www.certik.com/blog/hack3d-the-web3-security-report-2024>, 2025, consulta: 23 de juliol de 2026.
- [8] MetaMask Developer Documentation, “Transaction insights,” [En línia]. Disponible a: <https://docs.metamask.io/snaps/features/transaction-insights/>, 2024, consulta: 23 de juliol de 2026.
- [9] MetaMask Developer Documentation, “Snaps entry points: onTransaction,” [En línia]. Disponible a: <https://docs.metamask.io/snaps/reference/entry-points/>, 2024, consulta: 23 de juliol de 2026.
- [10] MetaMask Developer Documentation, “Snaps permissions: endowment:transaction-insight,” [En línia]. Disponible a: <https://docs.metamask.io/snaps/reference/permissions/>, 2024, consulta: 23 de juliol de 2026.
- [11] Consensusys, “Consensusys announces public launch of MetaMask Snaps,” [En línia]. Disponible a: <https://consensusys.io/blog/consensusys-announces-public-launch-of-metamask-snaps>, 2023, consulta: 23 de juliol de 2026.
- [12] Triple-A, “Global crypto ownership reaches 562 million people in 2024,” [En línia]. Disponible a: <https://www.triple-a.io/blog/crypto-ownership-report>, 2024, consulta: 23 de juliol de 2026.

- [13] Solidity Team, “Solidity documentation,” [En línia]. Disponible a: <https://docs.soliditylang.org/en/latest/>, 2025, consulta: 23 de juliol de 2026.
- [14] Ethereum EIPs, “EIP-1193: Ethereum provider JavaScript API,” [En línia]. Disponible a: <https://github.com/ethereum/EIPs/blob/master/EIPS/eip-1193.md>, 2018, consulta: 23 de juliol de 2026.
- [15] Ethereum EIPs, “EIP-20: Token standard,” [En línia]. Disponible a: <https://eips.ethereum.org/EIPS/eip-20>, 2015, consulta: 23 de juliol de 2026.
- [16] Ethereum EIPs, “EIP-721: Non-fungible token standard,” [En línia]. Disponible a: <https://eips.ethereum.org/EIPS/eip-721>, 2018, consulta: 23 de juliol de 2026.
- [17] Nomic Foundation, “Hardhat documentation,” [En línia]. Disponible a: <https://hardhat.org/docs/getting-started>, 2025, consulta: 23 de juliol de 2026.
- [18] Ollama, “Ollama API introduction,” [En línia]. Disponible a: <https://docs.ollama.com/api/introduction>, 2025, consulta: 23 de juliol de 2026.
- [19] Ollama, “Ollama API authentication,” [En línia]. Disponible a: <https://docs.ollama.com/api/authentication>, 2025, consulta: 23 de juliol de 2026.
- [20] Wallet Guard, “Wallet Guard,” [En línia]. Disponible a: <https://www.walletguard.app/>, 2025, consulta: 23 de juliol de 2026.
- [21] Pocket Universe, “Pocket Universe,” [En línia]. Disponible a: <https://www.pocketuniverse.app/>, 2025, consulta: 23 de juliol de 2026.
- [22] Blockaid, “Blockaid transaction security,” [En línia]. Disponible a: <https://www.blockaid.io/transaction-security>, 2025, consulta: 23 de juliol de 2026.
- [23] Blockfence, “Blockfence,” [En línia]. Disponible a: <https://blockfence.io/>, 2025, consulta: 23 de juliol de 2026.
- [24] Rabby Wallet, “Rabby Wallet,” [En línia]. Disponible a: <https://rabby.io/>, 2025, consulta: 23 de juliol de 2026.
- [25] J. Nielsen, “Response times: The 3 important limits,” [En línia]. Disponible a: <https://www.ngroup.com/articles/response-times-3-important-limits/>, Nielsen Norman Group, 1993, consulta: 23 de juliol de 2026.
- [26] SQLite Consortium, “SQLite documentation,” [En línia]. Disponible a: <https://www.sqlite.org/docs.html>, 2025, consulta: 23 de juliol de 2026.
- [27] MyEtherWallet, “ethereum-lists: darklist and lightlist address datasets,” [En línia]. Disponible a: <https://github.com/MyEtherWallet/ethereum-lists>, 2025, consulta: 23 de juliol de 2026.
- [28] OpenZeppelin, “OpenZeppelin Contracts documentation,” [En línia]. Disponible a: <https://docs.openzeppelin.com/contracts>, 2025, consulta: 23 de juliol de 2026.
- [29] Ethereum Foundation, “Networks: Sepolia test network,” [En línia]. Disponible a: <https://ethereum.org/en/developers/docs/networks/>, 2025, consulta: 23 de juliol de 2026.

- [30] Ethereum EIPs, “EIP-712: Typed structured data hashing and signing,” [En línia]. Disponible a: <https://eips.ethereum.org/EIPS/eip-712>, 2017, consulta: 23 de juliol de 2026.
- [31] Ethereum EIPs, “EIP-2612: Permit – 712-signed approvals,” [En línia]. Disponible a: <https://eips.ethereum.org/EIPS/eip-2612>, 2020, consulta: 23 de juliol de 2026.

A Instruccions d'instal·lació i execució

Aquest annex descriu els passos necessaris per recuperar el codi font, instal·lar les dependències i executar els diferents components del prototip. L'objectiu és facilitar la reproducció de l'entorn utilitzat durant el desenvolupament i l'avaluació del sistema.

A.1 Requisits previs

Abans d'executar el projecte, és necessari disposar dels components següents:

- Node.js i npm;
- MetaMask Flask;
- Ollama;
- el model local `llama3.2:latest`;
- Git;
- un navegador compatible amb MetaMask Flask;
- accés a un endpoint RPC de Sepolia;
- ETH de prova de la xarxa Sepolia.

Les versions exactes utilitzades durant l'avaluació es recullen a la Taula 5.

A.2 Descàrrega del repositori

El codi font del projecte es pot obtenir des del repositori de GitHub mitjançant l'ordre següent:

```
git clone https://github.com/marccarot0202/
TFG_MarcCarotFigueres.git
cd TFG_MarcCarotFigueres
```

La versió utilitzada en l'avaluació correspon a l'estat del repositori dels dies 17 i 18 de juliol de 2026. Abans de publicar la versió final es recomana crear una etiqueta Git associada a l'entrega.

A.3 Instal·lació de les dependències

Les dependències generals del projecte s'instal·len des de l'arrel del repositori:

```
yarn install
```

El backend i els contractes disposen també dels seus propis fitxers de dependències:

```
cd backend
npm install
```

```
cd ../smart-contracts
npm install
```

A.4 Instal·lació del model local

El model utilitzat pel prototip es descarrega mitjançant Ollama:

```
ollama pull llama3.2
```

Es pot comprovar que el model està disponible amb:

```
ollama list
```

El servei local d'Ollama ha d'estar accessible a:

```
http://localhost:11434
```

A.5 Configuració de les variables d'entorn

Les credencials i les dades sensibles no s'emmagatzemen directament al repositori. Per executar el desplegament o les consultes sobre Sepolia és necessari crear un fitxer local de variables d'entorn.

Un exemple simplificat de configuració és el següent:

```
SEPOLIA_RPC_URL=URL_DEL_PROVEIDOR_RPC
PRIVATE_KEY=CLAU_PRIVADA_DEL_COMPTE_DE_PROVES
ETHERSCAN_API_KEY=CLAU_DE_L_API
```

Aquest fitxer no s'ha d'incorporar al control de versions ni publicar al repositori.

A.6 Execució dels components

El prototip està format per diversos serveis que s'han d'executar simultàniament. En l'entorn Windows utilitzat per a l'avaluació, la forma recomanada és executar `Iniciador_Portatil.bat` des de l'arrel. Aquest script selecciona Node.js 20.11.1 i obre Ollama, el backend i el *workspace* de la DApp i el Snap en l'ordre correcte.

```
Iniciador_Portatil.bat
```

Les ordres següents descriuen els components per separat amb finalitat de reproducció i diagnòstic; no s'han d'executar simultàniament amb l'iniciador, perquè es produirien conflictes de ports.

A.6.1 Backend local

El backend d'anàlisi s'executa al port 3000:

```
cd backend
node server.js
```

Es pot comprovar el seu estat accedint als endpoints:

```
http://localhost:3000/health
```

```
http://localhost:3000/stats
```


A.6.2 *Snap*

El servidor de desenvolupament del Snap s'executa al port 8080:

```
yarn workspace snap start
```

A.6.3 *DApp local*

La DApp de proves s'executa al port 8000. L'ordre exacta depèn de l'estructura del repositori:

```
yarn workspace site start
```

Un cop iniciada, la interfície queda disponible a:

`http://localhost:8000`

A.7 Ordre recomanat d'inicialització

Per preparar correctament l'entorn, es recomana seguir aquest ordre:

1. iniciar Ollama;
2. iniciar el backend local;
3. iniciar el servidor del Snap;
4. iniciar la DApp;
5. obrir MetaMask Flask;
6. instal·lar o reconnectar el Snap;
7. seleccionar la xarxa Sepolia;
8. comprovar l'estat dels serveis des de la DApp;
9. iniciar una operació de prova.

B Estructura de les peticions i respostes JSON

Aquest annex mostra una versió abreujada, però fidel, del contracte real de l'endpoint `/analyze`. Els nivells de risc interns utilitzats pel *backend* són `BAJO`, `MEDIO` i `ALTO`, i les accions són `ALLOW`, `REVIEW` i `BLOCK`. La DApp i el Snap en mostren els equivalents en català, però el contracte conserva aquests valors per compatibilitat.

B.1 Petició enviada pel Snap

```
1 {
2   "chainId": "eip155:11155111",
3   "from": "0x852712de...45AE881aa",
4   "to": "0xA32D1b3B...c672a363",
5   "value": "0x0",
6   "data": "0x095ea7b3...0001",
7   "origin": "https://sepolia.etherscan.io"
8 }
```

El camp `data` conté la `calldata`; els primers quatre bytes formen el selector. En aquest exemple, `0x095ea7b3` correspon a `approve(address,uint256)`.

B.2 Risposta rappresentativa del backend

[illegible]

```

35     "reason": "No hi ha hagut motius suficients per alterar el
        veredict base"
36 },
37 "analysis_id": 48,
38 "performance": {
39     "ai_review_ms": 29,
40     "explanation_ms": 10,
41     "persistence_ms": 38,
42     "total_backend_ms": 93
43 },
44 "evaluation": null,
45 "timestamp": "2026-07-18T16:35:41.289Z"
46 }

```

La resposta diferencia el veredict determinista, la revisió complementària, el veredict final i les mesures de rendiment. `raw_response` conserva la sortida original d'Ollama quan existeix; si el servei no està disponible, queda a `null` i el sistema utilitza una explicació local segura. Els indicis del camp `findings` són cadenes de text, no objectes amb camps `code` o `severity`.

B.3 Persistència i detall

`analysis_id` identifica el registre d'`analysis_history`. El detall recuperat des de `/analysis-history/:id` afegeix els camps complets de transacció normalitzada, senyals de memòria local, coincidències amb adreces conegudes i fets semàntics. El *hash* d'una transacció confirmada no forma part de la resposta prèvia a la confirmació, perquè encara no existeix en el moment de l'anàlisi.

C Configuració de Sepolia i contractes desplegats

Aquest annex recull la configuració blockchain utilitzada durant el desenvolupament i l'avaluació, així com les adreces dels contractes intel·ligents desplegats a la xarxa de proves Sepolia.

C.1 Configuració de la xarxa

La configuració general utilitzada és la següent:

Paràmetre	Valor
Xarxa	Sepolia
Identificador de cadena	11155111
Identificador hexadecimal	0xaa36a7
Moneda nativa	Sepolia ETH
Proveïdor RPC	Google Cloud Web3 Portal
Explorador de blocs	Etherscan Sepolia
Entorn de desplegament	Hardhat

Taula 12: Configuració de la xarxa utilitzada durant les proves

L'URL concreta del node RPC no es publica a la memòria quan incorpora credencials o identificadors privats. Aquesta informació es proporciona mitjançant variables d'entorn durant l'execució.

C.2 Contractes desplegats

La Taula 13 recull els contractes utilitzats durant les proves.

Contracte	Adreça a Sepolia	Finalitat
SecurityTestContract	0xA32D1b3BE52922ffa5e65403d9378165c672a363	Generació d'aprovacions ERC20 limitades, revocacions i aprovacions elevades.
SecurityTestNFT	0x216033047ffbec7eb223bf206e4d440f644500d3	Generació de permisos globals ERC721 mitjançant setApprovalForAll.

Taula 13: Contractes intel·ligents desplegats a Sepolia

C.3 Verificació dels contractes

Els contractes es van verificar mitjançant Etherscan, fet que permet consultar públicament el codi font, l'ABI i les funcions exposades. Aquesta verificació també facilita la generació manual d'operacions mitjançant la interfície *Write Contract*.

Per a cada contracte es pot registrar:

- l'adreça de desplegament;
- el bloc de desplegament;
- el *hash* de la transacció de desplegament;
- la versió del compilador Solidity;
- els paràmetres del constructor;
- l'estat de verificació a Etherscan.

Element	SecurityTestContract	SecurityTestNFT
Adreça	0xA32D...a363	0x2160...00d3
Bloc de desplegament	No conservat	10588546
Hash del desplegament	No conservat	0xbdd099cf...27417ccb
Pragma de Solidity	~0.8.20	~0.8.20
Verificació	Verificat a Etherscan	Verificat a Etherscan

Taula 14: Informació tècnica dels contractes desplegats

La identitat del contracte **SecurityTestNFT** es va recuperar a partir de l'historial ERC721 del compte de proves i es va contrastar amb Etherscan. El contracte va ser

creat per `0x8527...81aa`, el mateix compte emprat durant l'avaluació, i el rebut del desplegament presenta estat satisfactori. Aquestes dades permeten reproduir els casos D1 i D2 directament des de la interfície *Write Contract* del contracte verificat.